ÉPIGRAPHE

''L'intelligence ce n'est pas ce que l'on sait, mais ce que l'on fait quand on ne sait pas. ''

Jean Piaget

IN MEMORIAM

À mon très cher oncle MAKANDA Macaire qu'on perd de vue parce que la vie l'a changé de rue, la mort est un voleur, un désamour et un sablier sans cœur.

Il faut dire je t'aime à tous ceux qu'on aime tant qu'ils sont vivants.

DEDICACES

Je dédie ce modeste travail

Nous exprimons nos profonds remerciements à celui qui garde l'âme et protège le corps ; **Le Seigneur Jésus Christ** pour nous avoir gardé en bonne santé tout au long de notre cursus universitaire. Et qui a bien voulu que nous achevions le présent travail avec son soutien précieux.

À mes très parents ILIOMO Toussaint et BABA Sabine, pour tant de sacrifices, d'affection, de patience et d'amour consentis à mon égard afin que je m'implique avec triomphe dans le monde des intellectuels.

À mes très chers oncles et tantes ENZAM Dur, MBUKA Jacques, MUNSONI IFUMU Odon, BABA Toussaint, BABA Cyrile et BLANDINE IFUMU, NATHALIE KURU KURU, NENE MBUBI, MICHELINE MANZEKE ont toujours cru en moi, ils m'ont soutenu spirituellement, physiquement, moralement et financièrement pour me voir réussir.

Je remercie également mes grandes sœur Souzy IFUMU, Dalicia BADESIRE et Elvie Augustine ILIOMO pour leurs présences bienveillantes, leur aide financièrement tout au long de cette formation. Elles ont toujours su m'apporter leurs soutiens indéfectibles.

Une particulière gratitude S'adresse au professeur BULANGUNGA Dieudonné et Maman Schola BULANGUNGA pour tout l'aide qu'il apporte à notre famille et plus particulièrement à ma vie Estudiantine, trouver ici l'expression de notre gratitude ainsi que notre sympathie de reconnaissance.

Je dédie affectueusement ce modeste travail
ILIOMO DUR

REMERCIEMENTS

Aux termes du cycle de licence à l'Université de Kinshasa, selon la tradition et les dispositions réglementaires réagissant l'organisation de l'enseignement supérieur et universitaire en République Démocratique du Congo, un travail scientifique doit être rédiger par tout étudiant, le travail qui sanctionne la fin de son cycle de licence.

C'est à ce titre que le présent travail a été rédiger. Il est le fruit de multiples sacrifice et de durs labeurs sur le plan tant intellectuelle, moral que matériel, puisse-t-il dore et déjà constituer une documentation pour le monde scientifique en général et pour quiconque aimerait évoluer dans ce domaine en particuliers.

Ainsi, saisissons-nous cette ultime opportunité pour nous acquitter d'un noble devoir, celui d'exprimer notre gratitude à tous ceux qui ont contribué d'une manière ou d'une autre à la réalisation de ce travail.

Notre profonde et inoubliable reconnaissance s'adresse également au Professeur KASENGEDIA MOTUMBE Pierre et a l'Assistant KANINGINI Junior, respectivement Directeur et Encadreur de ce travail, qui en dépit de leurs multiples fonctions et engagements, ont bien voulu diriger notre mémoire de fin de cycle. Leurs soutient, leurs conseils avisés, leurs avis clairs, leurs bienveillances, leurs critiques et remarques pertinentes nous ont été d'une utilité indispensable pour notre apprentissage et à la réussite de ce travail, et nous ont permis de réaliser notre pensée et ont donné à notre étude sa structuration définitive. Je suis reconnaissant de cette expérience enrichissante et des précieuses leçons que j'ai pu en tirer. Merci infiniment pour cette opportunité et confiance. Je les adresse mes plus sincères remerciement.

Nous exprimons nos remerciements à cœur de joie a tous nos Professeurs, Chefs de travaux et aux Assistants de la Faculté des Sciences et Technologies de l'université de Kinshasa plus particulièrement celle du département de Mathématique, Statistique et Informatique pour tous les enseignements biens riches et l'encadrements adéquat qu'ils nous ont fournis tout au long de notre formation.

A ma grande famille tout entière, ce travail est le fruit de votre amour et le souci de mon devenir. Notre particulières gratitude s'adresse également à nos frères et sœurs ILIOMO, nous pensons à Gisel, Irène, Augustine Elvie, Merovine, Jephté et Josué pour tout ! Sans relâche vous avez su combler en nous l'amour fraternel, ce travail portes aussi vos marques.

Notre grande famille source d'amour et d'équilibre ont notre gratitude : mes sœurs et frères Chamy, Grâce, Mendes, Makanda, Manuella, Divine, Guerda, Benjamine Bulangunga, Prisca Ibwo, Anita Ifumu, Moïse Manoka, Souzy Ifumu, Yvonne Ifumu, Sylvie Ifumu, Judith Musikor, Esther Malu, Sadam Mpamba, Emanuel Manteko, Eureka Mbway et Aristote Mbway, je suis reconnaissant d'avoir une famille aussi formidable, qui me soutient dans mes projets et qui m'encourage a donner le meilleur de moi-même. Merci du fond du cœur pour tout ce que vous faites pour moi durant ces parcours académiques.

Une particulière gratitude s'adresse à l'Assistant Serge MUBIKAY pour tout l'aide qu'il porte à moi durant cette vie Estudiantine. Les mots sont trop modestes pour exprimer la gratitude que l'on porte à l'égard d'un homme rempli d'autant de bonté.

A mes amis, ma deuxième famille NoStress elle a été plus qu'importante dans ma carrière académique et à ce travail, ma famille NoStress, qui est sur la direction de S.E Monsieur YONGO Daniel, HANGI Elie, ISAMENE Jason, MUTOMBO Fabrice, Josué DIANGITUKULU, Jovial KAJIBALE, KALENGA K Axel, MULENGA Joël, MAKUNDA Darius, MULONGO Yves Sans oublier Queen's Christine AMBOKA merci d'être toujours présente en tout pour me soutenir et me propulser d'aller de l'avant.

Aux amis et connaissance : Ricardo Mus, Don BILANDA, Séraphin MULUBA, Sephora KAYOLO, Jonathan AKO, Joel OkENDE, Ange MAVULA, Plamedi MUSIMBA et Jean paul ISAMFWA, sans oublier mon mentor IT MBOMA Erick, IT Taylor MUNTINENE, Ir valentin DEMBA et Ir kardozo, qui ont toujours été là à mes côtés pour me soutenir.

Cordiales gratitudes et sincères remerciements à tous mes compagnons de lutte, nous pensons à LUBANZI Voldi, MOYIKA Luc, IYOKO Nathan, MURHULA Jonathan, KUYANGISA Jonathan, MILOLO Blessing, ALIKO Jier, BUSU Divin, EBE nacris, KABASELE Ben, DIANDJA Garry, Dieudonné LONJI, Gorethie, Exaucé WABA, Exaucé dont nous sommes redevables d'innombrables échanges instructifs, cette page ne peut absolument pas contenir les mots justes seul le très haut sait évaluer vos divers apports.

Que ceux dont le nom ne figure pas sur cette page et qui se considèrent comme oubliés, veuillent bien m'en excuser et qu'ils sachent que je les porte dans mon cœur.

ILIOMO DUR

LISTE DES ACRONYMES

AA : Application Agent
AAA : Authentication, Authorization, Accounting
ABAC : Contrôle d'accès en Fonction de l'attribut
ACL : Access Control List
AES : Advanced Encryption Standard
AIDS : Anomaly Intrusion Detection System
AM : Application Manager
AOR : Address-of-Record
ARP : Address Resolution Protocol
ARPANET : Advanced Research Projets Agency Network
ASCII : American Standard Code for information Interchange
B2BUA : Back-to-Back User Agent
BCDC : Banque Commercial du Congo
BCZ : Banque Commercial Zairoise
CEO : Chief executive officier
DAC : Controle d'acces Discretionnaire
DOS : Déni de Service
DDoS : Déni de service distribué
DES : Data Encryption Standard
DHCP : Dynamic Host Configuration Protocol
DMZ : De-Militarized Zone
DNS : Domain name server
DNSSEC : Domain name server security
DSA : Digital Signature Algorithm
DoS : Denial of Service
EAP : Extensible Authentication Protocol
ECC : Elliptic Curve Cryptography
FAI : Fournisseur d'accès Internet
FDDI : Fiber Distributed Data Interface
FTP : File Transfert Protocol
GIX : Global internet eXchange
GPRS : General Packet Radio Service
GPS : Global Positionning System
GSM : Groupe Spécial Mobile
HIDS : Hosted-based Intrusion Detection System
HIPS : Host-based Intrusion Prevention System
HTTP : HypertText Transfer Protocol
HTTPS : HypertText Transfer Protocol secure
IBM : International business machines
ICMP : Internet Control Message Protocol
IDMEF : Intrusion Detection Message Exchange Format
IDS : Intrusion Detection System
IEEE : Institute of Electrical and Electronic
IETF : Internel Engineering Task Force
IGMP : Internet Group Management Protocol
IMEI : Internationt Mobile Equipment Identity

IP : Internet Protocol
IPNG : Internet Protocol Next Generation
IPS : Intrusion Prevention System
IPSec : Internet Protocol Secuty
IPV4 : Internet Protocol Version 4
IPV6 : Internet Protocol Version 6
ISO : International Standardizing Organization
ISP : Internet Service Provider
IXP : Internet eXchange Provider
KIPS : Kernel Intrusion Prevention System
L2F : Layer 2 Forwarding Protocol
L2TP : Layer Two Tunneling Protocole
LAN : Local Area Network
LDAP : Lightweight Directory Access Protocol
MAC : Media Access Control
MFA : Authentification Multifacteurs
NIDS : Network Intrusion Detection System
NIPS : Network Intrusion Prevention System
NPS : Network Policy Server
NSA : National Security Agency
OS : Operating System
OSI : Open System Interconnections
PME : Petite et Moyen Entreprise
PMI : Petite et Moyen Industrie
POP : Post Office Protocol
RADIUS : Remote Access Dial In User Service
RAID : Reduadant Array of Independent Disks
RBAC : Controle d'access en fonction du role
RC4 : Rivest Cipher 4
RJ45 : Registred Jack 45
RNIS : Réseau Numérique à Intégration de Service
RPV : Réseau privé virtuel
RSA : Rivest Shamir Adleman
RSH : Remote Shell
RTC : Réseau Téléphonique Commuté
RTCP : Real Time Transport Control Protocol
RTP : Real_Time Transport Protocol
SLED : Sigle Large Expensive Drive
SMS : Short Message Service
SMTP : Simple Mail Transfer Protocol
SNMP : Simple Network Management Protocol
SSO Single Sign On
SSH Secure Shell
SSL : Secure Sockets Layer
SQL Structured Query Languag
TCP : Transmission Control Protocol
TELNET : Tele communication Network
TLS : Transport Layer Security
URL : Uniform Resource Locator

VLAN : Virtual Local Area Network
VoIP : Voice over IP
VPN : Virtual Private Network
WAN : Wide Area Network
WEP : Wired Equivalent Privacy
Wi-Fi : Wireless Fidelity
WLAN : Wireless Local Area Network
WWAN : Wireless Wide Area Network
XMPP : Extensible Messaging and Presence Protocol

LISTE DES FIGURES

FIGURE 1. 1: ANALYSE DE TRAFIC5
FIGURE 1. 1: USURPATION DE TRAFIC5
FIGURE 1. 2: LA MODIFICATION DE MESSAGE5
FIGURE 1.3: L'INTERRUPTION DE LA COMMUNICATION6
FIGURE 1.4: ATTAQUE PAR INONDATION SYN9
FIGURE 1.5: ATTAQUE PAR REBOND10
FIGURE 1.6 : DÉNI DE SERVICE (DOS)10
FIGURE 1.7: DÉNI DE SERVICE DISTRIBUÉ11
FIGURE 1.8: TRANSFERT D'UN MESSAGE AVEC LE CHIFFREMENT SYMETRIQUE18
FIGURE 1.9: CONSTRUCTION DE CHIFFREMENT EN BLOC18
FIGURE 1.10: TRANSFERT DE DONNÉES PAR LA MÉTHODE DU CHIFFREMENT20
FIGURE 1.11: FONCTIONNEMENT D'UN FIREWALL21
FIGURE 1.12: PRINCIPE DE LA SIGNATURE NUMÉRIQUE22
FIGURE 1.13: VÉRIFICATION DE L'AUTHENTICITÉ DE L'EXPÉDITEUR ET DU MESSAGE22

FIGURE 2.1: CLASSIFICATION DES PROGRAMMES MALVEILLANTS II-34
FIGURE 2.2: ARCHITECTURE D'UN VIRUS II-38
FIGURE 2.3: ARCHITECTURE D'UN VER INFORMATIQUE II-42
FIGURE 2.4: LES NIDS (IDS RESEAU)41
FIGURE 2.5: REPRESENTATION LES IDS HYBRIDE43
FIGURE 2.6: LA CONFIGURATION D'UN SYSTEME DE CONTRE-MESURE IDS HYBRIDE45
FIGURE 2.7: TYPES DE COMMUNICATION AUTORISEE SUR RX45
FIGURE 2.8: TYPES D'ARCHITECTURES D'UN PARE-FEU46
FIGURE 2.9: PRINCIPES DE FONCTIONNEMENT DE PARE-FEU47
FIGURE 2.10: ZONES DEMILITARISEES OU DMZ.48
FIGURE 2.11: TECHNOLOGIES POUR L'AUTHENTIFICATION FORTE51
FIGURE 2.12: FONCTIONNEMENT D'UN ONE TIME PASSWORD52
FIGURE 2.13: FONCTIONNEMENT D'UNE CARTE MATRICIELLE52
FIGURE 2.14: FONCTIONNEMENT D'UNE AUTHENTIFICATION FONDE SUR UN COMPTEUR53

FIGURE 3.1: ORGANIGRAMME DE L'EQUITY BCDC61
FIGURE 3.2: ARCHITECTURE DE L'EQUITY BCDC63
FIGURE 3.3: ARCHITECTURE BACKBONE DE L'EQUITY BCDC64
FIGURE 3.4: ARCHITECTURE VPN DE L'EQUITY BCDC [25]66

FIGURE 4. 1: ILLUSTRATION DU SCÉNARIO70
FIGURE 4. 2: ARCHITECTURE PROPOSÉ À L'ENTREPRISE72
FIGURE 4.3: SCHEMA LOGIQUE73
FIGURE 4.4: SCHÉMA D'ATTAQUE TYPIQUE74
FIGURE 4.5: MENU DE SCRIPT AVEC LES DIFFÉRENTS OUTILS75
FIGURE 4.6: MISE À L'ÉCOUTE AUTOMATIQUE DE PORT76
FIGURE 4.7: LANCEMENT DE DPIKER, L'OUTIL DE PRÉVENTION ET DÉTECTION77
FIGURE 4.8 : ALERTE SUR LA TENTATIVE D'INTRUSION78

INTRODUCTION GENERALE

A l'ère du numérique, la sécurité informatique est devenue un enjeu majeur pour les entreprises et les individus. Les programmes malveillants, tels que les virus, ransomwares et les chevaux de Troie, évoluent sans cesse, exploitant les vulnérabilités des systèmes pour compromettre la confidentialité, l'intégrité et la disponibilité des données. Face à cette menace omniprésente, il est essentiel d'adopter une approche proactive en matière de cybersécurité.

L'approche hybride émerge comme une solution prometteuse, qui regorge l'IDS et l'IPS en combinant des infrastructures sur site et des services cloud pour offrir une flexibilité et une résilience accrues. Cette approche permet non seulement de renforcer les mesures de protection contre les cyberattaques, mais aussi de permettre à l'administrateur d'observer les moyens de compromissions des attaques, de se prémunir contre les nouvelles attaques à temps réel et d'optimiser la gestion des ressources informatiques au sein de systèmes informatique.

Dans ce contexte, nous examinerons les différents types de programmes malveillants qui sévissent aujourd'hui et les stratégies de protection efficaces, en mettant particulièrement l'accent sur l'importance d'une approche hybride pour une cybersécurité renforcée et une détection en temps réel.

PROBLEMATIQUE

De manière très brève, la problématique de ce travail se laisse constater par les questions suivantes :

1. Quesque qu'il faudrait faire pour que les clients ne soient plus victime des attaques permanente au moment de transactions ?
2. Comment faire pour permettre aux administrateurs de facilement se détecter et prévenir les comportements frauduleux en temps réel ?
3. Quelles sont les stratégies et les moyens à mettre en place pour aider l'EQuity BDCD dans la lutte contre les menaces et les attaques au sein de son système informatique ?
4. Quel sera l'apport de ce nouveau système dans la détection et la prévention des attaques contre le trafic malveillant ?

1. HYPOTHESE

D'après les questions posées ci-haut, nous pensons que l'études des mesures de protection d'un système informatique pour prévenir les menaces et contrecarrer les attaques dues aux programmes malveillants, apportera non seulement la solution de protéger les actifs numériques de la banque mais aussi de renforcer la sécurité de transaction financière en ligne, sécuriser les données de la banque et en détectant les attaques en temps réel.

2. CHOIX ET INTERET DU SUJET

Ce n'est pas par pire hasard ou par complaisance que notre choix c'est tourné vers ce sujet aussi délicat, mais c'est avec des raisons pertinentes et particulières qui nous a poussée à faire le choix de ce sujet : **''Études des mesures de protection d'un système informatique pour prévenir les menaces et contrecarrer les attaques dues aux programmes malveillants. Cas de l'Equity BCDC''**

Après descente sur terrain, auprès des clients et des utilisateurs de ces services, et après une visite au sein de la société, nous nous sommes soumis à la conclusion du choix de ce sujet, vue l'envergure se présentait : et aussi son intérêt pourtant sur le bien de la société et de ses clients.

1. Intérêt de la société

Ce sujet permettra ainsi à la société :

- De viser tous les enjeux pouvant arriver pour la détection des menaces et la préventions d'attaques afin de faire aux problèmes liée à la sécurité leur système informatique.
- D'améliorer le système de contrôle sur le plan sécurité des utilisateurs car c'est une de cause majeur de la défaillance de système informatique.
- D'alléger les taches des agents placées dans le différents commune pour couvrir des zones plutôt vastes pour assurer le bon fonctionnement des travaux et des bonnes opérations en ligne.
- Avoir une interaction directe et facile entre des utilisateurs, et permettre aux utilisateurs d'avoir les infos à temps réel des modifications, des améliorations etc… dans le service.

2. Intérêt social

Son intérêt est de donner une bonne image de l'entreprise et de ce nouveau système qu'on doit mettre en place pour déployer un système détection et prévention d'intrusion, dans la norme standard fiable sur le plan sécuritaire, et aussi permettre les gestionnaires d'avoir un moyen plus efficace pour le renforcement de la sécurité du système et d'aussi d'assurer la bonne mesure pour protéger les échanges des données entre les machines de ladite entreprise et les machines externes.

3. Intérêt scientifique

Sur le plan scientifique, ce travail a un intérêt qui permet d'acquérir des nouvelles connaissances, et de faire à certains problèmes qui arrivent dans notre milieu professionnel, il constitue, pour toute personne passionnée du domaine informatique, une référence, et aussi, la source d'inspiration dans l'avenir pour les travaux de scientifiques d'autres chercheurs.

4. TECHNIQUES DE RECHERCHE

Plusieurs techniques de recherche utilisée au cours de la réalisation de notre travail nous ont permis de récolter les données nécessaires et importantes favorisant le déploiement de notre système. Entre autre :

- **L'observation** : permettant de découvrir en personne les réalités liées et relevant du système existant.
- **L'interview** : procédant par des séances questions-réponses auprès des utilisateurs, et aussi auprès des clients pour la récolte des données.
- **La documentation** : en nous référant aux documents descriptif de ce service, la société nous a données accès aux documents pouvant nous aider à avancer dans nos recherches.

5. DELIMITATION

Du point de vue spatial, notre travail se limite aux Études des mesures de protection d'un système informatique pour prévenir les menaces et contrecarrer les attaques dues aux programmes malveillants de l'Equity BCDC. Et du point de vue temporel, nos investigations ont été menées de la période allant de 2022-2023

6. LE CANEVAS DU TRAVAIL

En vue d'élucider à bon escient notre étude, hormis l'introduction générale et la conclusion générale, nous avons jugé bon de subdiviser notre travail en deux grandes parties :

La première partie consiste les concepts théoriques de base, elle est divisée à trois chapitres respectivement dont nous donnons sommairement le contenu ci-dessous :

- PREMIER CHAPITRE : LA SECURITE INFORMATIQUE
- DEUXIEME CHAPITRE : LES PROGRAMMES MALVEILLANTS ET MESURES DES PROTECTIONS
- TROISIEME CHAPITRE L'ETUDE DE L'EXISTANT

La deuxième partie consiste, pratique, subdivisé a un seul chapitre

- QUATRIEME CHAPITRE : DEPLOIEMENT DE L'OUTIL DANS LE RESEAU

CHAPITRE I. SECURITE INFORMATIQUE [7] [8] [12] [13] [14] [21 [30] [38]

La sécurité informatique c'est l'ensemble de moyens mise en œuvre pour réduire la vulnérabilité d'un système contre les menaces accidentelles ou intentionnelle.

I.1 LA SECURITE INFORMATIQUE SELON ISO [12] [21]

I.1.1 Introduction

La sécurité informatique est l'ensemble d'outils (méthodes conçues pour protéger les données et contrecarrer les pirates informatiques).

Concept de base de la sécurité[21]

Il y a trois concepts sont à la base de l'architecture de la sécurité :

- Les menaces de sécurité ;
- Les services de sécurité ;
- Les mécanismes de sécurité.

I.1.2 Les menaces de sécurité

Du point de vue de la sécurité informatique, une menace est une violation potentielle de la sécurité. Cette menace peut être accidentelle ou intentionnelle (attaque), active ou passive.

I.1.3 Types de menaces

On distingue deux types de menaces :

- Les menaces passives ;
- Les menaces actives.

I.1.3.1.1 Menace passive

Les menaces passives regroupent les attaques portant atteinte à la confidentialité : c'est le cas de l'interception.

- ✓ L'**analyse de trafic** pour déterminer la nature d'une communication : identité des "hosts" communicants, fréquence et longueur des messages échangés. Les attaques passives ne sont pas facilement détectables car elles n'impliquent aucune altération des informations.

La figure I.1. Ci-dessous illustre l'analyse de trafic par un pirate.[21]

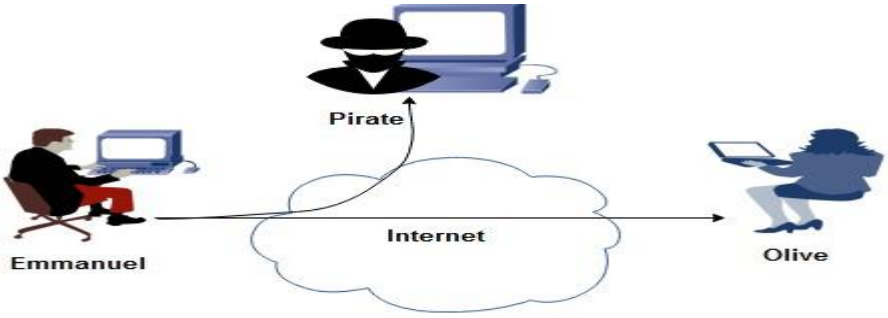

Figure 1. 1: Analyse de trafic

I.1.3.1.2 Menace active

Les menaces actives concernent celles qui entraînent une modification des données ou création de données incorrectes. Autrement dit, celles qui portent atteinte à l'intégrité, l'authenticité et la disponibilité. Nous retrouvons alors quatre types d'attaques actives:

- **L'usurpation (Fabrication) :** c'est lorsqu'une entité se fait passer pour une autre ; c'est type de menace s'appelle la fabrication.

La figure I.1. Ci-dessous illustre l'usurpation de trafic par un pirate.[21]

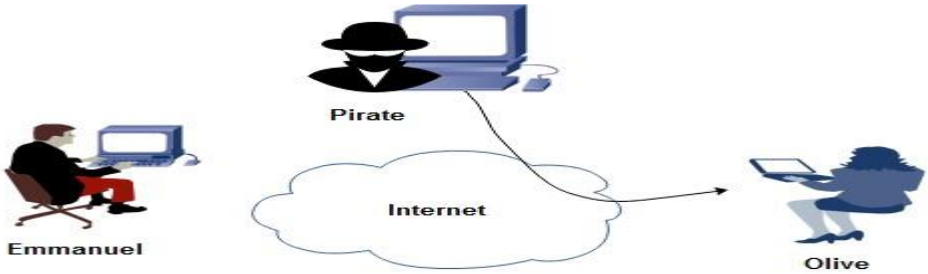

Figure 1. 2: usurpation de trafic

- **La modification de messages** ;

La figure I.2. Ci-dessous illustre la modification de messages capturés par un pirate. [21]

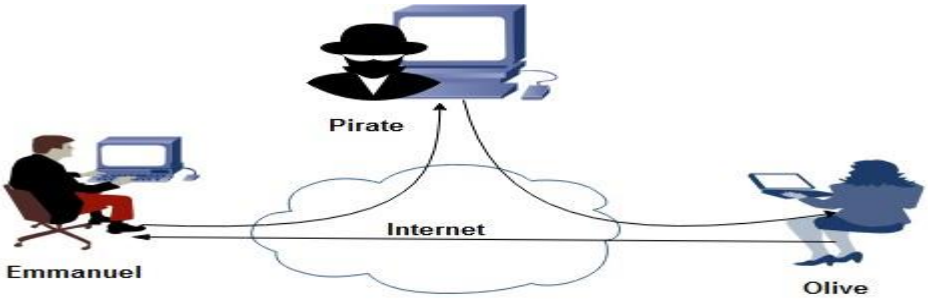

Figure 1. 3: la modification de message

- **Déni de service :** est une atteinte à la disponibilité
- **Interruption :** est une atteinte à la disponibilité.

La figure I.3. Ci-dessous illustre l'interruption de la communication entre deux entités.[21]

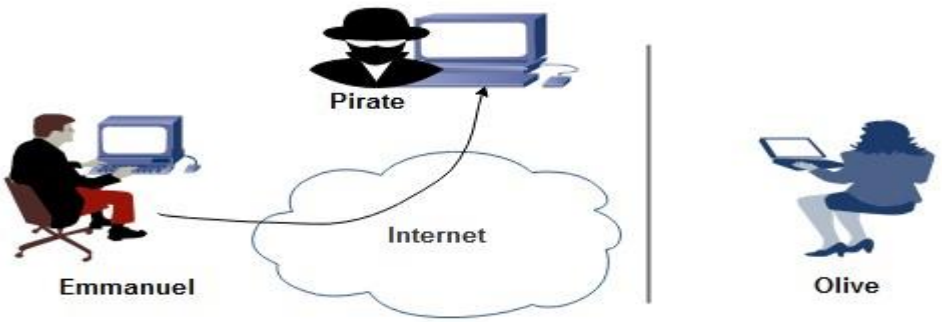

Figure 1.4: L'interruption de la communication

I.1.3.2 Vulnérabilité [14]

La vulnérabilité ou **faille** est une faiblesse dans un système informatique, permettant à un attaquant de porter atteinte à l'intégrité de ce système, c'est-à-dire à son fonctionnement normal, à la confidentialité et l'intégrité des données qu'il contient.

I.1.3.3 Risque de sécurité[14]

Les coûts d'un problème informatique peuvent être élevés et ceux de la sécurité le sont aussi. HIl est nécessaire de réaliser une analyse de risque en prenant soin d'identifier les problèmes potentiels avec les solutions avec les coûts associés.

L'ensemble des solutions retenues doit être organisé sous forme d'une politique de sécurité cohérente, fonction du niveau de tolérance au risque. On obtient ainsi la liste de ce qui doit être protégé. Il faut cependant prendre conscience que les principaux risques restent : les câbles arrachés, la coupure secteur, le crash disque, le mauvais profil utilisateur, etc.

Cependant, voici quelques éléments pouvant servir de base à une étude de risque :

1. La valeur des équipements, des logiciels et surtout des informations ;
2. Le coût et le délai de remplacement de ces derniers ;
3. L'analyse de vulnérabilité des informations contenues sur les ordinateurs en réseau (programmes d'analyse des paquets, des logs etc.) ;
4. L'impact sur la clientèle d'une information publique concernant des intrusions sur les ordinateurs de la société.

Le risque en termes de sécurité est généralement caractérisé par l'équation suivante :

$$\text{Risque} = \frac{\text{Menace} * \text{Vulnérabilité}}{\text{Contre} - \text{mesure}}$$

- Plus le taux de contre-mesure moins le risque diminue ;

- Moins le taux de contre-mesure plus le risque augmente.

I.1.3.4 Pirate Informatique [30]

Les pirates désignent des spécialistes en informatique dont les actions sont nuisibles. Selon leurs actions ils peuvent être qualifiés de hackers et de crackers. Voici des explications rapides de ces termes :

I.1.3.4.1 Hacker et cracker [14]

Il existe une communauté, une culture partagée, de programmeurs expérimentés et de spécialistes des réseaux.

✦ **Hackers**

Un hacker est une personne qui utilise ses compétences en informatique pour explorer, tester et améliorer les systèmes informatiques. Les hackers peuvent être des experts en sécurité informatique qui cherchent à identifier et a résoudre les vulnérabilités des systèmes, ou des hackers éthiques qui travaillent pour aider les entreprises à renforcer leur sécurité. Il existe trois types d'hackers :

- Hacker au chapeau noir (Black Hat Hacker)
- Hacker au chapeau blanc (White Hat Hacker)
- Le Grey Hat Hacker ou Chapeau gris

✦ **Crackers:**

Crackers sont des spécialisés en sécurité informatique qui utilisent ses compétences d'une manière malveillante, souvent dans le but de violer la sécurité d'un système, de voler les informations sensibles ou de causer des dommages. Les crackers sont souvent impliqués dans des activités illégales, telles que piratage de comptes bancaires, le vol d'identité, le piratage de sites web, etc.

I.1.3.4.2 Objectifs des attaquants[38]

Ces objectifs sont de :

- Empêcher l'accès à une ressource ;
- Prendre le contrôle d'une ressource ;
- Récupérer de l'information présente sur le système ;
- Utiliser le système compromis pour rebondir ;
- Constituer un réseau de botnet.

I.1.3.4.3 Compétences et moyens des attaquants [38]

Les attaquants sont des informaticiens chevronnés. Ils possèdent des connaissances avancées dans les différents domaines de l'informatique.

Ils utilisés les moyens ci-dessous pour attaques le système d'information d'une organisation ou une entreprise :

- **Codes malicieux:**
  - Virus
  - Cheval de Troie
  - Ver

I.1.3.5 Attaques de sécurité [38]

a. Définition

Une attaque c'est n'importe quelle action qui compromet la sécurité des informations.

b. Classification des attaques

Malgré la diversité des attaques de sécurité, nous retiendrons quatre classifications possibles.

Première classification :

Un système informatique peut être attaqué :

- Soit par des utilisateurs internes, dans le but d'abuser de leurs droits et privilèges, on parlera alors d'**attaques internes** ;
- Soit par des utilisateurs externes qui essayent d'accéder à des informations ou ressources de manière illégitime et non autorisée et dans ce cas on parlera **d'attaques externes**.

Deuxième classification :

C'est la classification la plus classique, elle regroupe quatre types d'attaques. Ainsi une attaque peut porter atteinte à:

- La confidentialité des informations en brisant des règles privées ;
- L'intégrité, en altérant les données ;
- L'authenticité des données;
- La disponibilité, en rendant un système ou réseau informatique indisponible. On parle alors d'attaque de déni de service.

Troisième classification:

Les attaques de sécurité peuvent également être classées en termes :

- **D'attaques réseaux :** leur but principal est d'empêcher les utilisateurs d'utiliser une connexion réseau, de rendre indisponible une machine ou un service et de surveiller le trafic réseau dans le but de l'analyser et d'en récupérer des informations pertinentes.

- **D'attaques systèmes :** ce sont des attaques qui portent atteinte au système, comme par exemple effacer des fichiers critiques (tel que le fichier "password") ou modifier la page web d'un site dans le but de le discréditer ou tout simplement le ridiculiser.

Quatrième classification

Les attaques peuvent aussi classiquement définir deux grands types d'attaque sur les réseaux : les attaques sur les protocoles de communications, d'une part, et les attaques sur les applications standards, d'autre part.

- **Les attaques sur les protocoles de communications** : Elles consistent pour un agresseur à profiter des failles des protocoles de communications (IP, ICMP, TCP et UDP pour l'essentiel).

- **Les attaques sur les applications standards** : elles bénéficient des vulnérabilités des applications classiques mises en œuvre dans les Intranets et les Extranets (HTTP, SMTP, FTP…).

I.1.3.5.1 Les principales attaques [30] [38]

On distingue les principales attaques suivantes :

I.1.3.5.1.1 Attaques réseaux[30]

Les informations ou les systèmes d'informations d'une entreprise peuvent subir des dommages de plusieurs façons : certains intentionnels (malveillants), d'autres par accident. Ces événements sont appelés attaques.

I.1.3.5.1.2 Attaque par inondation SYN ou (balayage de port)

La requête SYN est la communication initiale envoyée pour établir une connexion TCP. Une attaque par inondation SYN consiste à ouvrir des ports TCP au hasard et à inonder de fausses requêtes SYN aux périphériques réseau ou à l'ordinateur ciblé. Cela entraîne un déni de service. Une attaque par inondation SYN est un type d'attaque DoS (Denial of Service).

Ci-dessous la figure I.4 illustre attaque par inondation

SYN

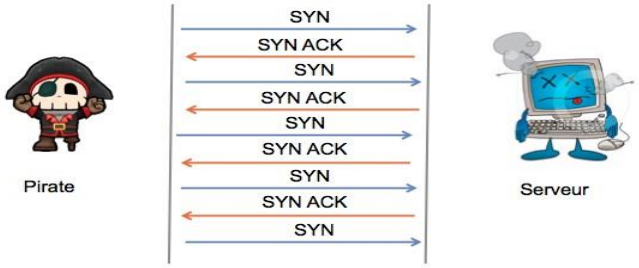

Figure 1.5: Attaque par inondation SYN

I.1.3.5.1.3 Attaque par rebond

Les attaques par rebond constituent une famille d'attaques de systèmes informatiques qui consistent à utiliser un ou des systèmes intermédiaires, participant à leur insu, et permettant à un assaillant de rester caché lors d'une intrusion. Son principe est basé sur : des paquets envoyés à un ordinateur intermédiaire qui répercute l'attaque vers la machine victime.

Ce procédé permet au pirate de masquer son identité, c'est à dire son adresse IP, et d'utiliser les ressources de l'ordinateur intermédiaire dont la puissance de calcul et l'espace disque pour attaquer la machine visée.

Ci-dessous la figure I.5 illustre attaque par rebond.

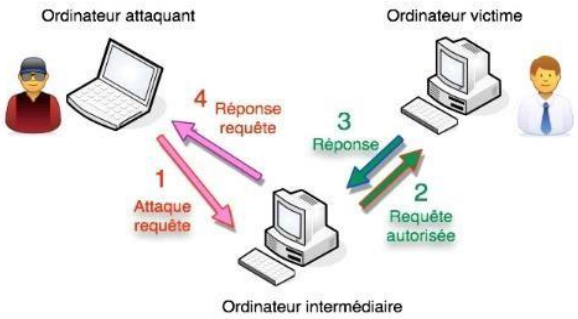

Figure 1.6: Attaque par rebond

I.1.3.5.1.4 Déni de service (Dos) [7]

Le déni de service (Dos, Denial of Service) est une forme d'attaque qui empêche les utilisateurs d'accéder normalement à des services tels que la messagerie électronique ou un serveur Web, car le système est occupé à répondre à un nombre de requêtes anormalement élevé. Cette attaque envoie un très grand nombre de requêtes à une ressource système pour que le service requis soit surchargé et cesse de fonctionner.

Ci-dessous la figure I.6 illustre le déni de service (DoS).

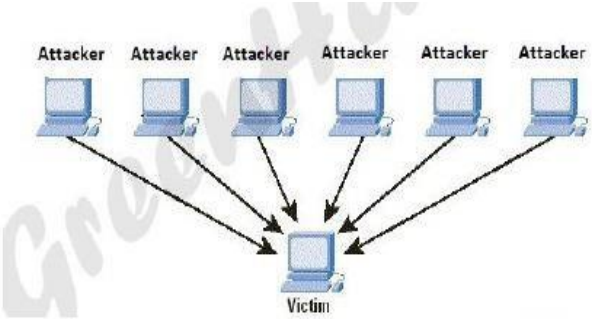

Figure 1.7 : Déni de service (Dos)

I.1.3.5.1.5 Déni de service distribué (DDoS) [7]

Une attaque par déni de service distribué (DDoS) utilise un grand nombre d'ordinateurs contaminés, appelés des zombies ou des botnets (réseaux de zombies), pour lancer une attaque. L'objectif est de bloquer l'accès au service visé. Les botnets sont généralement répartis sur toute la planète, ce qui rend difficile l'identification de l'origine de l'attaque.
Ci-dessous la figure I.7 illustre le déni de service distribué (DDoS).

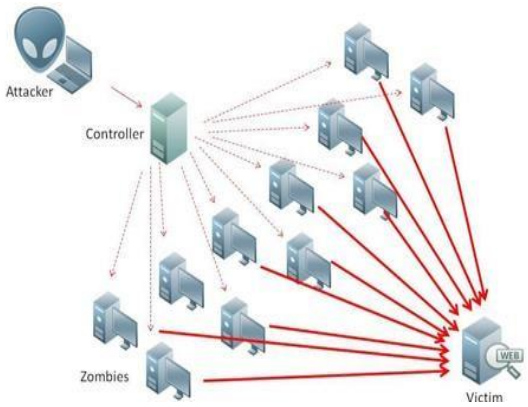

Figure 1.8: Déni de service distribué[7]

Ces attaques se basent principalement sur des failles liées aux protocoles ou à leur implémentation.

Parmi ces attaques, il y a lieu de citer :

<u>Les techniques de scan</u> [30]

Les scans de ports ne sont pas des attaques à proprement parler. Le but des scans est de déterminer quels sont les ports ouverts, et donc en déduire les services qui sont exécutés sur la machine cible (ex : port 80/TCP pour un service HTTP). Par conséquent, la plupart des attaques sont précédées par un scan de ports lors de la phase Probe.
Il existe un nombre important de techniques de scan. Idéalement, la meilleure technique de scan est celle qui est la plus furtive afin de ne pas alerter les soupçons de la future victime.

Voici une description des techniques de scan les plus répandues :

1. Le scan simple

Le scan simple : est aussi appelé le scan connect (), il consiste à établir une connexion TCP complète sur une suite de ports. S'il arrive à se connecter, le port

est ouvert ; sinon, il est fermé. Cette méthode de scan est très facilement detectable.

Exemple:

1. *[root@ nowhere.net /root]# nmap [ip de la machine cible]*

2. *[root@nowhere.net /root]# nmap -sT [ip de la machine cible]*

2. Le scan furtif

Le scan furtif : aussi appelé scan SYN, il s'agit d'une amélioration du scan simple. Ce scan essaie également de se connecter sur des ports donnés, mais il n'établit pas complètement la connexion : pas de commande ACK (acquittement) après avoir reçu l'accord de se connecter.

Grâce à ceci, la méthode est bien plus furtive que le scan normal.

Exemple :

- *[root@nowhere.net /root]# nmap -sS [adresse IP de la machine cible]*

3. Le scan basé sur le RFC

Les scans XMAS, NULL et FIN : se basent sur des détails de la RFC du protocole TCP pour déterminer si un port est fermé ou non en fonction de la réaction à certaines requêtes. Ces scans sont moins fiables que le scan SYN mais ils sont un peu plus furtifs. La différence entre ces trois types de scan se situe au niveau des flags TCP utilisés lors de la requête.

- Le scan FIN consiste en l'envoi de paquets TCP avec seulement le flag FIN armé. La commande se fait par l'appel de nmap avec l'option -sF :
  - *[root@nowhere.net /root]# nmap -sF [adresse IP de la machine cible]*
- Le scan NULL consiste en l'envoi de paquets TCP avec seulement le flag NULL armé. La commande se fait par l'appel de nmap avec l'option -sN :
  - *[root@nowhere.net /root]# nmap -sN [adresse IP de la machine cible]*

I.1.3.5.1.6 Attaques des réseaux sans fil [28]

Les risques liés à la mauvaise protection d'un réseau sans fil sont multiples :

- **Man in the middle**

Lorsqu'un pirate, prenant le contrôle d'un équipement du réseau, se place au milieu d'une communication il peut écouter ou modifier celle-ci. On parle alors de « l'homme du milieu » (man in the middle*)*. Les points sensibles permettant cette technique sont : DHCP, ARP, ICMP Virus, RIP, DNS, Proxy HTTP

- **DHCP (Dynamics Host Configuration Protocol)** : Ce protocole n'est pas sécurisé et un pirate peut fournir à une victime des paramètres réseau qu'il contrôle. Solution: IP fixe;

- **ARP (Address Résolution Protocol)** : Si le pirate est dans le même sous réseau que la victime et le serveur, il peut envoyer régulièrement des paquets ARP signalant un changement d'adresse MAC aux deux extrémités. Solution: ARP statique;

- **ICMP (Internet Control Message Protocol)** : Un routeur peut émettre un ICMP-redirect pour signaler un raccourci, le pirate peut alors demander de passer par lui. Solution : refuser ICMP-redirect ou seulement vers des routeurs identifiés ;

- **Virus** : Un virus, éventuellement spécifique à la victime et donc presque indétectable, il peut écrire dans les fichiers « hosts » ; et autres Solution : bloquer les fichiers auto exécutable avec les extensions. VBs et. Exe

- **RIP** : Le pirate envoie une table de routage à un routeur indiquant un chemin à moindre coût et passant par un routeur dont il a le contrôle. Solution : nouvelle version de RIP qui intègre une identification des routeurs de confiance.

- **DNS** : par « ID spoofing » un pirate peut répondre le premier à la requête de la victime et par « cache poisoning » il corrompt le cache d'un serveur DNS. Solution : proxy dans un réseau différent des clients, désactivation de la récursivité, vidage du cache DNS régulier.

- **Proxy HTTP** : Par définition un proxy est en situation d'homme du milieu. Une confiance dans son administrateur est nécessaire de même qu'un contrôle du proxy lors de son départ !

- **Espiogiciels**

Ces logiciels espions sont aussi appelés *« spyware ».* Ils ne posent pas, à priori, de problème de sécurité mais plutôt celui du respect de la vie privée. Plusieurs logiciels connus se permettent de renvoyer vers l'éditeur des informations concernant l'usage du logiciel mais aussi sur les habitudes ou la configuration de l'utilisateur, et ceci au mépris de la loi « informatique et liberté ». Il s'agit souvent de « freewares » qui trouvent ainsi une source de revenus mais pas toujours !

- **Cookies**

Un « cookies » est une chaîne de caractère généralement court, qu'un Serveur HTTP (Web) déposé dans un ordinateur client. L'objectif original d'utiliser l'élément susmentionné est de permettre au serveur Web de suivre le comportement du client HTTP, via ses requêtes [6].

- **Logiciel publicitaire**

Un logiciel publicitaire est un programme qui affiche de la publicité sur l'ordinateur. En général, ces logiciels sont distribués avec un logiciel téléchargé. Plupart du temps, ils s'affichent dans une fenêtre publicitaire intempestive(pop-up).
Ces fenêtres sont parfois difficiles à contrôler et ouvrent de nouvelles fenêtres plus rapidement que l'utilisateur ne peut les fermer.

- **Le brouillage radio**

Les ondes radio sont très sensibles aux interférences, c'est la raison pour laquelle un signal peut facilement être brouillé par une émission radio ayant une fréquence proche de celle utilisée dans le réseau sans fil.

- **Le war driving**

Le War-driving consiste à détecter les réseaux sans fil urbains appartenant à des particuliers ou à des entreprises, déterminer s'ils sont protégés par une clé WEP et tenter de les pénétrer. Pour ce faire, le War-driver utilise un ordinateur portable ou un pocket PC, un logiciel de détection de réseau sans fil, une antenne externe et une carte réseau 802.11.

I.1.3.5.1.7 Attaques du système d'exploitation [37]

On distingue les attaques ci-après qui visent le système d'exploitation :

➢ +++ATHZéro.

I.1.3.5.1.7.1 +++ATH Zéro (L'écran bleu de la mort)

Elle se réfère à l'écran affiché par le système d'exploitation Windows lorsqu'il est au point Fork bomb critique d'une erreur fatale. En général, la vue de cet écran signifie que l'ordinateur est devenu complètement inutilisable. Pour certains Black Hat (chapeau noir), leur but est d'arriver à provoquer cet écran bleu de la mort sur plus d'ordinateurs possibles.

I.1.4 SERVICES DE SECURITE [12] [21]

C'est l'ensemble de services de communication qui peuvent élever le niveau de sécurité dans le système informatique et le transfert d'information d'une organisation. Ils sont appelés à contrecarrer les menaces à la sécurité informatique. Les services que doivent fournir un système informatisé OSI sécurisé, sont :

- Authentication;
- Le contrôle d'accès;
- La confidentialité de données;
- L'intégrité des données;
- La non – repudiation;
- La disponibilité.

I.1.4.1 L'Authentification

Ce service permet d'authentifier les entités qui communiquent entre elles, préalablement à tout échange de données. Il a pour but de garantir l'identité des correspondants. On peut distinguer deux types : L'authentification homologue et l'authentification de l'origine :

1. L'authentification de l'entité homologue qui assure que l'entité réceptrice qui est connectée est bien celle annoncée. Son activation peut intervenir à l'établissement de la communication et pendant le transfert de données. Son objectif principal est la lutte contre le déguisement
2. L'authentification de l'origine qui assure que l'entité émettrice est bien celle prétendue.

I.1.4.2 Le Contrôle d'accès

Ce service empêche l'utilisation non autorisée de ressources accessibles par le réseau. Le mot utilisation sous-entend les modes lecture, écriture, création ou suppression. Ce service utilise le service d'authentification vu ci – dessus afin de s'assurer de l'identité des correspondants, échangée lors de la phase d'initialisation des dialogues.

I.1.4.3 La Confidentialité des données

L'objectif de ce service est d'empêcher des données d'être compréhensibles par une tierce entité non – autorisée, le plus souvent en état de fraude passive.

I.1.4.4 L'intégrité des données

Ce service est destiné à lutter contre les fraudes actives. Il détecte les altérations de données entre l'émetteur et le récepteur.

I.1.4.5 La non-répudiation

En rapport avec la non – répudiation, il y a lieu de considérer deux cas :

- **La non – répudiation à l'origine** des données fournit au récepteur une preuve empêchant l'émetteur de contester l'envoi ou le contenu d'un message effectivement reçu.
- **La non–répudiation de la remise** fournit à l'émetteur une preuve empêchant le récepteur de contester la réception du message.

I.1.4.6 La disponibilité

L'aptitude d'un bien/d'une entité à être en état d'accomplir une fonction requise dans des conditions données, à un instant donné ou pendant un intervalle de temps donné, en supposant que la fourniture des moyens extérieurs nécessaires soit assurée.

I.1.5 LES MECANISMES DE SECURITE [12][14]

Les mécanismes de sécurité, sont de mécanismes de systèmes, permettant la détection, la prévention, la réparation d'une menace de sécurité. Ils ont pour objet de réaliser les services de sécurité, que nous avions abordée :

I.1.5.1 Mécanisme qui assume L'authentification

Il s'agit de technologies permettant d'identifier de manière unique une personne grâce à une ou plusieurs caractéristiques biologiques, telles que l'empreinte digitale, le visage, la morphologie de la main, la voix…

La biométrie remplit deux fonctions distinctes :

- L'identification répond à la question « **Qui êtes-vous ?** ». Dans ce cas, la personne est identifiée parmi d'autres (vérification) ;
- L'authentification répond à la question : « **Êtes-vous bien celui que vous prétendez être ?** ». Dans ce cas, elle certifie l'identité d'une personne en comparant les données qu'elle va présenter avec celles préenregistrées dans la base de données de la personne qu'elle prétend être.

I.1.5.2 Mécanisme qui assume Le contrôle d'accès

Le mécanisme de contrôle d'accès est le mécanisme qui permet de Vérifie les droits d'accès d'un acteur aux données. N'empêche pas l'exploitation d'une vulnérabilité.

I.1.5.2.1 La gestion de l'accès utilisateur

Il convient de mettre en place tous les outils nécessaires afin de donner accès à un utilisateur uniquement aux services dont il a besoin et reçu une autorisation. Des méthodes d'authentifications telles que le Single Sign On – SSO– peuvent être mise en place pour un Contrôle d'accès au réseau.

I.1.5.2.2 Le contrôle de l'accès au système et à l'information

Les accès non autorisés aux systèmes et aux applications doivent être empêchés. Il est nécessaire de sécuriser les connexions et mettre si possible des procédures de contrôle.

La gestion du contrôle d'accès passe par l'identification et l'authentification des utilisateurs pour un accès autorisé aux ressources réseau.

I.1.5.3 Le Mécanisme qui assume La confidentialité de données

La confidentialité est le fait de s'assurer qu'une information est accessible uniquement par les entités qui ont le droit d'accéder à celle-ci. Dans le cadre où nous avons à faire à des données sensibles (données de l'armée, gouvernementales etc…) ce principe est souvent respecté. Il est important de respecter ce principe, imaginons qu'un tiers arrive à obtenir la liste des cartes bancaire des clients d'une banque. Cela peut être extrêmement dommageable pour la banque ainsi que les clients.

I.1.5.3.1 La Cryptographie [14] [18]

Cryptographie est une science qui vise à créer des cryptogrammes à partir des algorithmes de chiffrage.

- **Le chiffrement :** consiste à transformer une donnée lisible (ou clair) en une donnée illisible (ou incompréhensible par un humain logiciel, ou cryptogramme) sans posséder la clé qui permet de déchiffrer la donnée.
- **Le déchiffrement :** est logiquement l'opération inverse du chiffrement.
- **Le Cryptage :** est un anglicisme ambigu issu de Encryption qui signifie en français Chiffrement.
- **Le décryptage :** désigne l'acte de rendre clair un message chiffré sans en posséder la clé.
- **Le cryptogramme :** message chiffré.
- **Le Crypto-Analyse :** technique qui vise à étudier les messages chiffrés ou Cryptogrammes en vue de les rendre lisible (ou de les décrypter).

I.1.5.3.1.1 Types de chiffrements

Il existe plusieurs grands principes de chiffrement (seuls les deux premiers seront expliqués) :

- **Basé sur des clés asymétriques**, la clé de chiffrement est différente de la clé de déchiffrement.
- **Basé sur des clés symétriques**, la même clé permet de chiffrer et déchiffrer.

I.1.5.3.1.1.1 Le Chiffrement Symétrique

Le chiffrement symétrique, ou chiffrement à clé secrète est basé sur une clé partagée entre les deux parties communicantes. Cette clé permet à la fois de chiffrer et de déchiffrer les données.

Figure 1.9: Transfert d'un message avec le chiffrement symetrique

I.1.5.3.1.1.1.1 Chiffrement par bloc

Le chiffrement par bloc est une technique de chiffrement utilisée pour proteger les données en les divisant en blocs de taille fixe avant de les chiffrer. Chaque bloc est ensuite chiffré individuellement, généralement en utilisant un algorithme de chiffrement symétrique tel que AES (Advanced Encryptions Standard).

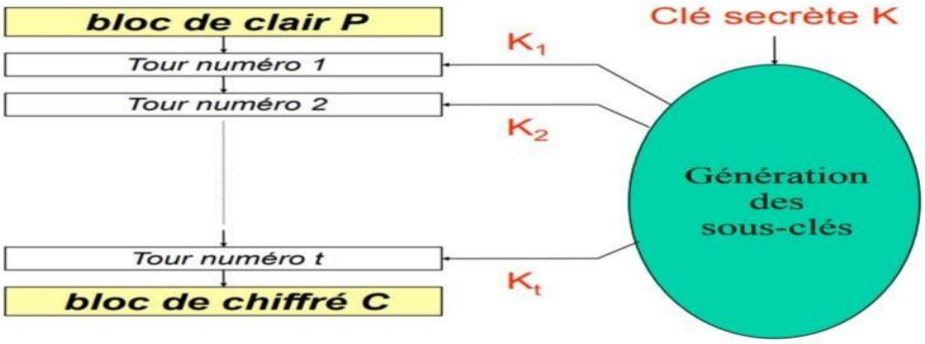

Figure 1.10: construction de chiffrement en bloc

L'algorithme de chiffrement utilise une clé secrète pour effectuer des opérations mathématiques sur chaque bloc de données, ce qui rend les données illisibles sans la clé appropriée pour les déchiffrements par bloc est considérer comme sur et fiable, car il est difficile pour un attaquant de déchiffrer les données sans clé.

Exemple d'algorithmes : DES, AES, IDEA, RC6…

I.1.5.3.1.1.1.2 Chiffrement de Feistel [21]

C'est la base de pratiquement plusieurs algorithmes modernes à clé secrète (en particulier DES), il est proposé par Horst Feistel (IBM) en 1973. C'est un chiffrement itératif par blocs Opérant sur des blocs de 2n bits.

I.1.5.3.1.1.1.3 Algorithme de DES (Data Encryptions Standard)

L'algorithme DES est un algorithme de chiffrement symétrique largement utilisée dans les années 1970 et 1980. il utilise une clé de 54 bits pour chiffrer et déchiffrer les données par blocs de 64 bits.

I.1.5.3.1.1.1.4 Double DES

Un double DES est une copie exacte ou une réplique d'un document, d'une clé ou d'un objet. Dans le contexte du chiffrement, un double DES peut se référer a une copie de la clé de chiffrement utilisée pour crypter les données.

I.1.5.3.1.1.1.5 Le Triple DES

(Aussi appelé 3DES) est un algorithme de chiffrement symétrique enchainant trois applications successives de l'algorithme DES sur le même bloc de données de 64 bits, avec 2 ou 3 clés DES différentes. Cette utilisation de trois chiffrements DES a été développée par Walter TUCHMAN. Elle permet d'augmenter la sécurité du DES, toutefois, il a l'inconvénient majeur de demander également plus De ressources pour le chiffrement et le déchiffrement.

I.1.5.3.1.1.1.6 Le Chiffrement non Feistel

I.1.5.3.1.1.1.6.1 Definition

Le chiffrement non feistel est une méthode de chiffrement de Feistel, qui est une structure couramment utilisée dans les algorithmes de chiffrement symétrique. Dans un chiffrement non Feistel, les données ne sont pas divisées en bloc et les opérations de chiffrement ne sont pas effectuées en itérations successives. Au lieu de cela, le chiffrement non Feistel utilise d'autres techniques et structures pour chiffrer les données. Il peut utiliser des substitutions, des permutations, des opérations mathématique complexes ou d'autres méthodes pour rendre les données illisibles sans utiliser la structure Feistel.

I.1.5.3.1.1.1.7 Algorithme AES (Advanced Encryption Standard)

L'AES est un algorithme considéré comme la norme par le gouvernement américain et de nombreuses d'autres organisations. Bien qu'il soit extrêmement efficace sous forme de 128 Bits, L'AES utilise également des clés de 192 et 256 Bits pour le chiffrement a haute rendement. Il utilise de processus de transposition de Bits entre les deux et la transposition matricielle.

I.1.5.3.1.1.2 Le Chiffrement Asymétrique

Pour échanger des données, chaque utilisateur doit être en possession de deux clés :

La figure I.11 Décrit le transfert de données par la méthode du chiffrement Asymétrique.

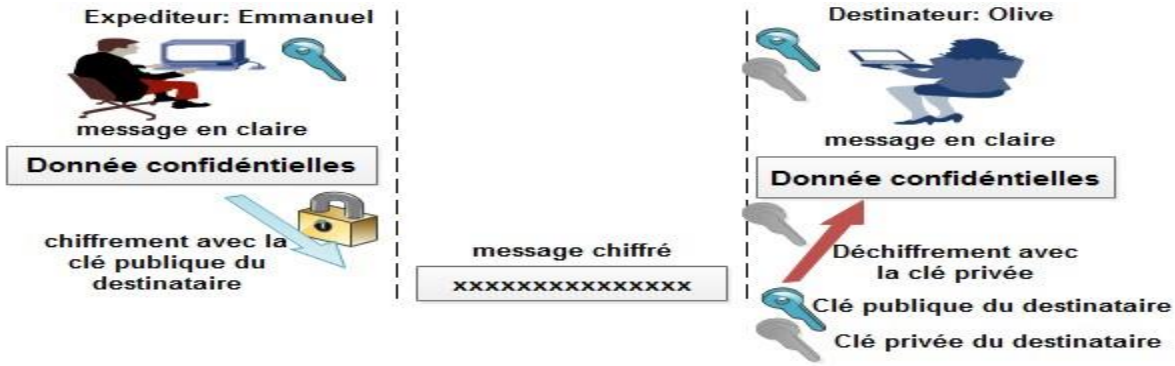

Figure 1.11: Transfert de données par la méthode du chiffrement

I.1.5.3.1.1.2.1 Algorithme utilisé dans la cryptographie Asymétrique [18]

Dans la cryptographie asymétrique, les algorithmes les plus couramment sont :

I.1.5.3.1.1.2.1.1 Algorithme RSA (Rivest-Shamir-Adleman)

Cet algorithme est basé sur la difficulté de factoriser de grands nombres premiers. Il utilise une paire de clés, une clé publique pour le chiffrement et une clé privée correspondante pour le déchiffrement. RSA est largement utilisé pour le chiffrement des communications sécurisées et des transactions en ligne.

I.1.5.3.1.1.2.1.2 Diffie-Hellman

Cet algorithme permet l'échange de clés secrètes sur un canal public non sécurisé. Il repose sur le problème du logarithme discret dans les groupes finis. Diffie-Hellman est utilisé pour établir des clés de session secrètes dans les protocoles de chiffrement à clé publique.

I.1.5.3.1.1.2.1.3 Algorithme ECC (Elliptic Curve Cryptography)

Cet algorithme utilise des courbes elliptiques pour effectuer des opérations cryptographiques. Il offre un niveau de sécurité équivalent à RSA avec des clés beaucoup plus courtes, ce qui le rend plus efficace en termes de ressources. ECC est utilisé dans diverses applications, telles que les cartes à puce et les systèmes embarqués.

I.1.5.3.1.1.2.1.4 Algorithme DSA (Digital Signature Algorithm)

Cet algorithme est utilisé pour la génération et la vérification de signatures numériques. Il repose sur le problème du logarithme discret dans les groupes finis. DSA est utilisé pour garantir l'intégrité et l'authenticité des données dans de nombreuses applications, y compris les transactions financières en ligne.

I.1.5.4 Mécanisme qui assume L'intégrité de données [14]

L'intégrité s'assure que la donnée reste toujours intègre c'est-à-dire qu'elle n'a pas été modifiée par un tiers non autorisé. Ce principe devra être respecté tout au long de la vie de l'information. Garantir l'intégrité d'une donnée, c'est garantir que la donnée est restée fiable depuis sa création.

I.1.5.4.1 Firewall

Un firewall est un outil de sécurité, logiciel ou matériel, qui tient lieu de barrière entre deux réseaux. Il est généralement placé entre un réseau non sûr, comme Internet et un réseau privé pour en garantir la protection. Toutes les connexions entre les deux réseaux passent alors par le firewall au niveau duquel il est possible de faire suivre les paquets à leur destination ou au contraire de les rejeter.

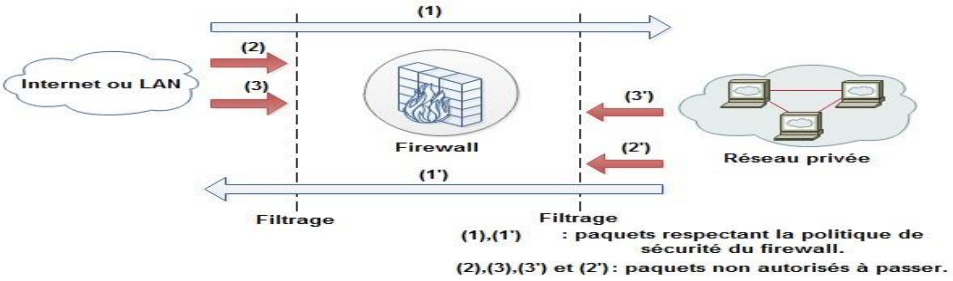

Figure 1.12: Fonctionnement d'un firewall

Selon le type de pare-feu, ce filtrage de paquets s'effectue soit aux niveaux 3 ou soit au 4 du modèle TCP / IP. Toutefois, un firewall ne protège pas des attaques qui ne passent pas par lui. Il ne protège pas très bien des virus. Bien qu'il filtre tous les paquets transitant entre les deux réseaux, le pare-feu peut être contourné.

I.1.5.5 Mécanisme qui assume La non répudiation

Mécanisme de non-répudiation est un mécanisme dont l'objectif est de ne pas permettre aux correspondants de nier la participation à un échange d'informations.

I.1.5.5.1 Signature numérique

Le principe de la signature numérique décrit par la figure I.13. Consiste, dans un premier temps, à appliquer une fonction mathématique sur une portion du message

ou l'information à signer. Cette fonction est appelée **fonction d'hachage**. Le résultat de cette fonction est appelé « **empreinte** ou **code de hachage** ». Elle est choisie de telle manière à ce qu'il soit impossible de changer le contenu du message sans altérer l'empreinte. Cette empreinte est ensuite chiffrée avec la clé privée de l'émetteur. On obtient ainsi « **la signature numérique** ». Elle est ajoutée au message ou à l'information à transmettre.

La figure I.13. Ci-dessous illustre le fonctionnement de la signature numérique.

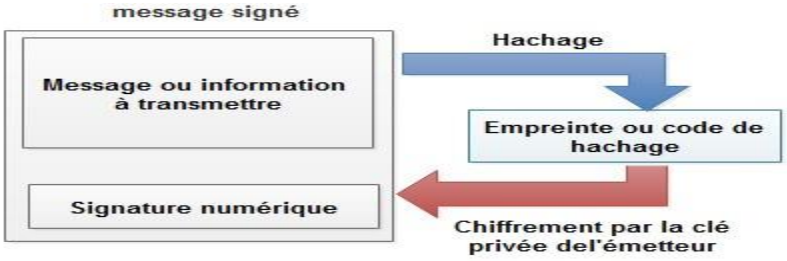

Figure 1.13: Principe de la signature numérique

La vérification de l'authenticité de l'expéditeur et du message s'effectue comme suit. Lorsque le destinataire reçoit le message, il détermine l'empreinte en appliquant sur le message la fonction de hachage. Ainsi, il obtient l'empreinte calculée. Entre autres, il déchiffre la signature numérique du message à l'aide de la clé publique de l'expéditeur. Ensuite, il compare le résultat avec l'empreinte du message.
La figure I.14. Ci-dessous illustre la vérification de l'authenticité.

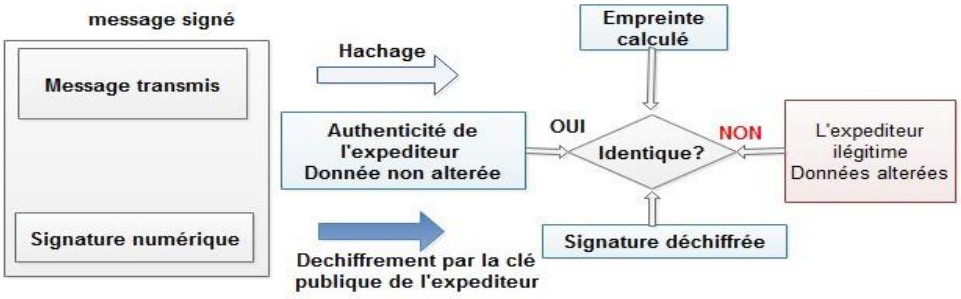

Figure 1.14: Vérification de l'authenticité de l'expéditeur et du message

Si les deux correspondent, le message n'a donc pas été altéré et qu'il provienne bien de l'expéditeur légitime qui est le seul qui a pu chiffrer les données avec sa clé privée.

I.1.5.6 Mécanisme qui assume La disponibilité

Le mécanisme de disponibilité est un mécanisme dont l'objectif est de permettre les acteurs de la communication accèdent aux données dans de bonnes conditions.

I.1.5.6.1 RAID (Redundant Array of Independent DISKS)

Le RAID (Redundant Array Of Independent Disks) a été défini par l'université de Berkeley en 1987 dans le double but de réduire les couts et d'augmenter la fiabilité du stockage des données. Le but est de combiner plusieurs petits disques physiques en une matrice (array : tableau, ensemble, rangée, matrice) des disques dont la capacité dépasse celle du SLED (single large expensive drive).

La figure I.14. Ci-dessous illustre le fonctionnement de RAID 5.

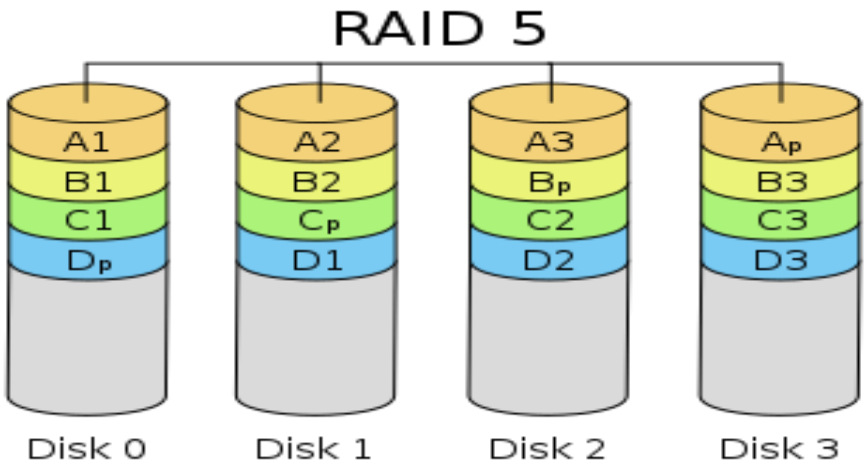

Figure 1.14: le fonctionnement de RAID

Pour tout responsable de système d'information, l'objectif est de garantir un niveau de disponibilité maximal, c'est-à-dire résistant aux défaillances. Le respecter certains principes peut permettre d'obtenir la meilleure disponibilité possible. Sans pour autant dépasser les budgets. Ces principe ou piliers, sont :

- La redondance
- La reputation
- La fiabilité
- La facilité de réparation
- La facilité de récupération
- La rapidité de réaction
- La robustesse

CHAPITRE II. PROGRAMMES MALVEILLANTS ET MESURES DES PROTECTIONS

[2] [5] [9] [11] [12] [13] [14] [15] [16] [17] [21] [30] [33] [34]

Les programmes malveillants sont des logiciels conçus pour causer des dommages, voler des informations et perturber les fonctionnements normaux d'un système. Ainsi pour assurer la sécurité de votre système informatique, il est essentiel de mettre en place des mesures de protections contre les programmes malveillants.

II.1 PROGRAMMES MALVEILLANTS [15] [16] [34]

II.1.1 Définition

Un programme malveillant ou maliciel, aussi dénommé logiciel nuisible ou Programme malveillant ou pourriciel (« malware » en anglais), est un programme developpé dans le but de nuire à un système informatique, sans le consentement de l'utilisateur dont l'ordinateur est infecté. De nos jours, le terme « virus » est souvent Employé, à tort, pour désigner toutes sortes de logiciels malveillants. En effet, les Malicieux englobent les virus, les vers, les chevaux de Troie, ainsi que d'autres Menaces. La catégorie des virus informatiques, qui a longtemps été la plus répandue, a Cédé sa place aux chevaux de Troie en 2005.

II.1.2 Classification du programme malveillants

Les programmes malveillants peuvent être Classés en fonction des trois mécanismes suivants :

- Le mécanisme de propagation (par exemple, un ver se propage sur un réseau Informatique en exploitant une faille applicative ou humaine) ;
- Le mécanisme de déclenchement (par exemple, la bombe logique comme la Bombe logique surnommée vendredi 13 se déclenche lorsqu'un évènement Survient) ;
- La charge utile (par exemple, le virus Tchernobyl tente de supprimer des parties Importantes du BIOS, ce qui bloque le démarrage de l'ordinateur infecté). La classification n'est pas parfaite, et la différence entre les classes n'est pas toujours évidente. Cependant, c'est aujourd'hui la classification standard la plus Couramment adoptée dans les milieux internationaux de la sécurité informatique. Dans une publication, J. Rutkowska propose une taxonomie qui distingue les Logiciels malveillants suivant leur mode de corruption du noyau du système d'exploitation : ne touche pas au noyau (applications, micrologiciel), corruption d'éléments fixes (code), corruption d'éléments dynamiques (données) et au-dessus du noyau(hyperviseur).

La figure 2.1. Ci-dessous illustre la classification d'un programme malveillants.

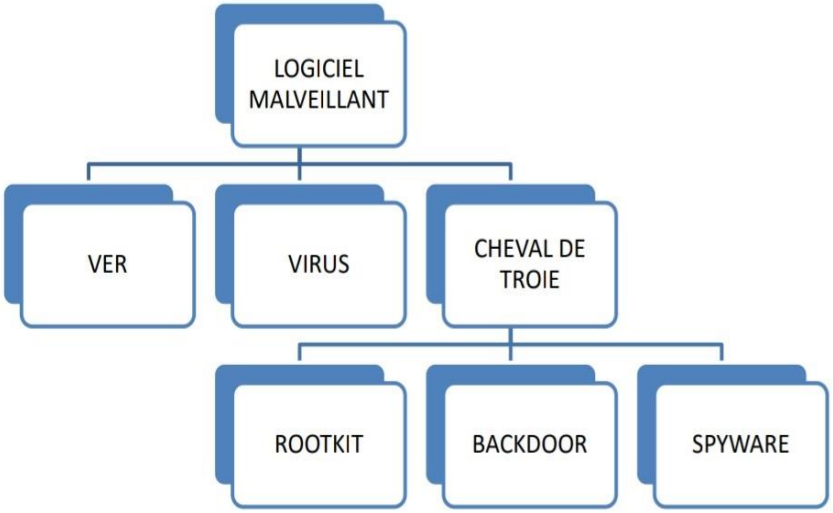

Figure 2.1: Classification des programmes malveillants

Les programmes malveillants ont été développés pour de nombreux systèmes d'exploitation et applications. Pourtant, certains d'entre eux n'ont jamais été concernés. En effet, les auteurs de virus privilégient les systèmes d'exploitation largement Utilisés ; les systèmes comportant des vulnérabilités ; et ceux pour lesquels une documentation détaillée est disponible (puisqu'elle inclut des descriptions des services Et des règles en vigueur pour écrire des programmes compatibles). Le volume de Logiciels malveillants destinés à Windows et Linux est à peu près prop ortionnel à leurs Parts de marché respectives.

II.1.2.1 LES VIRUS INFORMATIQUES [16]

Un virus informatique est un type de programme malveillant qui se propage en infectant d'autres fichiers ou programmes sur un système informatique. Il est conçu pour causer des dommages, voler des informations ou perturber le fonctionnement normal du système. Les virus peuvent se propager via des pièces jointes de courrier électronique, des téléchargements infectés, des sites web compromis ou des périphériques de stockage infectés tels que des clés USB. Une fois qu'un virus infecte un système, il peut se reproduire et se propager a d'autres fichiers, ce qui rend difficile sa détection et son élimination. Les anti-virus sont souvent utilisés pour détecter et supprimer les virus informatiques.

Tout comme le virus biologique, le virus informatique poursuit quelques objectifs :

- La destruction des données
- Le vol d'information

- L'espionnage
- La perturbation du système
- La propagation dans le système

Voici les quelques virus les plus célèbres du monde informatique :

- Cabir est considéré comme le tout premier virus informatique proof of concept recensé se propageant par la téléphonie mobile grâce à la technologie Bluetooth et du système d'exploitation Symbian OS.
- MyDoom.A est un virus informatique qui se propage par les courriels et le Service P2P de Kazaa. Les premières infections ont eu lieu le 26 janvier 2004.
- Psyb0t est un virus informatique découvert en janvier 2009. Il est considéré Comme étant le seul virus informatique ayant la capacité d'infecter les routeurs et Modem haut-débit.
- Le virus Tchernobyl
- Le ver Conficker
- Cryptolocker
- Zeus Bot

II.1.2.1.1 CARACTERISTIQUES DES VIRUS

Les caractéristiques des virus informatiques peuvent varier en fonction de leur conception et de leurs objectifs spécifiques. Cependant, certaines caractéristiques courantes des virus informatiques comprennent :

- *Auto-réplication*
- *Furtivité*
- *Activation*
- *Dommages*
- *Capacité d'évolution*

II.1.2.1.2 CLASSIFICATION DES VIRUS

Ils n'existent pas des classifications strictes des virus. Ce pendant on peut en retenir 4 grandes classifications :

- Classification selon le format visé (exécutable ou documents) ;
- Classification selon leur comportement (rapide, lent, résident, polymorphe…) ;
- Classification selon l'organe visé (boot sector, driver…)
- Classification selon le langage utilisé (virus assembleur, macrovirus, virus Interprété…).

C'est grâce à cette classification que nous pouvons maintenant en mesure de Distinguer les différents types de virus qui existent :

1. Le virus classique

Un virus classique est un type de virus informatique traditionnel qui se propage en infectant des fichiers exécutables ou des secteurs de démarrage sur les disques durs.

2. Un virus de botnet

Un virus Botnet est un type de virus informatique qui infecte les ordinateurs pour les contrôler à distance et les utiliser dans des activités malveillantes, telles que des attaques DDoS ou l'envoi de spam.

3. Un macro virus

Un macro virus est un type de virus informatique qui infecte les fichiers contenant des macros, généralement dans des programmes tels que Microsoft Office. Il utilise les macros pour se propager et causer des dommages aux fichiers et a un système.

4. Un virus vers

Un virus vers est un type de virus informatique qui se propage en utilisant les fonctionnalités de partage de fichiers des réseaux informatiques. Il peut se propager rapidement en infectant d'autres ordinateurs connectés au même réseau.

5. Un virus de type batch

Un virus de type batch est un type de virus informatique qui utilise des scripts batch pour infecter et se propager à d'autres fichiers et systèmes. Il est souvent utilisé pour causer des dommages aux fichiers et au système.

6. Un virus réside

Un virus résident est un type de virus informatique qui s'installe en mémoire et reste actif même après le redémarrage du système. Il peut se propager à d'autres fichiers exécutables et causer des dommages continus.

7.Un virus lent

Un virus lent est un type de virus informatique qui ralentit considérablement les performances du système infecté. Il peut causer des retards lors de l'exécution des programmes et rendre l'ordinateur inutilisable.

8. Un virus furtif

Un virus furtif est un type de virus informatique qui se cache et tente d'éviter la détection par les logiciels antivirus. Il utilise des techniques telles que la modification de son code ou de sa signature pour échapper à la détection.

9. Un virus polymorphe

Un virus polymorphe est un type de virus informatique qui modifie son code chaque fois qu'il se propage, rendant ainsi difficile sa détection par les logiciels antivirus. Il peut se transformer en différentes variantes pour éviter d'être détecté.

10. Un virus cavité

Un virus cavité est un type de virus informatique qui infecte les fichiers exécutables en s'insérant dans des espaces vides à l'intérieur du fichier. Il peut modifier le code du fichier hôte sans modifier sa taille, ce qui rend difficile la détection.

11. Un virus compagnon

Un virus compagnon est un type de virus informatique qui crée une copie de lui-même avec le même nom qu'un fichier système existant. Lorsque l'utilisateur ouvre le fichier système, le virus se lance à la place, infectant ainsi le système.

12. Un virus blindé

Un virus blindé est un type de virus informatique qui utilise des techniques de cryptage et d'offuscation pour rendre sa détection et son analyse plus difficiles. Il est conçu pour contourner les logiciels antivirus et autres outils de sécurité.

13. Un virus souterrain

Un virus souterrain est un type de virus informatique qui se cache dans les secteurs de démarrage du disque dur ou dans d'autres parties du système d'exploitation. Il est difficile à détecter et peut causer des dommages importants au système.

14. Un virus compte-gouttes

Un virus compte-gouttes est un type de virus informatique qui télécharge et installe d'autres logiciels malveillants sur le système infecté. Il peut agir comme un cheval de Troie en introduisant d'autres menaces sur l'ordinateur.

15. Une bombe ANSI

Une bombe ANSI est un type de virus informatique qui utilise des caractères spéciaux dans le code source pour provoquer des dysfonctionnements visuels sur l'écran de l'ordinateur. Il peut causer des clignotements, des distorsions ou des changements de couleur sur l'affichage.

II.1.2.1.3 ARCHITECTURE D'UN VIRUS

Un virus se compose de 3 fonctionnalités principales et d'une quatrième Optionnelle (mais de plus en plus présente dans les virus afin d'en améliorer L'efficacité).

La figure 2.2. Ci-dessous illustre Architecture d'un virus.

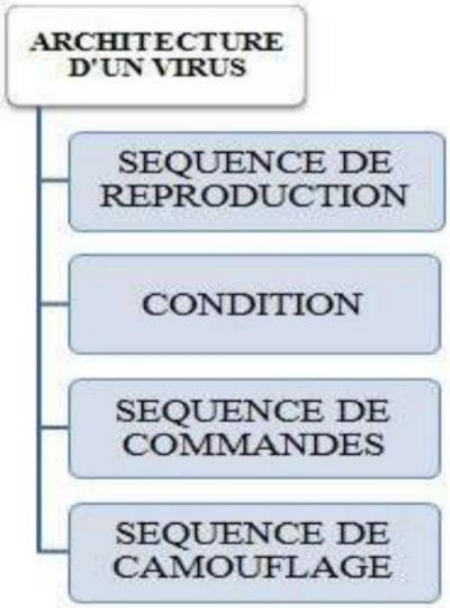

Figure 2.2: Architecture d'un virus

× La Séquence de reproduction

La séquence de reproduction fait la référence a l'ensemble des étapes ou actions qu'un virus informatique effectue pour se reproduire et infecter d'autres fichiers ou systèmes.

× Les Conditions

Les conditions font référence aux critères ou aux situations spécifiques qui doivent être remplis pour qu'une action ou un événement se produise. Dans le contexte des virus informatiques, cela peut inclure des conditions telles que la présence d'un certain système d'exploitation, la connexion a un réseau, etc.

× Séquence de commandes

La séquence de commande fait référence à l'ordre ou à la série d'instructions que suit un virus informatique pour exécuter ses actions ou ses tâches spécifiques. Cela peut inclure des instructions pour infecter des fichiers, se propager sur un réseau, Effacer des données, etc.

× Séquence de camouflage

Malgré leur petite taille, les virus peuvent être vite repérés (pour certains). Les développeurs de virus ont donc élaboré plusieurs techniques Pour cacher le virus. Il existe plusieurs techniques. Nous les aborderons en parlant Des virus polymorphes et furtifs par la suite. Il s'avère qu'en dépit de leur finalité, tous les virus fonctionnent selon un Modèle unifié qui les décrit tous : le modèle de virus générique.

II.1.2.1.4 MODE DE CONTAMINATION D'UN VIRUS

Le virus informatique utilise de même 4 modes de contamination pour se Propager dans les systèmes informatiques :

- Contamination par recouvrement : le virus écrase les premières instructions Du fichier par ses propres instructions. L'avantage est que la taille du fichier N'est pas modifiée. Cependant, il n'est plus utilisable par la suite, le début de Ses instructions ayant été supprimé.
- Contamination par ajout : le virus s'exécute avant le code original du fichier Infecté, mais repasse la main à ce dernier à la suite de son exécution. Dans ce cas, la taille du fichier est modifiée.
- Contamination par entrelacement : il s'agit ici d'insérer du code entre les Blocs valides du programme. Elle est plus difficile à mettre en place, mais est Moins facilement détectée.
- Contamination par accompagnement : Donc par ici, il s'agit tout simplement de Surcharger les fichiers infectés en les rendant plus lourd lors de leurs exécutions.

II.1.2.1.5 CYCLE DE VIE D'UN VIRUS

Les virus informatiques suivent un cycle de vie, qui recense 5 grandes étapes :

- Création ;
- Gestation ;
- Activation ;
- Découverte ;
- Elimination.

II.1.2.2 LES VERS INFORMATIQUES [35]

Un ver informatique est un type de logiciel malveillant qui se propage automatiquement d'un ordinateur a un autre, en exploitant les vulnérabilités du système ou en utilisant des mécanismes de propagation tels que les réseaux locaux, les courriels ou les périphériques de stockage amovibles. Contrairement aux virus, les vers n'ont pas besoin de s'attacher à un programme hôte existant pour se propager. Ils peuvent causer des dommages importants en ralentissant les systèmes, en détruisant des fichiers ou en compromettant la sécurité des données. Certains vers sont également conçus pour créer des réseaux de zombies, ou les ordinateurs infectés sont contrôler à distance par des pirates informatiques pour mener des attaques coordonnées.

II.1.2.2.1 Les Objectif malfaisant d'un ver informatique

Les objectifs malfaisants d'un ver informatique peuvent varier en fonction des intentions de ses créateurs. Voici quelques exemples :

1. Propagation et infection

L'objectif principal d'un ver informatique est de se propager à travers les systèmes informatiques en exploitant les vulnérabilités du système. Il peut chercher à infecter le plus grand nombre d'ordinateurs possible pour étendre sa portée et sa capacité de propagation.

2. Destruction de données

Certains vers sont conçus pour causer des dommages en détruisant des fichiers ou en corrompant des données. Cela peut entraîner la perte de données importantes pour les utilisateurs ou les organisations touchées.

3. Ralentissement des systèmes

Les vers peuvent consommer des ressources système importantes, ce qui entraîne un ralentissement significatif des performances des ordinateurs infectés. Cela peut rendre les systèmes inutilisables ou très lents, entraînant une perte de productivité et une frustration pour les utilisateurs.

4. Espionnage et vol d'informations

Certains vers sont conçus pour collecter des informations sensibles telles que des identifiants de connexion, des données bancaires ou des informations personnelles. Ces informations peuvent ensuite être utilisées à des fins malveillantes, telles que le vol d'identité ou le chantage.

5. Création de réseaux de zombies

Certains vers sont conçus pour créer des réseaux de zombies, également connus sous le nom de botnets, où les ordinateurs infectés deviennent contrôlés à distance par des pirates informatiques. Ces réseaux peuvent être utilisés pour mener des attaques coordonnées, telles que des attaques par déni de service distribué (DDoS), où un grand nombre d'ordinateurs infectés inondent un serveur cible de trafic malveillant, le rendant indisponible.

Il est important de noter que les vers informatiques sont illégaux et nuisibles. Les utilisateurs doivent prendre des mesures de sécurité appropriées pour se protéger contre les infections par des vers, telles que l'utilisation de logiciels antivirus et le maintien de leurs systèmes à jour avec les derniers correctifs de sécurité.

Voici les quelques exemples des vers sur Internet les plus célèbres :

- ILOVEYOU
- Conficker
- Code Red
- Slammer
- Stuxnet

II.1.2.2.2 CARACTERISTIQUE D'UN VER INFORMATIQUE

- Le ver est souvent transmis aux ordinateurs de différentes manières, telles que Le courrier électronique, des programmes source obscurs, des sites de forum, Des DVD et des CD de jeux piratés.
- Le ver est conçu pour se copier d'un ordinateur à un autre automatiquement. Tout d'abord, il prend le contrôle des propriétés qui transmettent des fichiers ou Des informations sur l'ordinateur. Cela peut entraîner un trafic réseau important En raison de l'effet domino, ce qui ralentit les réseaux des lieux de travail et L'ensemble de l'Internet.
- Le ver est une sous-classe de virus et se propage généralement sans action de L'utilisateur et distribue des copies complètes de lui-même (éventuellement Modifiées) de réseaux en réseaux.
- Un ver peut consommer de la mémoire ou de la bande passante réseau, ce qui Peut entraîner une panne d'ordinateur
- Comme les vers n'ont pas besoin d'un programme ou d'un fichier « support » pour Se répandre, ils peuvent ouvrir un tunnel dans votre système et permettre à une Autre personne de contrôler votre ordinateur à distance. Des exemples de vers Récents incluent le ver Sasser et le ver Blaster.

II.1.2.2.3 CLASSIFICATION D'UN VER INFORMATIQUE [11]

Il existe actuellement 4 Classifications des vers informatiques :

- Vers de réseau (Vers de réseaux de partage de fichiers) ;
- Vers de courrier électronique ;
- Vers de messagerie instantanée (Vers IRC : Internet Relay Chat) ;
- Vers Internet.

II.1.2.2.4 ARCHITECTURE D'UN VER INFORMATIQUE

Il Est composé de deux parties :

× Le vecteur c'est la partie principale du ver, qui s'occupe de la recherche de Failles et est responsable de transmettre la seconde partie du ver.

× L'archive c'est la partie « morte » du ver, qui sera envoyée sur le système Distant et l'infectera.

La figure 2.3. Ci-dessous illustre Architecture d'un ver informatique.

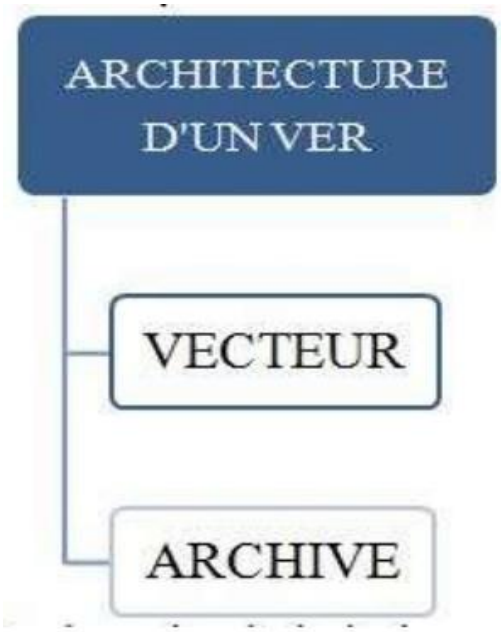

Figure 2.3: Architecture d'un ver informatique

Cette archive peut exister sous deux formes distinctes :

- Sous forme de sources – la reproduction est beaucoup plus aisée, car le nombre De machines potentiellement ciblées est beaucoup plus grand. L'inconvénient Majeur de ce procédé est qu'un compilateur est nécessaire sur la machine à Infecter. Les données nécessaires à l'infection sont plus volumineuses et une Compression des sources sera parfois opérée préalablement.

➢ Sous forme binaire – la reproduction de ce type de ver n'est possible que sur Une architecture compatible avec les données binaires. Cependant, ce format ne Nécessite pas de compilateur sur la machine hôte et est souvent plus compacte Que la version source. Il est à remarquer qu'il existe des vers multiformes, c'est-a-dire utilisant une archive en sources ou binaire selon le système à infecter.

II.1.2.2.5 MODE DE REPRODUCTION D'UN VER

Avant d'infecter un système, le ver doit procéder dans l'ordre à une série D'étapes. Ce n'est qu'à la suite de celles-ci qu'il pourra attaquer la machine cible. La Succession d'étapes est la suivante (et ne concerne que la partie « vecteur » jusqu'à la Phase d'invasion) :

- Initialisation – ce sont les premières instructions du ver. Il peut s'agir de la Création de fichiers temporaires, ou la compilation d'une partie de l'archive. A Cet instant, le ver est toujours sur la machine mère.

- Recherche de l'hôte – Cette étape procède à un scan d'IP. Ce scan peut être Aléatoire ou incrémental (on passe en revue des séries d'adresses IP). Pour Chacune d'entre elles, on teste si le système répond ou non (« up » ou « down »).

- Identification de l'hôte – une fois une victime potentielle détectée, le ver (la partie vecteur) va tester le système en place sur la machine distante. Il s'agira De vérifier si le système possède des failles pouvant être exploitées par le ver, S'il possède un compilateur approprié, … Si ce n'est pas le cas, on retourne à L'étape précédente.

- Attaque c'est ici que le ver exploite les vulnérabilités mises au jour dans la Phase précédente. Le vecteur obtient alors un accès sur la machine cible.

- Invasion Le vecteur est maintenant présent sur la machine cible, mais n'est Pas encore actif. Les instructions sont toujours données par la machine mère. Dès cet instant, le vecteur va rapatrier la partie archive sur le système à infecter. Deux techniques sont possibles :

1. Soit le vecteur est toujours accompagné de sa partie archive, auquel cas L'archive est présente sur la machine à tout moment, le vecteur uploadant Son archive de machines en machines. Cette technique est un peu plus Complexe à réaliser car le vecteur doit avoir été programmé pour Transmettre cette archive.

2. Soit le vecteur doit rapatrier la partie archive. Ce rapatriement se fait à Partir de la machine mère, ou depuis un serveur fixe (de type FTP) et Unique pour toutes les machines (mais dans ce cas, l'attaque se terminera si Le serveur tombe en panne). C"est beaucoup plus facile à réaliser, mais Également plus dangereux car l'utilisateur piraté pourra plus facilement Tracer le ver. Si l'archive est sous forme de sources, le vecteur devra Également procéder à la décompression et à la compilation de ces sources, le vecteur devra Également procéder à la décompression et à la compilation de ces sources Avant de passer à la phase suivante.

Les deux possibilités existent pour permettre la Reproduction du ver :

- Soit on tue le ver présent sur la machine mère. Le ver se déplacera alors de Stations en stations.
- Soit on ne le tue pas et chacun des deux vers continue à se propager selon La méthode décrite ci-dessus. Ce choix provoque une étendue exponentielle Du ver et est logiquement plus dangereuse que la précédente.

II.1.2.3 LE CHEVAL DE TROIE [15][35]

Un cheval de Troie, également connu sous le nom de Trojan, est un type de logiciel malveillant qui se présente légitime mais qui contient en réalité des fonctionnalités nuisibles. Le nom "Cheval de Troie" est inspiré de la légende grecque du cheval de Troie, ou les Grecs ont caché des soldats à l'intérieur d'un grand cheval en bois pour infiltrer et attaquer la ville de Troie.

Le cheval de Troie ne doit pas être confondu avec d'autres notions proches :

1. Un injecteur

Un injecteur est un type de logiciel qui permet d'injecter du code dans un processus en cours d'exécution sur un ordinateur. Cela peut être utilisé à des fins légitimes, comme le débogage ou la modification de jeux vidéo, mais peut également être utilisé de manière malveillante pour introduire des logiciels malveillants ou des fonctionnalités indésirables dans un système.

2. Une porte dérobée (ou backdoor en anglais)

Une porte dérobée est une méthode permettant d'accéder à distance à un système informatique sans que l'utilisateur en soit conscient. Cela peut être réalisé en exploitant des vulnérabilités ou en utilisant des mots de passe par défaut non sécurisés. Les portes dérobées peuvent être utilisées pour voler des informations, installer d'autres logiciels malveillants ou prendre le contrôle total du système.

3. Un rat (Remote Access Trojan)

Un rat est un type de logiciel malveillant qui permet à un attaquant d'accéder et de contrôler à distance un ordinateur infecté. Les rats sont souvent utilisés pour voler des informations sensibles, surveiller les activités de l'utilisateur, prendre des captures d'écran, activer la webcam ou le microphone, et exécuter d'autres actions malveillantes.

4. Une bombe de décompression (ou zip bombe en anglais)

Une bombe de décompression est un fichier compressé extrêmement petit qui, lorsqu'il est décompressé, se transforme en un fichier extrêmement volumineux. Cela peut entraîner une utilisation excessive du processeur, de la mémoire ou du stockage, ralentissant ou bloquant le système. Les bombes de décompression sont souvent utilisées pour causer des perturbations ou des dénis de service.

5. Un Trojan Stealer

Un trojan stealer est un type de cheval de Troie qui est spécifiquement conçu pour voler des informations sensibles stockées sur un ordinateur infecté. Cela peut inclure des identifiants de connexion, des mots de passe, des informations bancaires, des fichiers personnels, etc. Les Trojan stealers peuvent être distribués de différentes manières, telles que des pièces jointes d'e-mails ou des téléchargements de logiciels piratés, et peuvent causer des dommages importants à la vie privée et à la sécurité de l'utilisateur.

II.1.2.3.1 MANIFESTIONS D'UNE INFECTION PAR UN CHEVAL DE TROIE

Les manifestations d'une infection par un cheval de Troie peuvent varier en fonction du type de Trojan et de ses objectifs spécifiques. Cependant voici quelques signes courantes d'une infection par un cheval de Troie :

- Activité anormale de la carte réseau ou du disque dur (des données sont Chargées en l'absence d'activité de la part de l'utilisateur) ou du modem ;
- Ralentissement du système ;
- Pop-ups et publicité intrusives ;
- Modification inattendues des paramètres ;
- Réactions curieuses de la souris ;
- Ouvertures impromptues de programmes, du lecteur CD/DVD ;
- Plantages répétés ;
- Redémarrage répété du système ;
- Écran ou fenêtres avec des messages inhabituels ;
- Un comportement inhabituel dans le fonctionnement de l'ordinateur, tels que :

- Changements d'économiseur d'écran de bureau, modification du rôle des Boutons de la souris, modification du volume du lecteur audio ;
- Ouverture/Fermeture intempestive de fenêtres ;
- Les programmes commencent ou terminent leur exécution de manière Inattendue ;
- Le navigateur accède tout seul à certains sites Internet ;
- Présence d'autres programmes qui n'ont pas été volontairement installés (y Compris des logiciels malveillants) ;
- Vol de renseignements personnels : informations bancaires, mots de passe, Codes de sécurité…
- Suppression, modification ou transfert de fichiers (téléchargement ou upload) ;
- Exécution ou arrêt de processus ;

- Arrêt ou redémarrage impromptus de l'ordinateur ;
- Surveillance des frappes (voir Enregistreur de frappe) ;
- Captures d'écran impromptues ;
- Espace libre du disque dur occupé par des fichiers inutiles.

II.1.2.4 LES ROOTKITS [2] [17]

Les rootkits sont des types de logiciels malveillants conçus pour cacher leur présence et leurs activités sur un système infecté. Ils sont souvent utilisés par des attaquant pour obtenir un accès non autorisé à un ordinateur et maintenir ce contrôle de manière furtive.

II.1.2.4.1 TYPES DES ROOTKITS

Il existe plusieurs types de rootkits, chacun ayant ses propres caractéristiques et méthodes d'infection. Voici quelques-uns des types les plus courants :

- *Rootkits de noyau*
- *Rootkits de bibliothèque*
- *Rootkits de firmware*
- *Rootkits d'application*
- *Rootkits matériels*

II.1.2.4.2 MODE OPERATOIRE D'UN ROOTKIT

Le mode opératoire d'un rootkit peut varier en fonction de son type et de son objectif spécifique. Cependant, voici les étapes générales que la plupart des rootkits suivent :

× **Infection initiale**

Le rootkit doit trouver un moyen de s'introduire dans le système. Cela peut se faire par le biais de téléchargements malveillants, de pièces jointes infectées, d'exploits de vulnérabilités logicielles ou d'autres méthodes d'infection.

× **Installation**

Une fois dans le système, le rootkit tente de s'installer de manière permanente. Cela peut impliquer la modification du noyau du système d'exploitation, des bibliothèques système, du micro logiciel ou des applications spécifiques, selon le type de rootkit.

× **Furtive**

Une fois installé, le rootkit cherche à se cacher et à éviter d'être détecté. Il peut utiliser des techniques telles que l'obscurcissement des fichiers et des processus, la désactivation des outils de sécurité et la modification des logs système pour masquer ses activités.

× **Privileges élevés**

Les rootkits cherchent souvent à obtenir des privilèges élevés, tels que ceux d'un utilisateur administrateur ou du système. Cela leur donne un accès plus étendu et leur permet de contourner les mesures de sécurité.

- **Persistence**

Pour assurer sa survie, le rootkit doit être capable de persister même après un redémarrage du système ou une réinstallation du système d'exploitation. Cela peut être réalisé en modifiant le micro logiciel, en ajoutant des entrées de démarrage automatique ou en utilisant d'autres techniques pour se réinstaller après un nettoyage.

- **Actions malveillantes**

Une fois installé et caché, le rootkit peut effectuer diverses actions malveillantes en fonction de ses objectifs spécifiques. Cela peut inclure la collecte d'informations sensibles, l'installation de logiciels malveillants supplémentaires, le vol d'identifiants, l'espionnage des activités de l'utilisateur, etc.

- **Évasion de la détection**

Les rootkits sont conçus pour être difficiles à détecter et à supprimer. Ils peuvent utiliser des techniques d'évasion telles que la modification des signatures de fichiers, la dissimulation dans des zones inaccessibles du système ou la résistance aux outils de sécurité

Il est important de noter que la détection et la suppression des rootkits peuvent être très difficiles et nécessitent souvent l'utilisation d'outils spécialisés et l'expertise d'un professionnel en sécurité informatique.

II.1.2.5 LES PORTES DEROBEES [2]

Dans un logiciel, une porte dérobée (de l'anglais backdoor, littéralement porte de derrière) est une fonctionnalité inconnue de l'utilisateur légitime, qui donne un accès secret au logiciel. L'introduction d'une porte dérobée dans un logiciel à l'insu de son utilisateur transforme le logiciel en cheval de Troie.

II.1.2.5.1 TECHNIQUES UTILISEES

Une porte dérobée peut être introduite soit par le développeur du logiciel, soit par un tiers. La personne connaissant la porte dérobée peut l'utiliser pour surveiller les activités du logiciel, voire en prendre le contrôle (par contournement de l'authentification). Enfin, selon l'étendue des droits que le système d'exploitation donne au logiciel contenant la porte dérobée, le contrôle peut s'étendre à l'ensemble des opérations de l'ordinateur. La généralisation de la mise en réseau des ordinateurs rend les portes dérobées nettement plus utiles que du temps où un accès physique à l'ordinateur était la règle.

Parmi les motivations amenant les développeurs de logiciel à créer des portes dérobées, il y a :

- L'intérêt pratique d'un accès facile et toujours ouvert au logiciel pour pouvoir mener efficacement les actions de maintenance
- La possibilité de désactiver subrepticement le logiciel en cas de désaccord avec son client (non-paiement de licence). Parmi les motivations amenant les pirates informatiques à installer une porte dérobée :
- La possibilité de surveiller ce que fait l'utilisateur légitime et de copier ou détruire des données ayant une valeur (mots de passe, clé privée pour déchiffrer des messages privés, coordonnées bancaires, secrets commerciaux) ;
- La possibilité de prendre le contrôle d'un ordinateur et de pouvoir l'utiliser pour Mener des actions malfaisantes (envoi de pourriels notamment pour L'hameçonnage, de virus informatiques, déni de service) ;
- Le contrôle d'un vaste réseau d'ordinateurs (voire botnet), qui peut être utilisé Pour du chantage au déni de service distribué (DDoS), ou revendu à des Criminels. Pour installer des portes dérobées en masse, les pirates utilisent des vers. Ceux-Ci se répandent automatiquement et installent un serveur informatique sur chaque Ordinateur infecté. Ensuite le pirate peut se connecter à travers Internet au serveur

II.1.2.6 ESPIONAGE INFORMATIQUE

L'espionnage informatique est une surveillance secrète et désobligeante Accomplis par un attaquant au moyen de l'outil informatique afin de s'acquérir des Informations dont il n'est pas censé obtenir. L'espionnage informatique peut S'effectuer de plusieurs manières, les plus usuelles sont :

- L'homme du milieu (Environnement informatique) ;
- Les espiogiciels ;
- Les cookies.

II.1.2.6.1 L'HOMME DU MILIEU

Lorsqu'un pirate, prenant le contrôle d'un équipement du réseau, se place au Milieu d'une communication il peut écouter ou modifier celle-ci. On parle alors de Lhomme du milieu » (man in the middle). Les points sensibles permettant cette Technique sont les plus souvent les protocoles :

- DHCP
- ARP
- ICMP
- RIP
- DNS
- Proxy http
- Virus etc...

II.2 MESURES DES PROTECTIONS [5] [12] [13] [14] [21] [30]

Une mesure de protection est un ensemble des techniques permettant de se prémunir contre les attaques et piraterie informatique, en interdisant la copie de contenus d'un support (logiciel) ou en rendant inutilisable toute intrusion dans le système.

Les mesures des protections les plus connus sont :

- Les anti-virus;
- Les systèmes de détection (et prévention) d'intrusion (IDS) ;
- Les firewalls(Pare-feu) ;
- Les contrôles d'accès.
- L'authentification

II.2.1 LES ANTI-VIRUS [30]

Les antivirus sont des logiciels conçus pour identifier, neutraliser et éliminer des logiciels malveillants (dont les virus informatique ne sont qu'une catégorie). Ces derniers peuvent se baser sur l'exploitation de failles de sécurité, mais il peut également s'agir de logiciels modifiant ou supprimant des fichiers, que ce soit des documents de l'utilisateur stockés sur l'ordinateur infecté, ou des fichiers nécessaires au bon fonctionnement de l'ordinateur (le plus souvent ceux du système d'exploitation).

Il est intéressant de noter qu'une fois un fichier infecté, il ne l'est jamais deux fois. En effet, un virus est programmé de telle sorte qu'il signe le fichier dès qu'il est contaminé. On parle ainsi de signature de virus. Cette signature consiste en une suite de bits apposée au fichier. Cette suite, une fois décelée, permettra de reconnaitre le virus. Lorsque le virus est détecté par l'antivirus, plusieurs possibilités sont offertes pour l'éradiquer :

- Supprimer le fichier infecté;
- Supprimer le code malicieux du fichier infecté ;
- Placer le ou les fichiers infectés en "quarantaine" pour un traitement futur.

II.2.1.1 FONCTIONNEMENT DE L'ANTI-VIRUS

Un logiciel antivirus vérifie les fichiers et courriers électroniques, les secteurs de démarrage (afin de détecter les virus de boot), mais aussi la mémoire vive de l'ordinateur, les médias amovibles (clefs USB, CD, DVD, etc.), les données qui transitent sur les éventuels réseaux (dont internet) … Différentes méthodes sont possibles :

- Les principaux antivirus du marché se concentrent sur des fichiers et comparent alors la signature virale du virus aux codes à vérifier ;

- La méthode heuristique est la méthode la plus puissante, tendant à découvrir un code malveillant par son comportement. Elle essaie de le détecter en analysant le code d'un programme inconnu. Parfois de fausses alertes peuvent être provoquées;

- L'analyse de forme repose sur du filtrage basé entre des règles rege-xp ou autres, mises dans un fichier Junk. Cette dernière méthode peut être très efficace pour les serveurs de messagerie électronique supportant les rege-xp type postfix puisqu'elle ne repose pas sur un fichier de signatures.

II.2.1.2 TECHNIQUES DE DETECTION DES ANTI-VIRUS

Il y a plusieurs techniques de détections, mais nous suggérons quelques techniques spécialement :

- Un scanning de signature est une technique utilisée par les antivirus pour détecter les malwares en comparant les signatures connues des fichiers malveillants avec les fichiers présents sur un système. Lorsqu'un fichier correspond à une signature connue, il est identifié comme un malware.
- Un moniteur de comportement est un outil qui surveille les activités des programmes en cours d'exécution pour détecter les comportements suspects ou malveillants. Il peut identifier les actions telles que la modification du registre, l'accès à des fichiers sensibles ou la communication avec des serveurs inconnus.
- Une liste blanche est une liste préalablement établie de programmes, fichiers ou processus considérés comme sûrs et autorisés à s'exécuter sur un système. Les antivirus peuvent utiliser cette liste pour exclure les fichiers légitimes de leurs analyses, ce qui permet de réduire les faux positifs.
- Un contrôleur d'intégrité est un outil qui vérifie régulièrement l'intégrité des fichiers système en comparant leur état actuel avec une empreinte ou une signature préalablement enregistrée. Si un fichier a été modifié ou altéré, cela peut indiquer la présence d'un malware ou d'une modification non autorisée.
- L'analyse heuristique est une technique utilisée par les antivirus pour détecter les malwares en analysant le comportement des programmes et en identifiant les modèles ou les caractéristiques suspectes. Elle permet de détecter les nouvelles variantes de malwares qui n'ont pas encore de signatures connues.

II.2.2 LES SYSTÈMES DE DÉTECTION ET DE PRÉVENTION [30] [33]

Un système de détection et de prévention est un ensemble d'outils et de techniques utilisés pour identifier et bloquer les menaces de sécurité sur un système informatique. Il peut inclure des fonctionnalités telles que la détection d'intrusion, la protection contre les logiciels malveillants, le filtrage du trafic réseau et la surveillance du comportement des utilisateurs. L'objectif principal d'un tel système est de prévenir les attaques et de protéger les données et les ressources du système contre toute activité suspecte ou malveillante.

II.2.2.1 SYSTEMES DE DÉTECTION D'INTRUSION

Un système de détection d'intrusion (ou IDS : Intrusion Détection System) est un mécanisme destiné à repérer des activités anormales ou suspectes sur la cible analysée (un réseau ou un hôte). Il permet ainsi d'avoir une connaissance sur les tentatives réussies comme échouées des intrusions. Les IDS, les plus connus selon leurs différentes catégories sont :

II.2.2.1.1 Les systèmes de détection d'intrusion en réseau (NIDS)

Un système de détection d'intrusion en réseau (NIDS) sont des outils utilisés pour surveiller et analyser le trafic réseau afin de détecter les activités suspectes ou malveillantes. Ils peuvent être basés sur des règles prédéfinies, des modèles comportementaux ou des algorithmes d'apprentissage automatique pour identifier les comportements anormaux.

Le Figure 2.4 Illustre les systèmes de détection d'intrusion en réseau

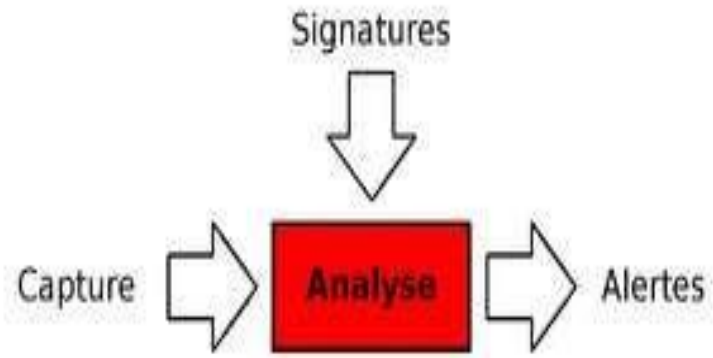

Figure 2.4: ***LES NIDS (IDS réseau)***

- **Fonctionnement du système de détection d'intrusion en réseau (NIDS)**

Pour détecter les menaces, les systèmes de détection des intrusions basés sur le réseau recueillent des informations sur le trafic internet entrant et sortant. Pour maximiser la visibilité, les capteurs NIDS sont placés stratégiquement sur un réseau. Par exemple sur un LAN et une DMZ. Les systèmes NIDS utilisent une combinaison de méthodes de détection basées sur les signatures et les anomalies. La détection basée sur les signatures consiste à comparer les caractéristiques des paquets de données collectés avec des fichiers de signature connus pour être malveillants. La détection basée sur les anomalies utilise l'analyse comportementale. Une analyse censée surveiller les évènements par rapport à une ligne de base de l'activité « typique » du réseau. Lorsqu'une activité malveillante ou anomale se produit sur un réseau, par exemple une augmentation

soudaine du trafic réseau, les technologies NIDS détectent l'activité. Elles génèrent ainsi des alertes pour les enquête.

II.2.2.1.2 Système de détection d'intrusion basé sur Hôte(HIDS)

Un système de détection des intrusions basé sur hôte(HIDS) est un système qui surveille un système informatique sur lequel il est installé. Il s'agit d'un système permettent de détecter une intrusion et/ou une utilisation abusive. Il peut également réagir en enregistrant l'activité et en notifiant l'autorité désignée. Un HIDS peut être considéré comme un agent qui surveille et analyse si quelque chose ou quelqu'un, interne ou externe, a contourné la politique de sécurité du système.

II.2.2.1.2.1 DIFFERENT ES TECHNIQUES DES NIDS

- **La recherche de motif (pattern matching)** : La recherche de motif est ce qui permet à un NIDS de trouver le plus rapidement possible les informations dans un paquet réseau.
- **L'Analyse** à partir des éléments donnés dans l'introduction, le moteur d'analyse met ces éléments de relation en employant plusieurs techniques : la défragmentation, la dissection protocolaire ou encore l'analyse comportementale :

- **La défragmentation** : Les paquets dépassant une certaine taille (qui en général est de 1 500 octets) sont fragmentés.
- **La dissection** : permet de comprendre un protocole donné, de le décoder pour l'analyser. Il s'agit de la partie la plus sensible des NIDS car c'est elle qui est le plus grand vecteur d'attaques.

II.2.2.1.2.2 Les mécanismes des HIDS

Les HIDS possèdent tout ou partie des mécanismes suivants :

- Surveillance des fichiers journaux, Exemple : Logcheck, logwatch, Swatch, OSSEC…
- Contrôles d'intégrité des fichiers, Exemple : tripwire, samhain, AIDE, mtree, OSSEC…
- Détection de rootkits, Exemple : OSSEC, chrootkit, rootkithunter
- Détection de comportements douteux (scans étude des syscalls…) Exemple : portsentry, scandlogd, lids, systrace...

II.2.2.1.3 Les IDS hybride

Les IDS hybrides sont basés sur une architecture distribuée, où chaque composant unifie son format d'envoi d'alerte (typiquement IDMEF : Intrusion Détection Message Exchange Format) permettant à des composants divers de communiquer et d'extraire des alertes plus pertinentes.

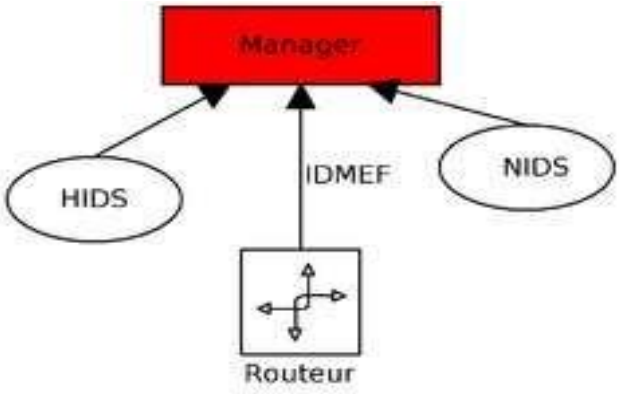

*Figure 2.5: **représentation LES IDS hybride***

Les avantages des IDS hybrides sont multiples :

- Moins de faux positifs;
- Meilleure correlation;
- Possibilité de réaction sur les analyseurs.

II.2.2.1.3.1 TECHNIQUES D'ANALYSE DU TRAFIC DES IDS

Il existe principalement deux techniques d'analyse du trafic, chacune ayant des avantages et des inconvénients :

- **L'analyse comportementale (AIDS : Anomaly Intrusion Détection System)** à partir d'un comportement normal déterminé, l'IDS analyse le comportement des machines. Si un ordinateur se connecte en pleine nuit alors que personne n'est présent, cela pourrait lever une alerte pour l'IDS. Ainsi, dans ce type d'analyse, un profil est dressé et lorsque la machine liée s'éloigne du profil type, l'IDS réagit.

  - **Avantage** : ce type d'analyse permet de détecter des attaques inconnues, elle ne nécessite pas de base de données.
  - **Inconvénient** : cette détection est assez aléatoire, elle peut produire de fausses alertes relativement facilement.

- **L'analyse par scénario (MIDS : Misuse Intrusion Détection System)** l'IDS utilise ici une base de données de signatures d'attaques. Ces signatures peuvent être assimilées à des déroulements d'attaques. En effet, chaque attaque possède des caractéristiques propres (numéro de port, taille de paquet, protocole employé...). Ces caractéristiques peuvent être collectées et placées dans une base de données qu'interrogera l'IDS. Ce type d'IDS utilise les fichiers journaux (log). Dès qu'il détectera des séquences suspectes (relatives à une signature de sa base de données), il déclenchera une alerte.

- **Avantage** : on peut gérer les attaques de façon très précise.

- **Inconvénient** : on doit maintenir une base de données à jour.

II.2.2.1.3.2 LA CORRÉLATION DES IDS HYBRIDE

La corrélation est une connexion entre deux ou plusieurs éléments, dont un de ces éléments crée ou influence un autre. Elle se traduit plus généralement par la transformation d'une ou plusieurs alertes en attaque. Cela permet de faciliter la compréhension sur les attaques au lieu de s'éparpiller parmi les alertes.
Ce pendant on peut définir deux catégories de corrélation :

- **La corrélation passive** - correspondant à une génération d'alerte basée sur celles existantes. Nous pouvons prendre par exemple les scans de force brute ssh ;
- **La corrélation active** - qui va chercher les informations correspondant à des alertes émises. Par exemple, lorsqu'une personne se connecte en dehors des heures de travail, cela a une influence importante qui n'aurait pas été en temps normal d'activité.

II.2.2.1.3.3 L'HARMONISATION DES FORMATS

Le format IDMEF (Intrusion Détection Message Exchange Format) décrit une alerte de façon objet et exhaustive. Une alerte est le message qui est émis depuis un analyseur, qui est une sonde en langage IDMEF, vers un collecteur. Le but d'IDMEF est de proposer un standard permettant d'avoir une communication homogène quels que soient l'environnement ou les capacités d'un analyseur donné.

II.2.2.1.3.4 LA CONTRE-MESURE DES IDS HYBRIDE

La contre-mesure est l'art de piloter les éléments réseau ou la machine cible, afin d'empêcher une attaque de se propager (Islanding) ou de perdurer. Il s'agit d'une procédure assez compliquée et souvent désactivée. Ce qui rend la contre-mesure difficile est la définition d'une attaque d'un point de vue formel. Il n'est pas possible de se baser sur des éléments qui génèrent des faux positifs. Et cela peut aussi engendrer un autre problème où l'attaquant se fait passer pon client du réseau en générant des motifs d'attaque. Cela peut même bloquer le réseau interne si la contre-mesure est mal configurée. Un système de contre-mesure se configure en général avec une liste blanche, dans laquelle sont mises les IP du réseau interne.

La figure 2.1. Ci-dessous illustre La configuration d'un système de contre-mesure IDS Hybride

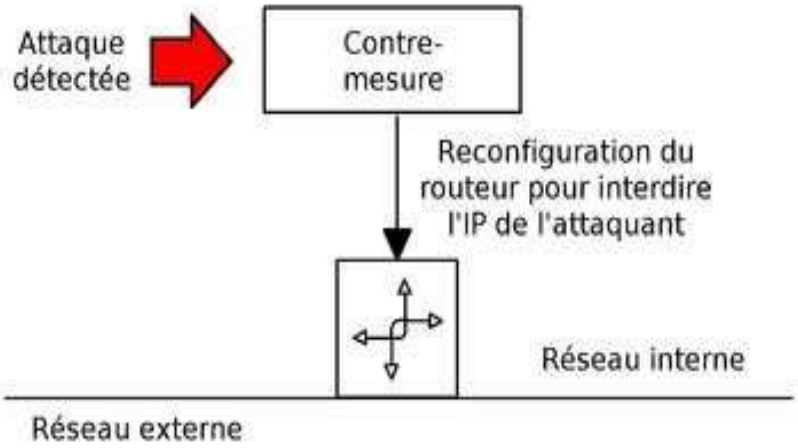

*Figure 2.6: **La configuration d'un système de contre-mesure IDS Hybride***

II.2.2.2 LES FIREWALLS (PARE-FEU) [12] [14]

Un pare-feu (firewall) est un logiciel et/ou un matériel permettant de faire respecter la politique de sécurité du réseau, celle-ci définissant quels sont les types de communications autorisés sur ce réseau informatique. Le pare-feu a pour objectif principal de surveiller et contrôler les applications et les flux de données (paquets), en empêchant les connexions non-autorisées sur un réseau informatique ou autres.

La figure 2.1. Ci-dessous illustre types de communication autorisée sur le RX

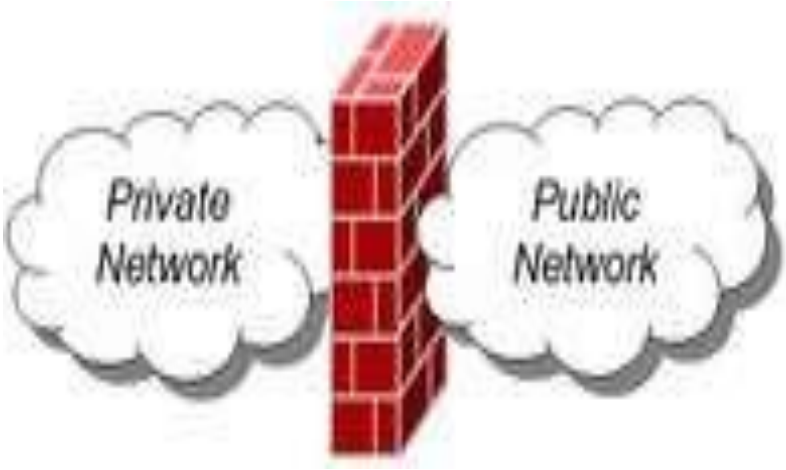

*Figure 2.7: **Types de communication autorisée sur Rx***

× Structure simple d'un pare-feu Selon le contexte, le terme peut revêtir différentes significations :

- Dans le domaine de la lutte contre les incendies de forêt, il se réfère aux allées pare-feu destinées à contenir l'extension des feux de forêts ;
- Au théâtre, le déclenchement d'un mécanisme « pare-feu » (ou « coupe-feu ») permet d'éviter la propagation du feu de la salle vers la scène ;
- Dans le domaine de l'architecture, il fait référence aux portes coupe-feu ou à tout autre dispositif constructif destiné à contenir l'extension d'un incendie ;
- En informatique, l'usage du terme « pare-feu » est donc métaphorique. Sa dénomination, reprend au sens figuré l'intention de "brûler par un mur de feu virtuel" tout ce qui tente d'entrer avec l'intention de nuire dans une machine ou un réseau. Il établit une barrière de protection contre les intrusions et les contaminations venant de l"extérieur.

D'une manière concrète, un pare-feu un système matérielle et immatérielle dédiée au routage entre LAN et Internet. Le trafic est analysé au niveau des datagrammes IP (adresse, utilisateur, contenu...). Un datagramme non autorisé sera simplement détruit, IP sachant gérer la perte d'information. Une translation d'adresse pourra éventuellement être effectuée pour plus de sécurité (protocole NAT Network Address Translation). Deux types d'architectures peuvent être exploités l'architecture classique et l'architecture concentrée. :

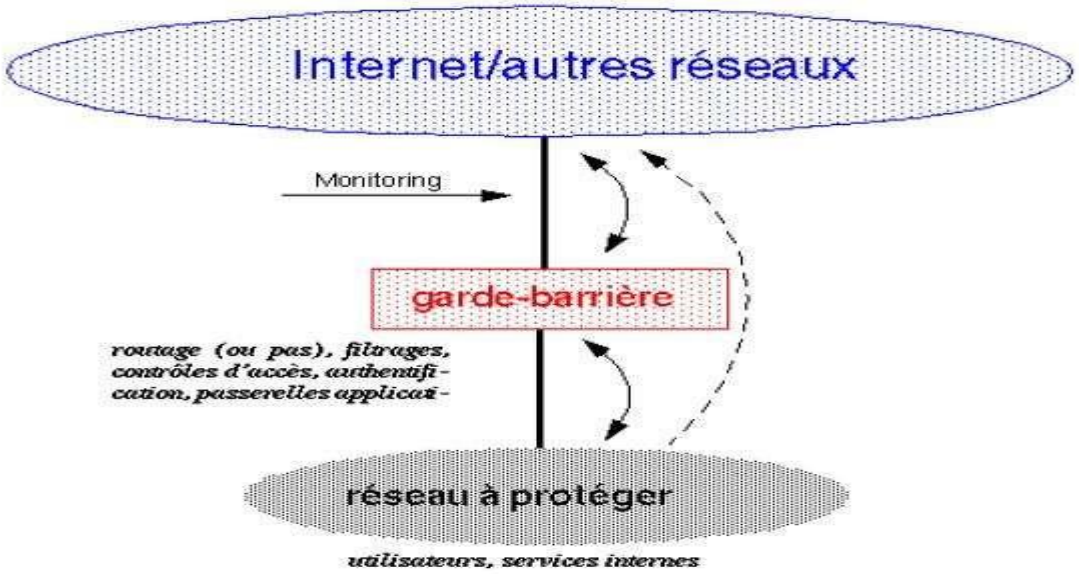

Figure 2.8: Types d'architectures d'un pare-feu

II.2.2.2.1 PRINCIPES DE FONCTIONNEMENT DE PARE-FEU

Le pare-feu est jusqu'à ces dernières années est considéré comme une des pierres angulaires de la sécurité d'un réseau informatique (il perd en importance au fur et à mesure que les communications basculent vers le HTTP sur TLS, court-circuitant tout filtrage). Il permet d'appliquer une politique d'accès aux ressources réseau (serveurs). Il a pour principale tâche de contrôler le trafic entre différentes zones de confiance, en filtrant les flux de données qui y transitent. Généralement, les zones de confiance incluent Internet (une zone dont la confiance est nulle) et au moins un réseau interne

(une zone dont la confiance est plus importante). Le but est de fournir une connectivité contrôlée et maîtrisée entre des zones de différents niveaux de confiance, grâce à l'application de la politique de sécurité et d'un modèle de connexion basé sur le principe du moindre privilège. On peut alors distinguer 3 types de principes de fonctionnement des pare-feu :

- Le filtrage de paquets (Packet Filtering)
- Le filtrage du flux (Circuit Filtering)
- La passerelle applicative (Application Gateway)

La Figure ci-dessus illustre le principe de fonctionnement de pare-feu

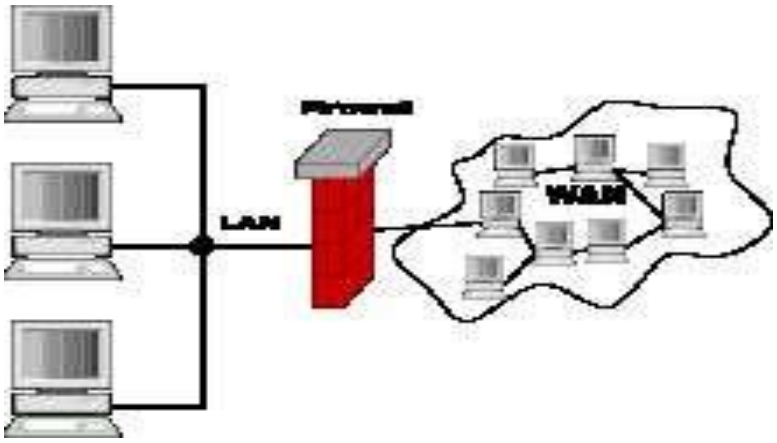

*Figure 2.9: **Principes de fonctionnement de pare-feu***

- **Le filtrage de paquets (Packet Filtering)**

Les paquets sont analysés en les comparants à un ensemble de filtres (c'est-à-dire à un ensemble de règles). Les paquets seront alors soit rejetés, soit acceptés et transmis au réseau interne. Lorsque le paquet arrive au Firewall, celui-ci analyse les champs IP et TCP/UDP. Ils sont confrontés à chacune des règles spécifiées dans la table des autorisations présente dans le Firewall, et configurée par l'administrateur du système. Selon les règles qui autorisent ou refusent la transmission des paquets, le Firewall obéira aux ordres. Si un paquet ne satisfait à aucune des règles, il est soit rejeté, soit accepté, suivant la philosophie choisie par l'administrateur réseau :

- Ce qui n'est pas expressément permis est interdit ;
- Ce qui n'est pas expressément interdit est permis. La première de ces deux approches est beaucoup plus sûre. La seconde est plus risquée car elle suppose que l'administrateur est certain d'avoir envisagé tous les cas pouvant engendrer des problèmes.

Le filtrage se fait selon divers critères. Les plus courants sont :

× l'origine ou la destination des paquets (adresse IP, ports TCP ou UDP, interface réseau, etc.) ;

× Les options contenues dans les données (fragmentation, validité, etc.) ;

× Les données elles-mêmes (taille, correspondance à un motif, etc.) ;

× Les utilisateurs pour les plus récents.

L'avantage du filtrage par paquet est sa rapidité. Il est de plus relativement simple à implanter dans un réseau. Néanmoins, la sécurité ne peut se baser uniquement sur le filtrage par paquet. D'une part, il est difficile de maintenir un niveau suffisant de sécurité lorsque le nombre de règles augmente. D'autre part, le type d'informations accessibles à ce niveau est limité, en l'occurrence, il n'identifie que la machine et non son utilisateur.

Un pare-feu fait souvent office de routeur et permet ainsi d'isoler le réseau en plusieurs zones de sécurité appelées zones démilitarisées ou DMZ. Ces zones sont séparées suivant le niveau de confiance qu'on leur porte.

La figure 2.1. Ci-dessous illustre zones démilitarisées ou DMZ

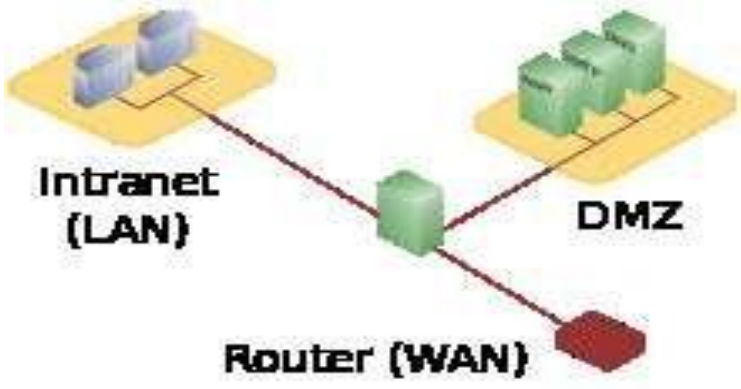

*Figure 2.10: **Zones démilitarisées ou DMZ.***

- **Le filtrage du flux (Circuit Filtering)**

Le filtrage de flux ne prête pas attention au contenu des paquets transitant sur la connexion. De ce fait, ce type de filtrage ne peut être utilisé pour assurer l'authentification des parties, ou la sécurité du protocole par l'intermédiaire duquel a lieu la connexion.

La passerelle applicative (Application Gateway)

Une passerelle applicative est un dispositif de sécurité utilise pour protéger les applications et les services en ligne contre les attaques et les intrusions.

Une passerelle applicative agit comme un intermédiaire entre les utilisateurs externes et les applications internes. Elle analyse le trafic réseau entrant et sortant, en inspectant les données et en appliquant des règles de sécurité spécifiques à chaque application.

II.2.2.3 LE CONTRÔLE D'ACCÈS [13] [34]

II.2.2.3.1 Définition du contrôle d'accès

Le contrôle d'accès est un élément incontournable de la sécurité et détermine qui est autorisé à accéder à certaines données, applications et ressources, et dans quelles circonstances. De la même manière que les clés et les listes d'invités pré-approuvés protègent les espaces physiques, les stratégies de contrôle d'accès protègent les espaces numériques. En d'autres termes, ils laissent entrer les bonnes personnes mais pas les mauvaises. Les stratégies de contrôles d'accès reposent en grande partie sur des techniques telles que l'authentification et l'autorisation, qui permettent aux organisations de vérifier explicitement que les utilisateurs sont bien ceux qu'ils prétendent être et que ces utilisateurs se voient accorder le niveau d'accès approprié en fonction du contexte (appareil, emplacement, rôle etc.).

Le contrôle d'accès empêche le vol d'information confidentielles, telle que les données des clients et la propriété intellectuelle, par des acteurs malveillants ou d'autres utilisateurs non autorisés. Il réduit également le risque d'exfiltration de données par les employés et prévient les menaces émanant du web. Plutôt que de gérer les autorisations manuellement, la plupart des organisations axées sur la sécurité s'appuient sur des solutions de gestion des identités et des accès pour mettre en œuvre des stratégies de contrôle d'accès.

II.2.2.3.2 Différents types de contrôle d'accès

Il existe quatre principaux types d'accès, chacun permet de gérer l'accès aux informations sensibles d'une manière unique.

- **Contrôle d'accès discrétionnaire (DAC)**

Dans les modèles DAC, chaque objet d'un système protégé a un propriétaire, et celui-ci accorde l'accès aux utilisateurs a sa discrétion. Le contrôle d'accès discrétionnaire permet un contrôle au cas par cas des ressources

.

- **Contrôle d'accès obligatoire (MAC)**

Dans les modèles MAC, les utilisateurs se voient accorder un accès sous forme d'autorisation. Une autorité centrale régule les droits d'accès et les organises en niveaux, qui s'entendent uniformément. Ce modèle est très courant dans les contextes gouvernementaux et militaires.

- **Contrôle d'accès en fonction du rôle (RBAC)**

Dans les modèles RBAC, les droits d'accès sont accordés selon des fonctions métier définies, plutôt que de l'identité ou de l'ancienneté des personnes. L'objectif consiste a fournir aux utilisateurs les seules données dont ils ont besoin pour exercer leurs fonctions, et pas plus.

- **Contrôle d'accès en fonction de l'attribut (ABAC)**

Dans les modèles ABAC, l'accès est accordé de manière flexible en fonction d'une combinaison d'attributs et de conditions environnementales, telles que l'heure et le lieu. Le contrôle d'accès en fonction de l'attribut est le modèle de contrôle d'accès le plus granulaire et permet de réduire le nombre d'affectations de rôle.

II.2.2.3.3 Le Fonctionnement du contrôle d'accès

Dans sa forme la plus simple, le contrôle d'accès consiste à identifier un utilisateur sur la base de ses informations d'identification, puis à autoriser le niveau d'accès approprié une fois cet utilisateur authentifier. Les mots de passe, les codes PIN, les jetons de sécurité, voire les analyses biométriques, sont autant d'informations d'identification couramment utilisées pour identifier et authentifier un utilisateur. L'authentification multifacteur (MFA). Une autre couche de sécurité en exigeant que les utilisateurs soient soumis à plusieurs méthodes de vérification. Une fois l'identité d'un utilisateur authentifiée, les stratégies de contrôle d'accès accordent des autorisations spécifiques et permettent à cet utilisateur de poursuivre comme il le souhaite.

II.2.2.4 L'AUTHENTIFICATION [34]

II.2.2.4.1 Définition

L'authentification est un processus de vérification de l'identité d'un utilisateur, d'un système ou d'une entité. Il permet de s'assurer que la personne ou l'identité qui demande l'accès à un système ou à des informations est bien celle qu'elle prétend être. L'authentification est classée en deux catégories à savoir :

- L'authentifaction faible,
- L'authentication forte.

1. L'authentification faible

C'est une méthode dite rejouable puisqu'elle est axée sur un élément statique. De nombreux systèmes informatiques sont basés sur cette technique et utilisent des login/mot de passe. Cette option présente pourtant plusieurs contraintes puisque le mot de passe choisi par l'utilisateur est généralement très simple.

2. L'auhentification forte

L'authentification forte est un processus de sécurité qui nécessite deux méthodes d'authentification distinctes pour vérifier l'identité d'un utilisateur. Cela renforces la sécurité en ajoutant une couche supplémentaire de protection, car même si un facteur d'authentification est compromis, l'autre facteur reste intact.

- **Technologies pour l'authentification forte**

La figure 2.11. Ci-dessous illustre technologies pour l'authentification forte.

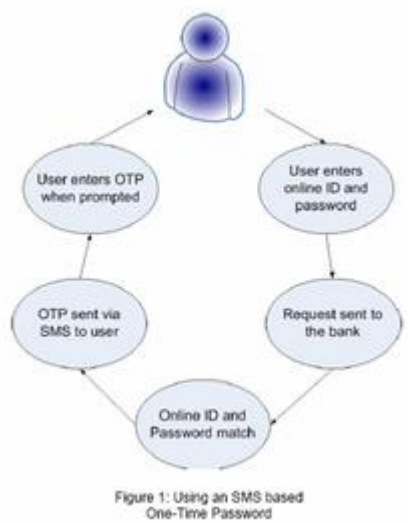

Figure 2.11: ***technologies pour l'authentification forte***

- Fonctionnement d'un One Time Password via SMS

La figure 2.12. Ci-dessous illustre le fonctionnement d'un one time password

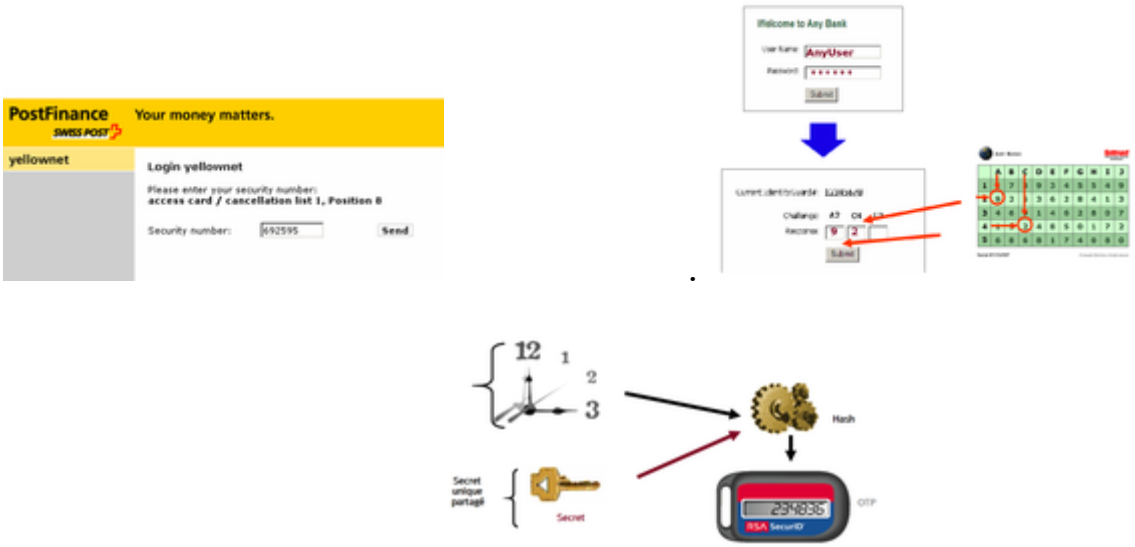

*Figure 2.12: **fonctionnement d'un one time password***

- Fonctionnement dune carte matricielle

La figure 2.13. Ci-dessous illustre le fonctionnement d'une carte matricielle.

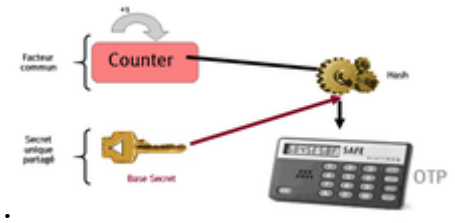

*Figure 2.13: **fonctionnement d'une carte matricielle***

- Fonctionnement d'un authentiquer fondé sur un compteur

Un authentifier fondé sur un compteur. Fonctionnement d'un authentifier fondé sur un mécanisme de « Challenge Réponse ».

La figure 2.14. Ci-dessous illustre le fonctionnement d'une authentification fondé sur un compteur

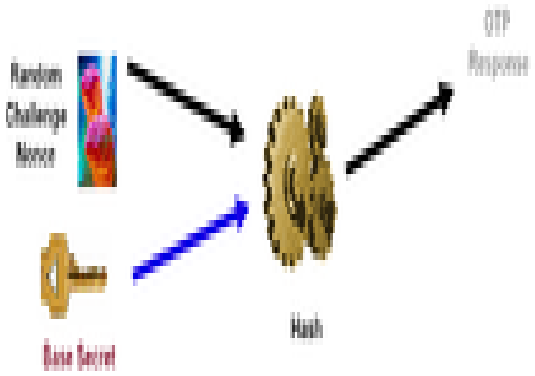

Figure 2.14: Fonctionnement d'une authentification fondé sur un compteur

CHAPITRE III. ETUDE DE L'EXISTANT (L'Equity BCDC) [19]

III.1 INTRODUCTION

L'étude de l'existant constitue une étape préliminaire pour la réalisation d'une solution informatique. En effet, elle permet d'analyser, d'évaluer et de critiquer le fonctionnement habituel, tout en élaborant la liste de solutions possibles. Ce chapitre sera réservé pour présenter l'étude préalable de notre projet.
Nous commençons par une description détaillée actuel mis en place. Cette description nous mène à une analyse et une critique de l'existant.
Enfin, nous allons proposer les différentes solutions aux problèmes soulevés

III.2 PRESENTATION DE LA BCDC [19]

L'Equity BCDC est une Société par Action à Responsabilité Limitée en sigle (SARL), exerçant des activités des établissements de crédits telles que définies par une instruction de la BCC, (Banque Centrale du Congo).

III.2.1 Historique

Le 11 janvier 1909, la Banque du Congo Belge aujourd'hui Banque Commerciale du Congo voit le jour, son capital de 2 millions de francs est entièrement souscrit par les principaux actionnaires suivants : la Banque d'outre-mer, la Compagnie du Congo pour le Commence et l'industrie, la Banque de Paris et des Pays-Bas, FM. Philippson et Cie.

De nouveaux actionnaires font leur entrée à l'actionnariat dès le 27 janvier 1909 à l'occasion de l'augmentation du capital de 1 million des francs. Parmi les nouveaux actionnaires on peut citer la Société Générale de Belgique et la Société Commerciale et Financière.

Dans le même temps, les dirigeants de la Banque du Congo décident d'établir une agence à Matadi, elle entre en activité dès le mois de juin de la même année.

Presque au même moment, la Banque lance ses activités au Katanga pour ouvrir en 1910, une agence à Elisabeth ville (aujourd'hui Lubumbashi)

Le 1er août de la même année, l'agence de Léopoldville (aujourd'hui Kinshasa) ouvre ses guichets.

En juillet 1911, la Banque obtient pour une période de 25 ans le privilège d'émission. Elle le conservera plus de 40 ans. Ce privilège nécessite une modification des statuts de la banque dont le champ d'activités comme Banque Commerciale est de ce fait fortement réduit.

Suivent ensuite l'ouverture des agences de Boma le 1er octobre 1911 et celle de Stanley ville, aujourd'hui Kisangani le 1er janvier 1912

Le 8 septembre 1914 l'ouverture d'un siège à Londres avec pour mission initiale d'assurer avec les puissances alliées, le gouvernement belge et la direction d'Afrique les opérations bancaires.

En 1917, la Banque du Congo Belge décide d'ouvrir 17 agences afin d'assurer partout dans le pays, à la demande du gouvernement de la colonie, les opérations bancaires.

En 1918, la banque du Congo Belge gère un réseau de sièges et d'agences dans 25 localités, une agence est ouverte à Dar-es-Salem.

Entre 1919 et 1928, 11 agences viennent compléter le réseau. Pendant ce temps, la Banque consolide ses assises à Bruxelles, Londres et Anvers où une agence est inaugurée le 27 octobre 1919.

Dès la fin de 1929, le Congo belge est durement atteint par la crise internationale. La Banque du Congo Belge comprime ses frais généraux, ferme 12 agences dont la rentabilité ne pourrait plus être assurée, mais reste grâce à ses réserves l'épine dorsale financière de la colonie.

Au terme de cette crise, les entreprises saines qui avaient su s'adapter retrouvent le dynamisme commercial et leur place au cœur de la concurrence internationale. Dès 1934 les bénéfices de la banque connaissent une progression constante.

En 1960, malgré les troubles qui suivirent l'indépendance, rendant nécessaire la mise en vielleuse temporaire de plusieurs agences, la Banque du Congo met tout en œuvre pour éviter la scission territoriale de ses activités.

En janvier 1964, le réseau d'agence de 1960 retrouve sa pleine activité alors que d'autres banques commerciales avaient fermé l'exploitation de certaines de leurs succursales.

Pendant cette période troublée, la Banque du Congo fut la seule institution financière capable d'assurer la régularité de paiement à l'intérieur du pays.

En 1965, le Conseil d'Administration décide de proposer aux autorités congolaises une prise de participation de la RDC dans le capital de la Banque Commerciale du Congo, proposition accueillie unanimement de manière favorable.

La réforme du 24 juin 1967 constitue un véritable programme de redressement économique. Les principaux objectifs visés dans le programme ont abouti à la création d'une nouvelle unité monétaire appelée « Zaïre » l'équivalent de 1 000 Francs congolaise anciens qui est mises en circulation.

Au 31 décembre 1970, le réseau d'exploitation de la banque du Congo s'appuie sur 27 implantations et compte 1885 personnes.

En octobre 1971 le « Congo » devient « Zaïre » l'assemblée générale du 18 novembre 1971 décide de modifier la dénomination sociale de la Banque du Congo en Banque Commerciale Zaïroise (BCZ).

Le 25 novembre 1975, la Banque Commerciale Zaïroise inaugure son nouveau siège social sur le Boulevard du 30 juin, après 5 ans de travaux, avec fonds propres ; tout en améliorant les conditions de travail de son personnel et offrant de meilleurs services à sa clientèle.

En 1977, la banque compte 32 points d'exploitation et emploie 2 352 personnes.

Dix ans plus tard, la Banque Commerciale Zaïroise emploie 2 952 agents avec une proportion des cadres plu élevée.

Pendant la périlleuse décennie 90, le secteur bancaire est de plus en plus marginalisé par la pénurie de signes monétaires, l'inflation de près de 9 000 % en 1994 illustre l'état d'effondrement progressif de l'économie et des finances du Zaïre. Fin 1995, la BCZ voit le nombre de ses agents ramenés à 1 608.

De 1998 à 1999, jusqu'à fin 2002, la Banque Commerciale du Congo (BCDC), doit faire face à une situation économique de plus en plus dégradée. Pour survivre dans les conditions sociales, politiques et économiques des années 90, la BCDC a dû s'adapter sur le plan organisationnel, fermer des nombreuses agences et réduit de manière drastique ses frais généraux, le nombre d'employés passe ainsi à 279 personne à fin 2011.

Dans le même temps de 19987 à 2008, la BCDC est privée de son réseau situé à l'Est, en zone non contrôlée par le Gouvernement.

Les 5 dernières années lui auront donné raison, de 2002 à 2008, la BCDC a engagé 189 personnes dont une majorité de jeunes cadres et le total du bilan passe de 22 à 193 milliard de FC (franc Congolais) et les fonds propres exprimés en contre-valeur USD, passent de 24,5 millions seulement.

En 2009, 9 agents seulement ont été recrutés compte tenu de la conjoncture économique peu favorable qui a marqué l'exercice 2009, pour de contrôle de performance, de consolidation, en vue d'assurer l'avenir de la banque.

III.2.2 SITUATION GEOGRAPHIQUE

Son siège social est situé sur le boulevard du 30 juin dans la Commune de la Gombe dans la ville de Kinshasa en République Démocratique du Congo.

III.2.3 MISSION ET OBJETIFS

La banque commerciale du Congo a pour objectif principal l'octroi des crédits ou des sommes d'argent déposent chez elle par sa clientèle (particulier et entreprise). Ces dépôts servent a financé les opérations des crédits et celles d'import et export. Les dépôts que la BCDC reçoit sont ceux à vue et à terme qui ne peuvent être supérieurs a deux ans et elles les emplois en opérations de crédit, essentiellement à court et a moyen des grands opérations telles que :

- Les opérations des compensations en monnaie locale,

- Les opérations des compensations en monnaie étrangère,

- Les opérations de validation des licences d'importation et d'exportation.

Elle ne peut détenir dans des entreprise industrielles ou commerciales de participation pour un montant de ses participations ne pouvant de passer 75 pourcent de leurs ressources propres à l'exclusion des dépôts c'est-à-dire de leur capital de leurs réserves. La banque commerciale du Congo a pour activités complémentaire d'exécuter pour le compte de sa clientèle ou de ses clients certains services. Les services accessoires de la banque commerciale du Congo sont suivants :

- Le frais inter agence
- Le paiement salaires agents et fonctionnement de l'état
- La remise des cheques
- La livraison des extraits bancaires aux clients
- Les transactions en opérations diverses. MAD.COMPENSATIONS
- Les relevés mensuels
- La saisie et main levée des oppositions cheque et ordre de virement
- Les renseignements a la clientele
- L'inventaire des comptes
- La surveillance des saisies arrêts et main levée
- La location boites aux lettres
- Les scannages des signatures

III.2.4 STRUCTURE FONCTIONNELLE [19]

A ce jour, la BCDC est structuré de la manière suivante :

- Le Conseil d'Administration
- La Direction Générale

III.2.4.1 Le réseau d'agences d'EQuity BCDC en RDC

01. Région Ouest

- **Le réseau d'agence de Kinshasa**

  - Kinshasa Agence des Aviateur
  - Kinshasa Agence Kintambo
  - Kinshasa Agence Limete Place Commerciale
  - Kinshasa Agence Paix
  - Kinshasa Agence Rond-point Victoire
  - Kinshasa Agence 30 Juin Huilerie
  - Kinshasa Agence Royal
  - Kinshasa Agence Siege
  - Kinshasa Agence Brikin
  - Kinshasa Agence Delvaux

- Kinshasa Agence Limete 7ème Rue
- Kinshasa Agence Masina Sans Fil
- Kinshasa Agence Matadi Kibala
- Kinshasa Agence Matonge
- Kinshasa Agence Mondjiba
- Kinshasa Agence Ngaba
- Kinshasa Agence Poste
- Kinshasa Agence Unikin
- Kinshasa Agence Commerce
- Kinshasa Agence Fleuve congo
- Kinshasa Agence Gambela
- Kinshasa Agence Gare Centrale
- Kinshasa Agence Joli Parc
- Kinshasa Agence Kinkole
- Kinshasa Agence Kin Maziere
- Kinshasa Agence Lukusa
- Kinshasa Agence Macampagne
- Kinshasa Agence Masina Pascal
- Kinshasa Agence Memling
- Kinshasa Agence Monishop
- Kinshasa Agence Oasis
- Kinshasa Agence Pigeon
- Kinshasa Agence Rond-point Huilerie
- Kinshasa Agence Rotana
- Kinshasa Agence Saio
- Kinshasa Agence Mont Ngafula
- Kinshasa Agence Ndjili - dédiée Western Union
- Kinshasa Agence Liberte - dédiée Western Union
- Kinshasa Agence Matete - dédiée Western Union
- Kinshasa Agence Bandal - dédiée Western Union
- Kinshasa Agence Kintambo - dédiée Western Union
- Kinshasa Agence Assossa - dédiée Western Union
- Kinshasa Agence Pascal - dédiée Western Union
- Kinshasa Agence Ozone - dédiée Western Union
- Kinshasa Agence Foire - dédiée Western Union
- Kinshasa Agence Kimbondo - dédiée Western Union
- Kinshasa Agence Kalina - dédiée Western Union
- Kinshasa Agence Kingasani - dédiée Western Union
- Kinshasa Guichet avancé Cilu
- Kinshasa Guichet avancé SN Brussels
- Kinshasa Guichet avancé Snel 1
- Kinshasa Guichet avancé Snel 2
- Kinshasa Guichet avancé Bralima

❖ **Le réseau d'agence de Kongo Centrale**

- Kongo Central Agence Mavungu
- Kongo Central Agence Boma
- Kongo Central Agence Kimpese
- Kongo Central Agence Matadi
- Kongo Central Agence Mbanza Ngungu
- Kongo Central Agence Inga
- Kongo Central Agence Lukala
- Kongo Central Agence Matadi Port
- Kongo Central Agence Matadi Port Sec

02. Région Centre

❖ **Le réseau d'agence de Kasaï (occidentale et orientale)**

- Kasaï-Central Agence Kananga
- Kasaï Agence Tshikapa
- Kasaï-Oriental Agence Mbuji Mayi

03. Région Est

❖ **Le réseau d'agence de Nord Kivu, sud Kivu, Tshopo, Ituri et Haut-Uélé**

- Nord Kivu Agence Beni
- Nord Kivu Agence Butembo
- Nord Kivu Agence Goma
- Nord Kivu Agence Serena
- Sud Kivu Agence Bukavu
- Sud Kivu Agence Lumumba
- Sud Kivu Guichet avancé DGI
- Tshopo Agence Kisangani
- Tshopo Agence Makiso
- Tshopo Guichet avancé DGRPT
- Tshopo Guichet avancé Congo Airways
- Tshopo Guichet avancé Bralima
- Ituri Agence Bunia
- Ituri Guichet avancé DGRPI
- Haut-Uele Agence Durba
- Haut-Uele Agence Isiro
- Haut-Uele Agence Aru
- Haut-Uele Agence Kibali

04. Region Sud

❖ Le réseau d'agence de Lualaba et Haut-Katanga

- Lualaba Agence Kolwezi
- Lualaba Agence Bissipi
- Lualaba Agence Lukala Dilala
- Lualaba Guichet avancé Connex Africa Kolwezi
- Lualaba Guichet avancé Mairie de Kolwezi
- Lualaba Guichet avancé Bralima – Kolwezi
- Lualaba Guichet avancé Mulykap
- Lualaba Guichet avancé Groupe SIL
- Haut-Katanga Agence Likasi
- Haut-Katanga Agence Lubumbashi Centre-ville
- Haut-Katanga Agence Lubumbashi – Katanga
- Haut-Katanga Agence Lakenya
- Haut-Katanga Agence Likasi Centre-ville
- Haut-Katanga Agence Carrefour
- Haut-Katanga Agence Golf
- Haut-Katanga Agence Kambove
- Haut-Katanga Agence Kasumbalesa
- Haut-Katanga Agence Manika
- Haut-Katanga Agence Plage
- Haut-Katanga Agence Révolution
- Haut-Katanga Agence Kicc
- Haut-Katanga Guichet avancé Congo Airways1
- Haut-Katanga Guichet avancé Congo Airways 2
- Haut-Katanga Guichet avancé Connex Africa
- Haut-Katanga Guichet avancé Congo Équipement
- Haut-Katanga Guichet avancé Brassimba 1
- Haut-Katanga Guichet avancé Brassimba 2
- Haut-Katanga Guichet avancé Bralima – Lubumbashi
- Haut-Katanga Guich. Av. Centre des Visas Afrique du Sud
- Haut-Katanga Guichet avancé ISP Lubumbashi
- Haut-Katanga Guichet avancé ISES
- Haut-Katanga Guichet avancé Institut Salama
- Haut-Katanga Guichet avancé ISC Lubumbashi
- Haut-Katanga Guichet avancé Université de Lubumbashi
- Haut-Katanga Guichet avancé ISTL
- Haut-Katanga Guichet avancé C.S. Bisounours
- Haut-Katanga Guichet avancé C.S. Galaxis

III.2.5 ORGANIGRAMME

La figure 3.1. Ci-dessous illustre Organigramme de l'Equity BCDC

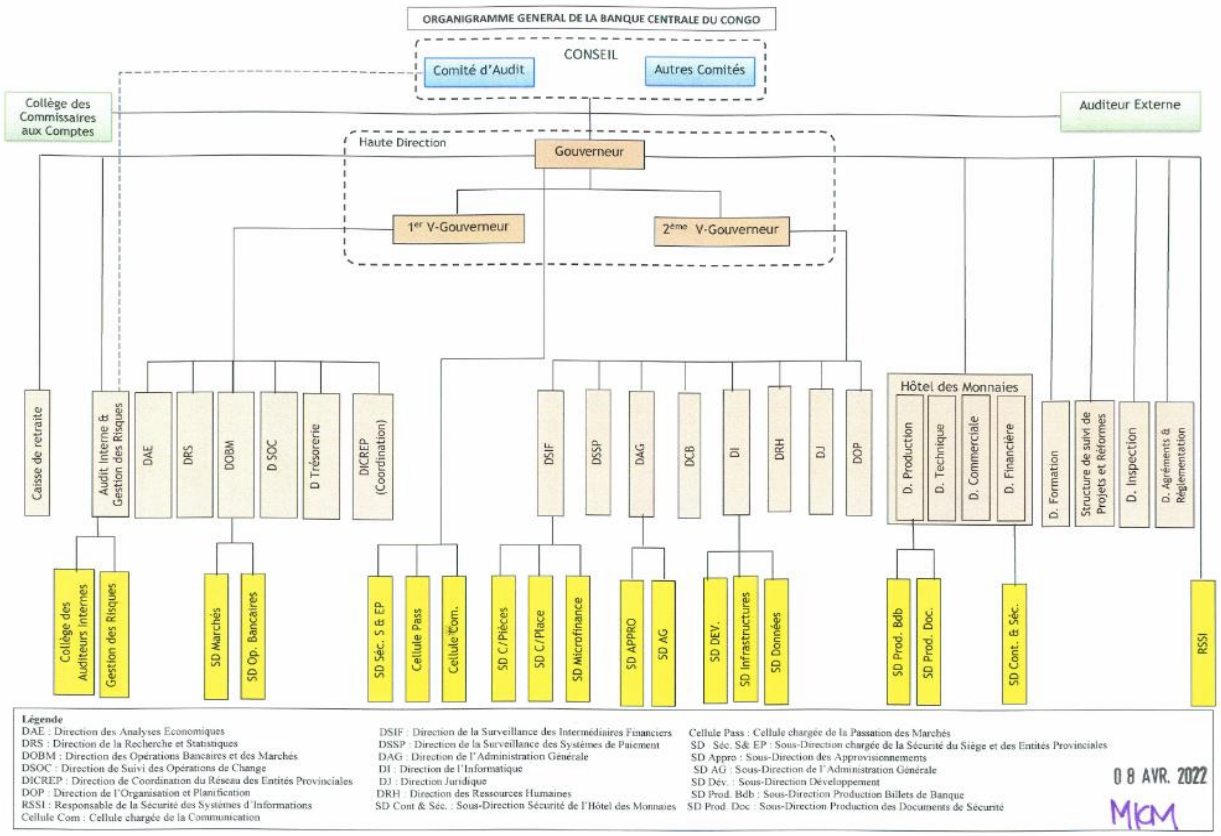

Figure 3.1: ***Organigramme de l'Equity BCDC***

III.2.6 ETUDE DE L'EXISTANT [19]

Banque commerciale du Congo comprend les ressources matérielles et logicielles suivantes :

III.2.6.1 Réseaux Informatiques et Interconnexion

La croissance des systèmes informatique, l'acquisition des applications fiables de transmission de données, la gestion des multiservices et le partage de ressources s'avèrent indispensables pour une entreprise en vue d'optimiser la qualité de ses services. soucieuse de répondre à ces exigences, la BCDC a mis sur pied un réseau

d'entreprise étendue (WAN) afin d'assurer le traitement, l'échange et partage de ses ressources ; et pour ce qui est de l'interopérabilité entre son siège principal avec toutes ses représentations sur l'étendue du pays et a l'étranger, elle se fait aux moyen des liens VSAT afin de garantir à ses utilisateurs l'accès sécurisé, le partage et échange de ressources ainsi que le traçabilité de fond, moyens matériels et logistiques leurs alloues.

III.2.6.2 Type de Matériels

Pour le déploiement de son architecture réseau, le Banque commerciale du Congo à disposer des matériels énumérés ci-dessous :

- Antennes VSAT avec Modem
- Switch fédérateur (switch cisco CATALYST 4506)
- Firewall et Routeur
- Switch Cisco Catalyst (2900)
- Fibre optique câblage UTP et STP.
- Des ordinateurs clients, serveurs en fonction sur le réseau actuellement
- Serveur de vidéoconférence
- Vidéo phones IP
- Téléphones IP Cisco

III.2.6.3 Protocole cœur

Comme protocole cœur, l'Equity BCDC utilise le PBB-TE (Provider Backbone Bridge-Trafic Engineering) afin de rendre plus fiable, extensible et déterministe son réseau de grande dimension.

III.2.6.4 Protocoles d'accès

L'Equity BCDC utilise la technologie NAP (Network Access Protection) qui permet de contrôler l'accès hôte à partir de la conformité du système hôte en question.

III.2.6.5 Topologie

L'architecture réseau de l'Equity BCDC utilise une topologie étoilée qui relie le point central qui est son siège, aux directions provinciaux et centre hospitalier.

III.2.6.6 Architecture

La figure 3.2. Ci-dessous illustre Architecture du Rx de l'Equity BCDC

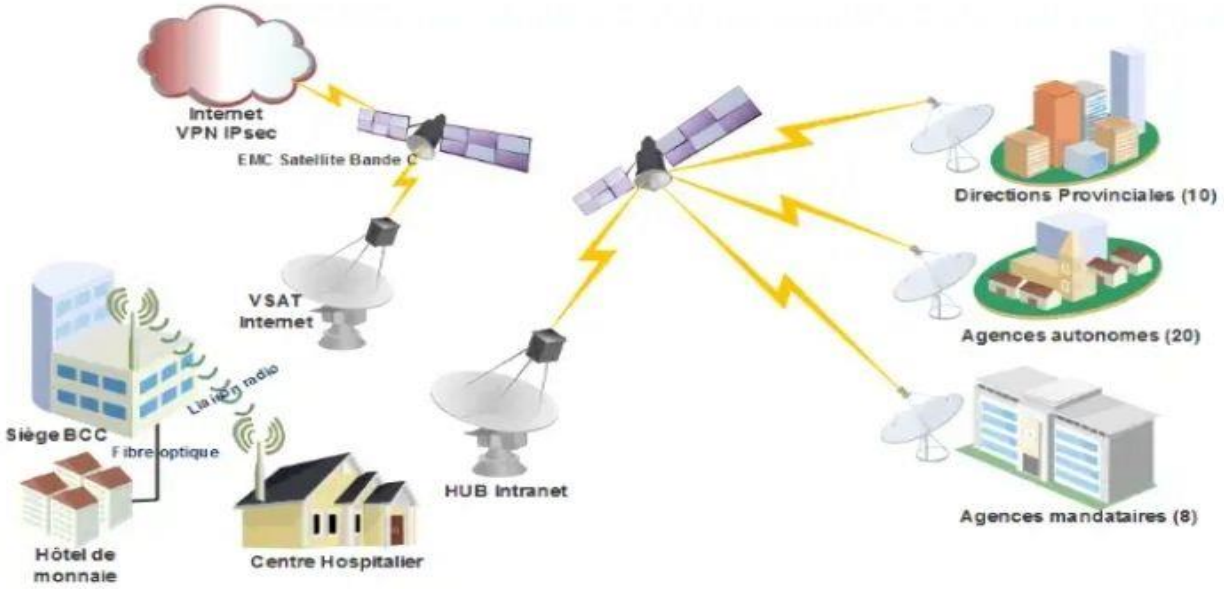

Figure 3.2: ***Architecture de l'Equity BCDC***

III.2.6.7 Le Backbone de la Banque

La Banque commerciale utilise les protocoles de routage dynamique intra-domaine OSPF afin d'acheminer paisiblement les informations au sein de son système et BGP pour l'échange d'informations entre les différents sites. Il s'appuie sur la qualité et les performances du média de communication toute en employant une base de données distribuées permettant de garder en mémoire l'état des liaisons. En outre, elle présente aussi quelques failles contraignantes d'une part, par la complexité de sa configuration au cas où il est segmenté en aires, et de l'autre, il est sensible au phénomène de bagottèrent ou flapping.

La figure 3.3. Ci-dessous illustre Architecture backbone de l'Equity BCDC

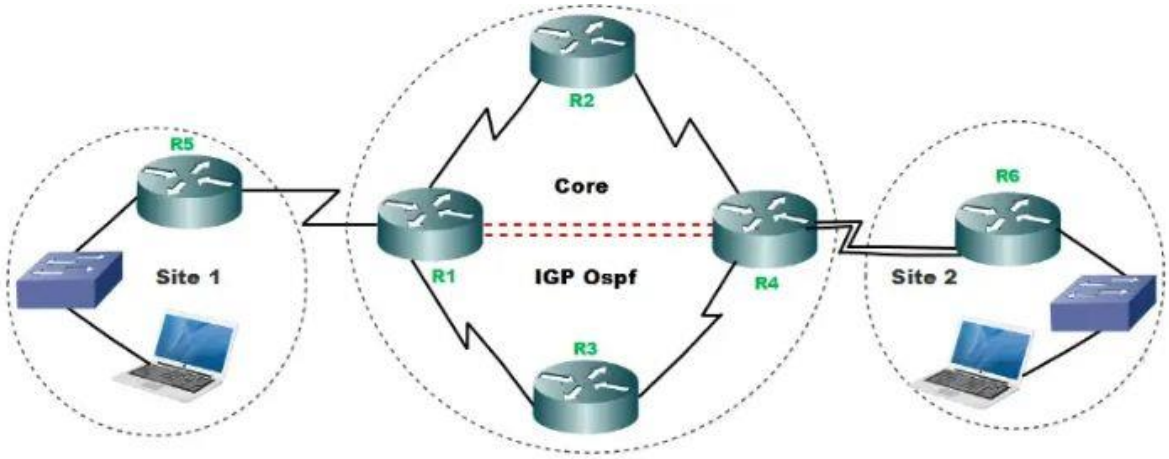

Figure 3.3: ***Architecture Backbone de l'Equity BCDC***

III.2.6.8 Mécanismes de sécurité

Les mécanismes de sécurité s'avèrent indispensables pour toute entreprise de manière globale et bancaire de manière particulière, car la sauvegarde des informations vitales, la restriction des actes malveillants aux ressources matérielles ou logicielles et la perte des infrastructures déployées dans une entreprise demeure une préoccupation majeure. Au vue de ce qui précède, la Banque commerciale a mis sur pied une politique de sécurité physique et logicielle afin de sécuriser au maximum ses infrastructures réseaux et maintenir ainsi, la qualité de service en son sein.

- **La politique de sécurité physique**

Elle consiste essentiellement à se protéger contre les vols, fuites d'eau, incendies, coupures d'électricité, etc… Les règles génériques à considérer sont les suivantes :

- Une salle contenant des équipements réseau ne doit pas être vue de l'extérieur afin de ne pas attirer ou susciter des idées de vol ou de vandalisme.
- Des périmètres de sécurité physique a accès restreint doivent être définis, et équipés de caméras de surveillances ;
- Des procédures doivent autoriser et révoquer l'accès aux périmètres de sécurité ;
- Des équipements de protections contre le feu, l'eau, l'humidité, les pannes de courant, le survoltage, etc… doivent être installés.
- Des procédures de supervision des éléments de protection doivent être mises en place.
- Les ressources critiques doivent être placées dans le périmètre le plus sécurisé.

- La politique de sécurité administrative et logique

III.2.6.8.1 Les contrôles d'accès constitués de filtrages de paquets (pare-feu) et de relais applicatifs (proxy)

Est l'un de mécanisme de sécurité appliqué à la banque commerciale du Congo afin d'autoriser un certain nombre de flux réseau sortants (http, FTP, SMTP, etc…) appliqués à l'ensemble du réseau interne ou à certaines adresses. Elles interdisent tout trafic non autorisé vers le réseau interne. Les contrôles d'accès s'accompagnent d'une politique définissant les règles suivantes à respecter :
° Obligation est faite d'installer et de mettre à jour le logiciel antivirus choisi par l'entreprise.
° Interdiction d'utiliser tout outil permettant d'obtenir des informations sur un autre système de l'entreprise.
° Concernant les communications entre le réseau de l'entreprise et un autre réseau, une politique spécifique de contrôle d'accès précise les points suivants :
Définition des services réseau accessibles sur internet.
° Définition des contrôles associés aux flux autorisés à transiter par le périmètre de sécurité pour vérifier, par exemple, que les flux SMTP, http et FTP ne véhiculent pas de virus. Ces contrôles peuvent aussi concerner des solutions de filtrage d'URL pour empêcher les employés de visiter des sites non autorisés par l'entreprise, réprimés par la loi, ou simplement choquants (pédophiles, pornographiques, de distribution de logiciels ou de de morceaux de music piratés, etc…).
° Définition des mécanismes de surveillance qui doivent être appliqué au périmètre de sécurité. Ces mécanismes concernant la collecte et le stockage des traces (logs), les solutions d'analyse d'attaque, comme les sondes d'intrusion, ou IDS (Intrusion Détection System), et les solutions d'analyse de trafic ou de prévention d'intrusion IPS (Intrusion préventions System).

III.2.6.8.2 Les contrôles d'authentification des utilisateurs

S'effectuent à plusieurs passages, au niveau de la sortie Internet, où chaque utilisateur doit s'authentifier pour avoir accès à Internet, mais aussi au niveau de chaque serveur pour accéder au réseau interne (serveurs de fichiers, serveurs d'impression, etc.).

Chaque fois qu'un utilisateur s'authentifie, un ticket est créé sur un système chargé de stocker les traces (logs) afin que le parcours de l'utilisateur soit connu à tout moment de manière précise.

Cette logique peut être généralisée et entraîne la création d'une trace pour chaque action de l'utilisateur sur chaque serveur (création, consultation, modification, destruction de fichier, impression de document, URL visitée par l'utilisateur, etc.).

III.2.6.8.3 Le mécanisme de Contrôle de l'accès au réseau

Il permet de vérifier un certain nombre de points de sécurité avant d'autoriser un système à se connecter au réseau local. L'objectif est ainsi de contrôler les accès au plus près de leurs sources.

Dans ce stade, le système qui désire se connecter et le commutateur (ou le routeur) attaché au LAN doivent intégrer la fonctionnalité NAC. Du point de vue de la sécurité, il est toujours recommandé de choisir la fonctionnalité NAC intégrée dans un commutateur mettant en œuvre les mécanismes de sécurité de VLAN (Virtual Local Area Network), de contrôle des adresses MAC (Media Access Control), etc., qui sont moins permissifs que ceux d'un routeur, qui ne voit passer que des trames IP.

Avant de se connecter au réseau, un dialogue s'établit entre le système et le commutateur (ou routeur) d'accès au réseau. Le commutateur (ou routeur) communique alors avec un serveur de politiques de sécurité pour valider ou refuser la demande d'accès du système au réseau. Et au cas où l'un de ces contrôles n'est pas validé, le système n'est pas autorisé à se connecter au réseau.

III.2.6.8.4 Réseau virtuel privé de l'Equity BCDC

La Banque Commerciale du Congo dispose bel et bien d'une infrastructure réseau mais l'utilise uniquement pour interpeler avec l'Interpol (Organisation Internationale de Police Criminelle) pour prévenir tout acte criminel pouvant être entrepris en son sein. Partant par l'identification, la localisation des individus recherchés sur la base de n'importe quel contrôle pour des fins d'extractions.

III.2.6.8.4.1 Architecture VPN de la BCDC

L'architecture VPN de l'Equity BCDC est celle d'un VPN Extranet le reliant à l'Interpol qui est un des partenaires stratégiques de la Banque par le moyen de l'Internet Public comme l'illustre la figure ci-dessous :

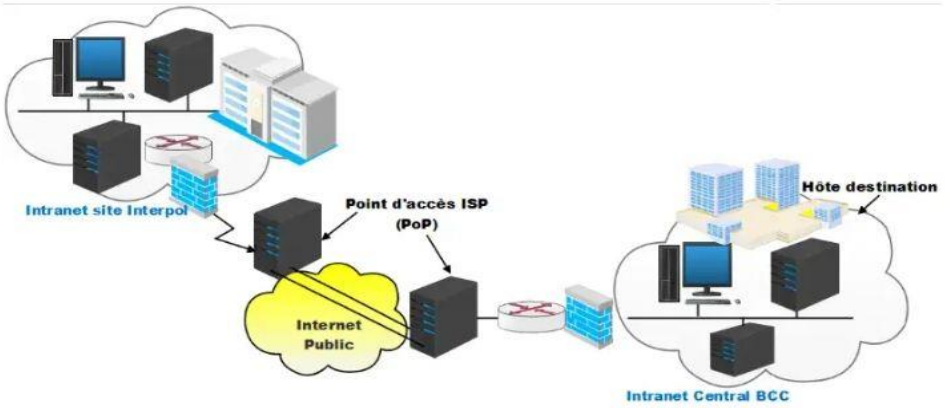

Figure 3.4: Architecture VPN de l'Equity BCDC [25]

III.2.6.8.4.2 Topologie VPN

Le VPN de l'Equity BCDC utilise une topologie étoilée dont la caractéristique fondamentale est l'existence d'un point central qui se comporte comme un hub concentrateur du trafic réseau et dans le cas qui nous concerne, c'est le réseau Internet Public.

III.2.6.8.4.3 Protocole VPN

Au niveau protocolaire, le réseau privé virtuel de l'Equity BCDC utilise principale le protocole IP sec (Internet Protocol Security) afin de sécuriser les communications par Internet sur un réseau IP par le moyen d'un tunnel déployé pour permettre à l'Interpol d'accéder à son intranet. Il sécurise de même le protocole communication Internet et vérifie chaque session avec un cryptage individuel des paquets de données pendant toute la connexion.

III.2.7 CRITIQUE DE L'EXISTANT

La critique du système existant constitue une phase très contraignante pour tout travail scientifique. Elle recherche de manière objective à exhiber les performances et les failles qui handicapent le bon déroulement et fonctionnement des processus d'un système en vue de proposer un autre plus fiable et rationnel que le système existant.

III.2.7.1 Critique sur les moyens humains

Les ressources humaines étant au cœur de tout système, elles nécessitent qu'elles soient de hautes factures pour une entreprise généralement et en particulier sur celle axée dans le domaine bancaire d'envergure nationale. A cet effet, le service de réseau de l'Equity BCDC dispose bel et bien d'un personnel qualifié, laborieux, expérimenté et ingénieux à la hauteur des missions lui conférées.

Cependant, cette entité devra être restructurée au vue de la couverture du réseau, les équipements réseaux déployés en son siège principal et dans toutes les succursales, nécessitant parfois des déplacements physiques des agents commis à ce service dans les différents coins du pays. Ainsi, compte tenu de la multitude des matériels, d'utilisateurs et la couverture réseau mise à leur disposition, les contraintes précitées sont plausibles de porter préjudice au bon fonctionnement de l'entreprise.

III.2.7.2 Critique sur les moyens matériels

Les moyens m atériels sont indispensables pour toute entreprise qui désire utiliser les nouvelles technologies de l'information et de la télécommunication de manière générale et de manière particulière les technologies de réseau. Ainsi, l'Equity BCDC utilise principalement les matériels réseaux CISCO et Microsoft. Concernant l'état de matériels, ceux déployés en son siège sont en bon état dans l'ensemble, mais ceux des directions provinciales sont dans un état préoccupant en raison des moyens logistiques, de maintenabilité permanente et quelques contraintes qui s'imposent pendant la migration des systèmes existants vers d'autres.

III.2.8 PROPOSITIONS DE SOLUTION ET RECOMMANDATION

Nous présentons premièrement quelques propositions de solution pouvant servir comme cahier de charge aux décideurs afin qu'ils participent à l'évolution technologique et architecturale de l'entreprise et ensuite nous formulerons quelques recommandations.

III.2.8.1 Proposition de solution

L'entreprise étant un système complexe dans lequel transitent de très nombreux flux d'information, sans un dispositif de maîtrise de ces flux, elle peut très vite être dépassée et ne plus fonctionner avec une qualité de service satisfaisante. De ce fait, pour apporter la lumière aux anomalies du système existant, nous pouvons proposer quelques solutions nécessaires, dans le but d'améliorer la performance de la sécurité au sein du système d'informatique de l'Equity BCDC.

III.2.8.2 Préparations pour l'évolution du Système Informatique

Pour préparer une bonne évolution au sein du système informatique, nous allons utiliser plusieurs techniques et approche pour déployer cette solution qui regorge l'Ids et l'Ips en s'appuyant dans le système hybride.

III.2.8.3 Déploiement de l'outil dans le réseau

Le déploiement d'une solution hybride combinant un IDS et un IPS offre une solution complète de la sécurité réseau. L'IDS permet de surveiller activement le trafic pour détecter les menaces potentielles, tandis que l'IPS intervient pour bloquer ou contrer ces menaces en temps réel. Cette combinaison permet de renforcer la sécurité du réseau en détectant les attaques et en prenant des mesures proactives pour les empêcher de réussir. En utilisant une approche hybride, les entreprises peuvent bénéficier à la fois de la détection avancée des menaces et d'une protections active contre les attaques, ce qui contribue à renforcer la résilience de leur infrastructure informatique.

III.2.8.4 Le Recommandation

Notre recommandation s'articule en deux volets. Le premier s'adresse principalement aux décideurs de la Banque commerciale du Congo et le second au manager en charge du service de réseau et télécommunication de ladite entreprise.

Aux décideurs de la Banque commerciale du Congo, nous leur recommandons de mettre leurs expertises en place afin d'amorcer le processus de recrutement des nouveaux ingénieurs et experts en la matière, non seulement pour accroitre la main d'œuvre au sein dudit service, mais également la qualité de service de l'entreprise. Cependant, nous les exhortons en plus de disponibiliser les moyens financiers et logistiques pour que ces ingénieurs et experts participent à des formations et ateliers pertinents afin d'étudier profondément les propositions leur suggérées et conduisent à bon escient la migration vers un cœur de réseau plus dynamique.

Au responsable dudit service, nous lui recommandons de mettre sur pied une structure engineering et de planification des réseaux. Celle-ci devra être composées des experts aguerris dans leurs spécialités respectives et permettre ainsi aux planificateurs des réseaux de dimensionner les capacités, les nœuds et des liens existants pour la prise des décisions judicieuses sur les caractéristiques des nouveaux équipements réseaux à acheter. Ils assureront également la prévention du trafic qui consiste à identifier les caractéristiques du trafic et le besoin en bande passante des différentes applications qui devront être supportées par les réseaux multiservices. Il s'agit d'estimer le trafic de départ et d'arrivée pour chaque catégorie d'abonnés et les indicateurs clés pour la performance (KPI) devraient à cet effet, être le centre d'intérêt des études engineering que devra effectuer cette structure, car ce sont des paramètres clé qu'un administrateur ou gestionnaire du trafic utilise pour prévenir à une éventuelle extension du système ou dimensionner composants du réseau.

CHAPITRE IV. DEPLOIEMENT DE L'OUTIL DANS LE RESEAU

IV.1 INTROUCTION

Plusieurs technique et approche ont été utilisés pour la mise en place de cette solution qui regorge l'IDS et IPS, nous pouvons citer par exemple honeypot (en français, au sens propre « pot de miel », et au sens figuré « leurre ») est une méthode de défense active qui consiste à attirer, sur des ressources (serveur, programme, service), des adversaires déclarés ou potentiels afin de les identifier et éventuellement de les neutralise, elle est associé avec l'approche par signature et d'anomalie.

Le Figure ci-dessous Illustre le scenario de l'architecture

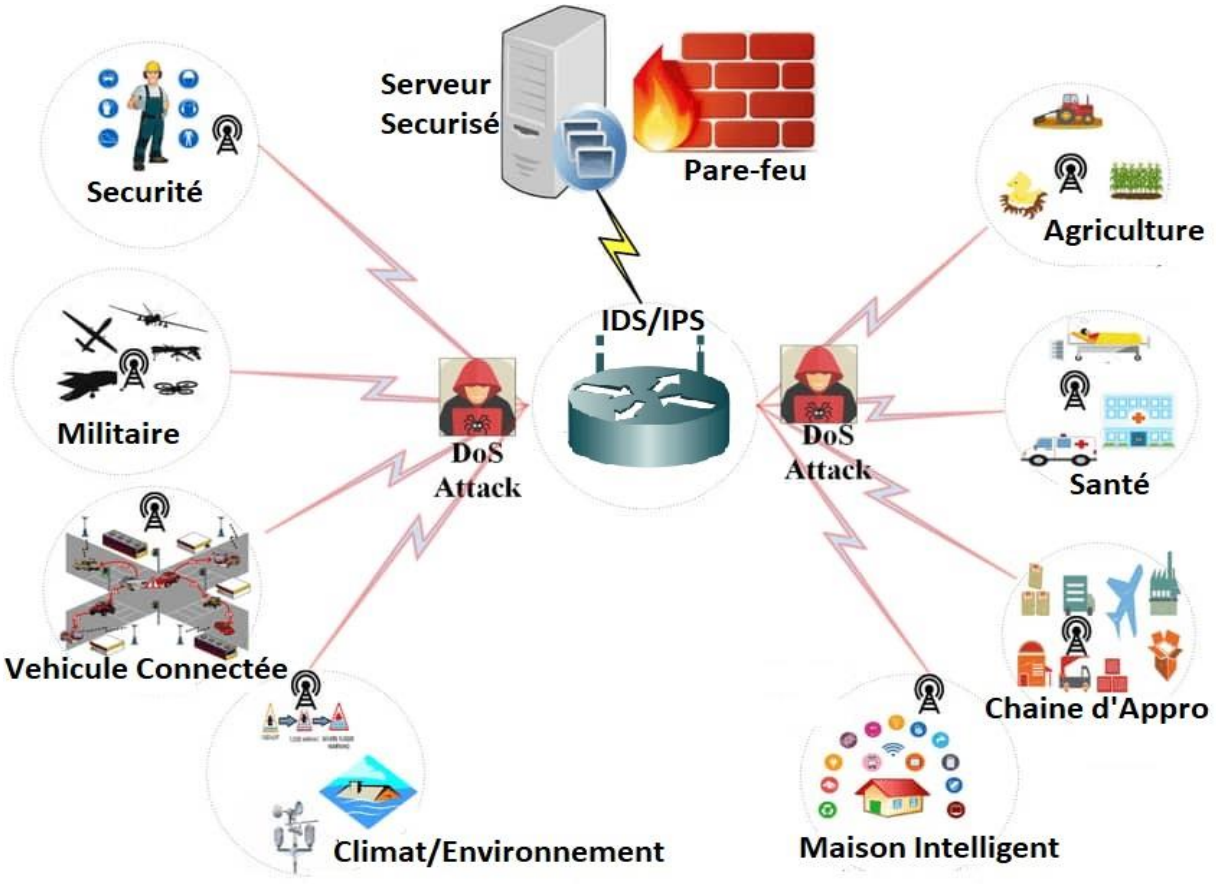

Figure 4. 1: Illustration du scénario

IV.2 ARCHITECTURE PROPOSER POUR L'ENTREPRISE

L'architecture réseau décrit est conçue pour garantir la sécurité, la fiabilité et les performances des communications au sein de l'entreprise. En combinant des éléments essentiels tels que WAN, les pare-feu, les switches, les serveurs et les outils de surveillance, cette architecture vise à créer un environnement informatique robuste et efficace.

Dans cette configuration réseau décrite, le réseau WAN (Wide Area Network) est connecté au routeur de distribution ISP, qui distribue la connexion Internet vers le pare-feu 1. Le pare-feu 1 assure la sécurité en contrôlant le trafic entrant et sortant du réseau. Ensuite, le trafic passe par un switch de liaison pour atteindre les différents PC du réseau. Ce switch permet de connecter et de gérer la communication entre les périphériques du réseau local.
Le trafic continue son chemin en passant par un switch de distribution, qui relie les différents segments du réseau et distribue le trafic de manière efficace. Le trafic est ensuite dirigé vers le pare-feu 2, qui renforce la sécurité du réseau en filtrant le trafic. Le trafic arrive ensuite au serveur, qui fournit des services ou des ressources aux autres appareils du réseau. Le serveur peut être utilisé pour héberger des applications, stocker des données ou exécuter des tâches spécifiques.

Le Dpiker monitor est un outil de surveillance du trafic réseau qui permet de détecter les pics de trafic ou les anomalies sur le réseau. Il est utilisé pour surveiller et analyser le trafic réseau afin d'optimiser les performances et la sécurité du réseau.

Enfin, la zone DMZ (Demilitarized Zone) est une zone intermédiaire entre le réseau interne et externe où les serveurs accessibles au public sont placés. Cette zone permet de limiter l'accès direct aux ressources internes sensibles et d'isoler les serveurs publics pour renforcer la sécurité du réseau.

Sachant que cette architecture réseau met en place plusieurs éléments de sécurité (pare-feu) et des zones distinctes (DMZ) pour protéger les ressources sensibles du réseau et assurer une communication efficace entre les différents appareils du réseau.

Le Figure ci-dessous Illustre l'architecture proposé à l'entreprise

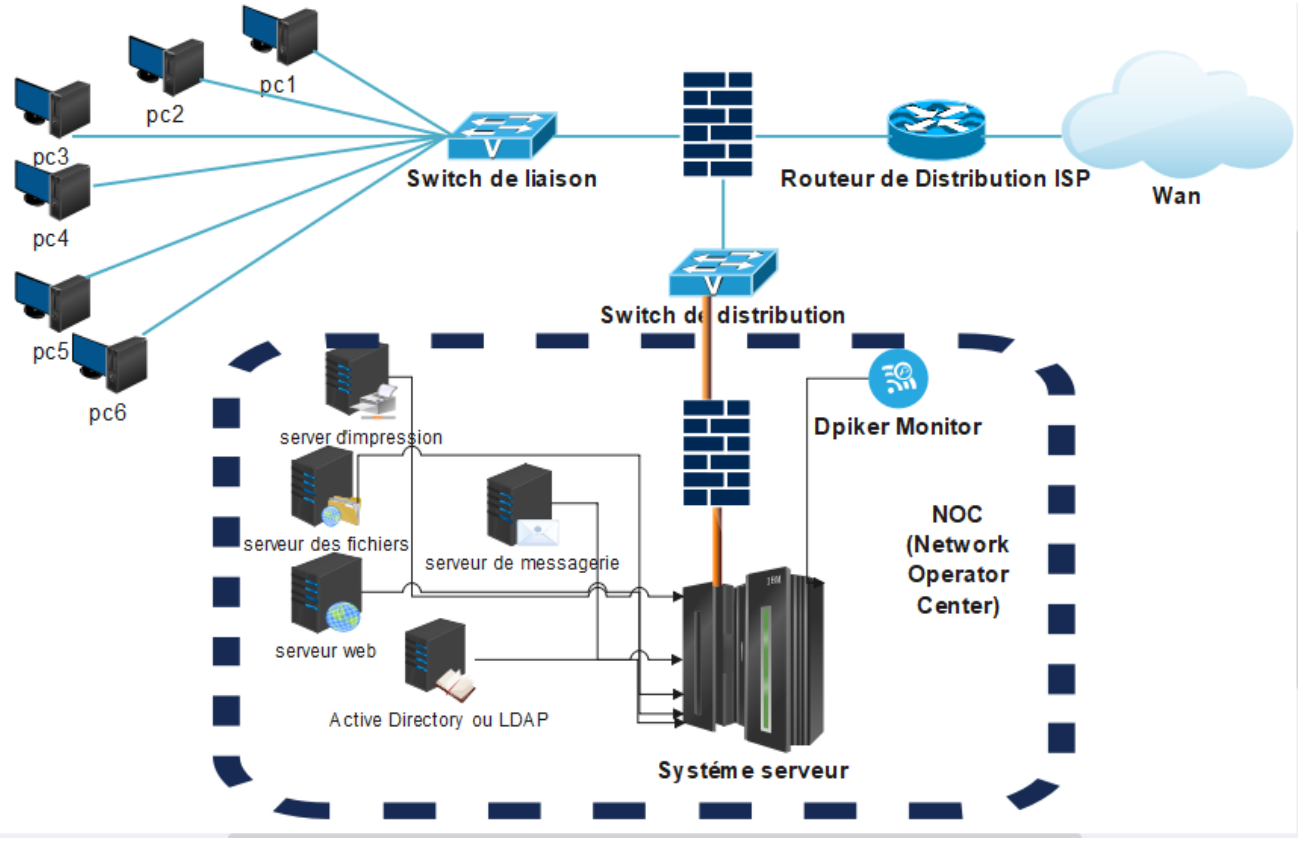

Figure 4. 2: Architecture proposé à l'entreprise

IV.3 SCHEMA LOGIQUE

Ce schéma décrit la manière dont l'application fonctionne, sachant que les IDS/IPS exploite deux méthodes ; méthode par approche comportemental (Apprentissage automatique). Tout en agissant avec les principes des règles. Dans le cadre notre travaille nous avons jugé mieux mettre en place un correctif qui fait appel à l'approche comportemental et approche par signature ; parce qu'elle va permettre à l'administrateur d'observer les moyens de compromission des attaquants, de se prémunir contre de nouvelles attaques et lui laisser ainsi plus de temps pour réagir. Sur le schéma ci-dessous nous avons User(Utilisateur) qui déclenche le requête ou le trap session; il envoie le requête au service dont il s'agit (Web service); cette zone est considérer comme DMZ et l'application envoie les logs d'entrée au moteur de Scannage(Application Scan) qui représente notre Sonde; celui-ci va envoyer les données d'authentification au module de base(Authentification Lib Module) qui va vérifier les informations d'entrer au système s'il s'agit d'un comportement ou un scénario normale ça va passer au cas contraire il envoie un message d'alerte et de détection au résultat qui va afficher les informations de l'attaquant tout en posant une restriction réseau.

Le Figure ci-dessous Illustre le Schéma logique

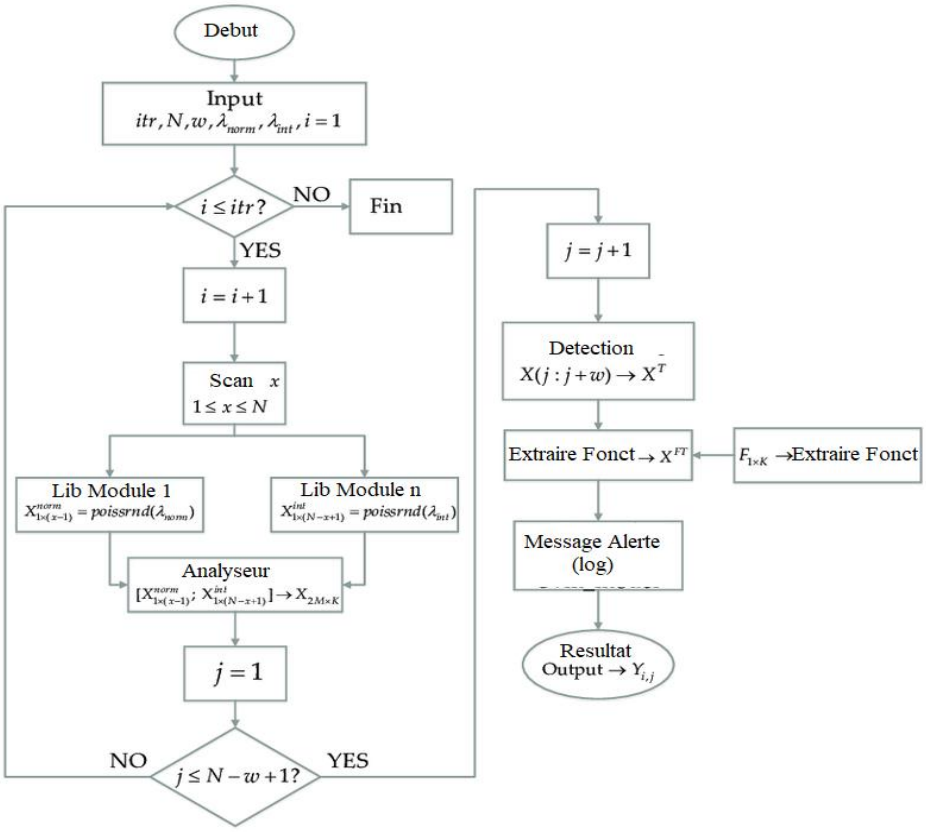

Figure 4.3: Schéma logique

IV.4 ATTAQUES TYPIQUES ET EFFET CONCOMITTANT

Le Figure Ci-dessous illustre schéma attaques typique

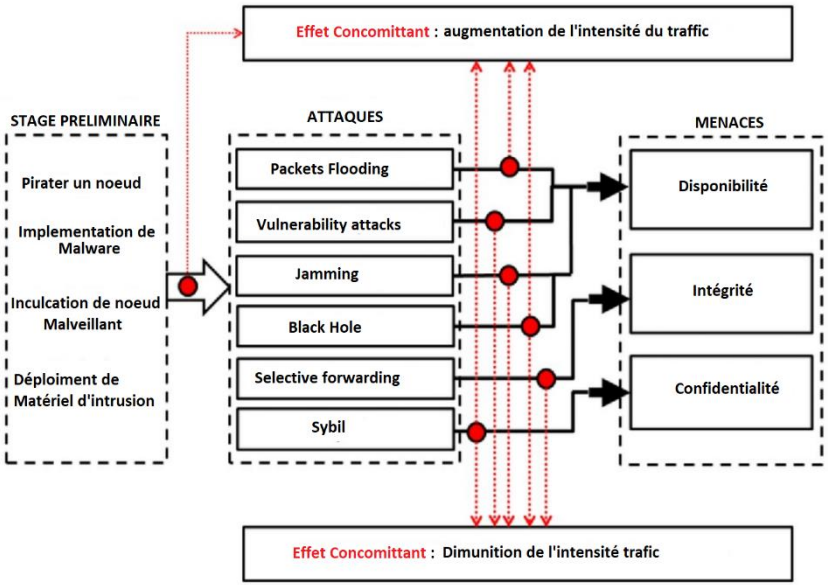

Figure 4.4: Schéma d'attaque typique

IV.5 PRINCIPE DE FONCTIONNEMENT

Le but de cette solution est de faire la détection par anomalies (détecter les écarts par rapport à un modèle représentant les bons comportements) grâce à l'approche comportemental). Qu'il peut prendre le contrôle d'une véritable machine de production, ce qui va permettre à l'administrateur d'observer les moyens de compromission des attaquants, de se prémunir contre de nouvelles attaques et lui laisser ainsi plus de temps pour réagir. Une utilisation correcte d'un IDS/IPS repose essentiellement sur la résolution et la mise en parallèle de trois problématiques :

- La surveillance ;
- La collecte d'information ;
- L'analyse d'information.
- Détection de l'attaque

On compte deux types de pots de miel qui ont des buts et des fonctionnalités bien distincts :

- L'ids/ips à faible interaction ;
- L'ids/ips à forte interaction.

Dans le cadre de notre travail nous avons déployé un outil honeypot sous kali linux et cet outil est compatible pour être utiliser dans Windows server qui son environnement à présent intègre le noyau linux

Figure ci-dessous illustre Menu de script avec les différents outils

```
Fichier  Actions  Éditer  Vue  Aide
┌──(kerene㉿kali)-[~/Bureau/dpi-Ker]
└─$ ./dpi-ker.rb

dpi-ker 1.0
                                        .::!!!!!!!:.
  .!!!!!:.                          .:!!!!!!!!!!!!!
  ~~~~!!!!!!.                   .:!!!!!!!!!UWWW$$$
      :$$NWX!!:              .:!!!!!!XUWW$$$$$$$$$P
      $$$$$##WX!:       .<!!!!UW$$$$   $$$$$$$$#
      $$$$$  $$$UX    :!!UW$$$$$$$$$   4$$$$$*
      ^$$$B  $$$$       $$$$$$$$$$$$   d$$R*
        **$bd$$$$       '*$$$$$$$$$$$o+#
              ****            *******

———————— Menu by KERENE            ruby2.7.4 @ x86_64-linux-gnu

1- Outils Cryptographie

2- Outils Reséaux

3- Web

4- Ip grabber

5- Geolocalisation ip

6- Mass attack

7- License & contact

8- Retour
```

Figure 4.5: Menu de script avec les différents outils

Figure ci-dessous illustre Mise à l'écoute automatique de port

```
   → 2

1- Net DoS Tester
2- TCP port scanner
3- DPI_ker
4- Fuzzer
5- DNS and host gathering
6- MAC address geolocalisation (samy.pl)

0- Retour

   → 2

// TCP port scanner //

Insérez l'hôte à numériser.
Port ouvert
   → 192.168.1.1

[*] Pinging ... /home/kerene/Bureau/dpi-Ker/tools/network/port_scanner.rb:46:
ead.
ok

[*] Scannage ...

 PORT OUVERT

  → 53

  → 80
```

Figure 4.6: Mise à l'écoute automatique de port

Figure ci-dessous illustre Lancement de Dpiker, l'outil de prévention et Détection

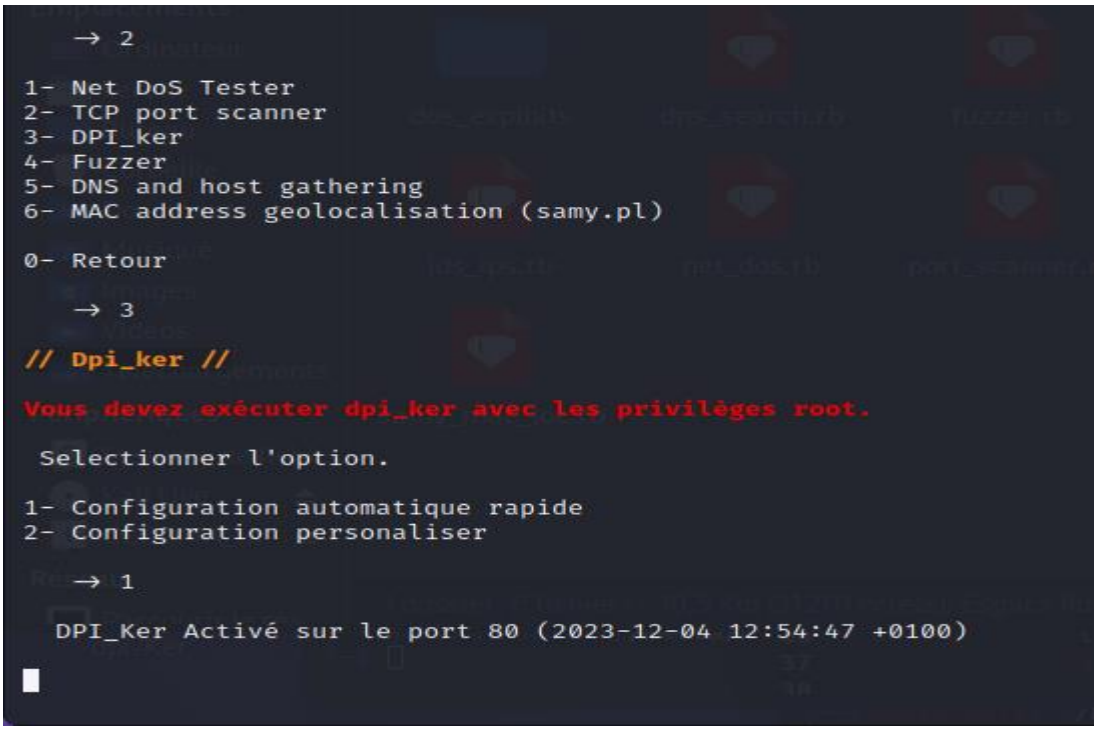

Figure 4.7: Lancement de Dpiker, l'outil de prévention et Détection

Figure ci-dessous illustre Alerte sur la tentative d'intrusion

IP de l'attaquant : 192.168.243.1
IP de la machine Hôte : 192.168.243.131

```
kerene@kali: ~/Bureau/dpi-Ker
Fichier  Actions  Éditer  Vue  Aide
1- Configuration automatique rapide
2- Configuration personaliser
   → 1

  DPI_Ker Activé sur le port 80 (2023-12-04 12:54:47 +0100)

  INTRUSION ATTEMPT DETECTED! from 192.168.243.1:58559 (2023-12-04 12:59:05 +0100)
  ____________________________
GET / HTTP/1.1
Host: 192.168.243.131
Connection: keep-alive
Upgrade-Insecure-Requests: 1
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/119.0.0.0 Safari/537.36
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=
0.7
Accept-Encoding: gzip, deflate
Accept-Language: fr-FR,fr;q=0.9,en-US;q=0.8,en;q=0.7


  INTRUSION ATTEMPT DETECTED! from 192.168.243.1:58560 (2023-12-04 12:59:08 +0100)
  ____________________________
GET /favicon.ico HTTP/1.1
Host: 192.168.243.131
Connection: keep-alive
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/119.0.0.0 Safari/537.36
Accept: image/avif,image/webp,image/apng,image/svg+xml,image/*,*/*;q=0.8
Referer: http://192.168.243.131/
Accept-Encoding: gzip, deflate
Accept-Language: fr-FR,fr;q=0.9,en-US;q=0.8,en;q=0.7
```

Access denied

2023-12-04 12:54:47 +0100

Figure 4.8 : Alerte sur la tentative d'intrusion

IV.6 CODE SOURCE

```
#!/usr/bin/env ruby

=begin

    Copyright (C) 2023

  Author:by KER

    dpi-ker (detection & prevention d'intrusion)

=end

############################
##   BASIC CONFIGURATION   ##
############################
```

```
# THIS DOESN'T WORK BY THE MOMENT. TODO
#
# Default -> false
$pb_log_enabled = false
$pb_log_file = File.dirname(__FILE__) + "/other/log/dpi-ker_log_" + ENV['USER'] +
".log"

# La variable $protected_mode définit si le mode protégé est activé ou non.
#
# Le mode protégé vous protège contre les "script kiddies" et les "lammers". Ils
# ne peut pas exécuter de modules dangereux sans les privilèges root.
#
# Recommandé pour les ordinateurs publics !!
#
# Default -> true
$protected_mode = true

# Variable $text_color.
# Lorsque c'est vrai, les titres et les avertissements seront colorés,
# sinon ce sera avec les couleurs par défaut.

# Default -> true
$text_color = true

###########################

##### Loading time
dir = File.dirname(__FILE__)
require dir + "/lib/pb_proced_lib.rb" # Common procedures and functions.

version = "1.0"
Signal.trap("INT") do
    puts ""
    puts "[*] EXITING ..."
    puts ""
    pb_write_log("exiting", "Core")
    exit
end
#####

pb_write_log("dpi_ker loaded", "Core")

srand(Time.now.to_i)
banner = rand(2)

puts ""
title " dpi-ker #{version} "
```

```
# Thanks to Cowsay for the ASCII Art ;-)
case banner
    when 0
        puts "                                        .::!!!!!!!:. "
        puts "  .!!!!!:.                          .:!!!!!!!!!!!! "
        puts "  ~~~~~!!!!!.                       .:!!!!!!!!!UWWW$$$ "
        puts "      :$$NWX!!:                 .:!!!!!!XUWW$$$$$$$$$P "
        puts "      $$$$$##WX!:            .<!!!!UW$$$$    $$$$$$$$# "
        puts "      $$$$$   $$$UX      :!!UW$$$$$$$$$    4$$$$$* "
        puts "       ^$$$B   $$$$         $$$$$$$$$$$$    d$$R* "
        puts "         **$bd$$$$         '*$$$$$$$$$$$o+#   "
        puts "              ****             ******* "


    when 1
        # This banner is thanks to figlet.
        puts "    ____            _____   "
        puts "   |  _ \\ ___ _ _|_   _| "
        puts "   | |_) / _ \\ '_ \\| |   "
        puts "   |  __/  __/ | | | |   "
        puts "   |_|   \\___|_| |_|_| | "
end

sleep(0.25)
option1 = ""

while option1 != "5"
    module_exec = true
    puts ""
      puts "--------- Menu by KER " + " "*10 + "ruby#{RUBY_VERSION} @
#{RUBY_PLATFORM}"
    puts ""
    puts "1- Outils Cryptographie"
    puts ""
    puts "2- Outils Reséaux"
    puts ""
    puts "3- Web"
        puts ""
        puts "4- Ip grabber"
        puts ""
        puts "5- Geolocalisation ip"
        puts ""
        puts "6- Mass attack"
    puts ""
    puts "7- License & contact"
    puts ""
    puts "8- Retour"
    puts ""
    print "   -> "
```

```
    option1 = gets_pb.chomp
    puts ""

    case option1
        when "1"
            puts "1- Base64 Encoder & Decoder"
             puts "2- Multi-Digest (MD5, SHA1, SHA256, SHA384, SHA512, RIPEMD-
160)"
             puts "3- Hash Password Cracker (MD5, SHA1, SHA256, SHA384, SHA512,
RIPEMD-160)"
            puts "4- Secure Password Generator"
            puts ""
            puts "0- Back"
            puts ""
            print "    -> "
            option2 = gets_pb.chomp
            case option2
                when "0"
                    module_exec = false
                when "1"
                    require "#{dir}/tools/cryptography/base64.rb"
                    Cryptogr_pb::Base64_pb.new()
                when "2"
                    require "#{dir}/tools/cryptography/digest.rb"
                    Cryptogr_pb::Digest_pb.new()
                when "3"
                    require "#{dir}/tools/cryptography/hash_cracker.rb"
                    Cryptogr_pb::Hash_cracker_pb.new()
                when "4"
                    require "#{dir}/tools/cryptography/sec_password.rb"
                    Cryptogr_pb::Sec_password_pb.new()
                else
                    module_exec = false
                    puts ""
                    puts "Invalide option."
                    puts ""
            end
        when "2"
            puts "1- Net DoS Tester"
            puts "2- TCP port scanner"
            puts "3- DPI_ker"
            puts "4- Fuzzer"
            puts "5- DNS and host gathering"
            puts "6- MAC address geolocalisation (samy.pl)"
            puts ""
            puts "0- Retour"
            puts ""
            print "    -> "
            option2 = gets_pb.chomp
```

```
            case option2
                when "0"
                    module_exec = false
                when "1"
                    if haspermission() == true
                        require "#{dir}/tools/network/net_dos.rb"
                        Network_pb::Net_dos_pb.new()
                    else
                        module_exec = false
                        puts ""
                            puts "Désolé, vous n'avez pas la permissions d'executer cet
outils (root?)."
                        puts ""
                    end
                when "2"
                    require "#{dir}/tools/network/port_scanner.rb"
                    Network_pb::Port_scanner_pb.new()
                when "3"
                    require "#{dir}/tools/network/ids_ips.rb"
                    Network_pb::Honeypot_pb.new()
                when "4"
                    require "#{dir}/tools/network/fuzzer.rb"
                    Network_pb::Fuzzer_pb.new()
                when "5"
                    require "#{dir}/tools/network/dns_search.rb"
                    Network_pb::DNS_search_pb.new()
                when "6"
                    require "#{dir}/tools/network/samy_mac_loc.rb"
                    Network_pb::Samy_mac_loc_pb.new()
                else
                    module_exec = false
                    puts ""
                    puts "Invalide option."
                    puts ""
            end
        when "3"
            puts "1- HTTP directory bruteforce"
            puts "2- HTTP common files bruteforce"
            puts ""
            puts "0- Retour"
            puts ""
            print "    -> "
            option2 = gets_pb.chomp
            case option2
                when "0"
                    module_exec = false
                when "1"
                    require "#{dir}/tools/web/http_brute_dir.rb"
                    Web_pb::HTTP_brute_dir_pb.new()
```

```
                when "2"
                    require "#{dir}/tools/web/http_brute_files.rb"
                    Web_pb::HTTP_brute_files_pb.new()
                else
                    module_exec = false
                    puts ""
                    puts "Invalide option."
                    puts ""
            end
        when "4"
module_exec = false
puts "

"
        when "5"
            module_exec = false
            Process.kill("SIGINT", Process.pid()) # Just exit.
        else
            module_exec = false
            puts ""
            puts "Option invalide."
             puts ""
    end
    if module_exec == true
        puts ""
        puts "[*] Exécution du module terminée."
        puts ""
    end
end
```

IV.7 CONCLUSION

Dans ce chapitre, nous avons décrit brièvement les fonctionnements de la solution, le schéma logique, les étapes d'installation et de configuration du programme, celui-ci est hybride ; ça peut fonctionner sous le noyau linux et MS-DOS. Ceci dans l'optique de renforcer la sécurité des systèmes d'informations des entreprises qui tourne autour du réseau administrer.

7. CONCLUSION GÉNÉRALE

La réalisation de ce travail de fin d'études, nous a permis d'améliorer nos connaissances et nos compétences dans le domaine de l'informatique précisément dans le réseau et la sécurité. En vue de l'obtention de ce dernier, nous avons opté comme sujet : étude des mesures de protection d'un système informatique pour prévenir les menaces et contrecarrer les attaques dues aux programmes malveillants. Cas EQuity BCDC

Certes, Dans le monde actuel où tout devient automatisé, l'administration, la connaissance du fonctionnement, la création et la configuration des réseaux informatiques parait indispensable pour tout entreprise. Elle permet aux entreprises de centraliser ses données, de travailler en coordination de manière productive et limiter les impressions papiers pour le transfert d'informations. Il permet aussi le traitement et la consultation des bases de données et une transmission rapide et fiable des données.

Pour mettre en œuvre ce projet, nous avons dans un premier temps passé en revue les généralités et les notions théorique relative à l'administration système et la sécurité du réseau informatique, fondamental pour la mise en œuvre de la solution proposée en Ruby pour la surveillance, prévention, détection et protection des activités.

C'est avec un réel enthousiasmé que nous nous sommes lancés dans ce projet. Ce dernier nous a permis d'avoir une idée très claire sur les services d'annuaire ainsi leur importance. L'élaboration de ce travail nous a permis d'une part d'approfondir les connaissances acquises durant les années d'études à l'université, et d'une autre part de préparer notre intégration à la vie professionnelle.

REFERENCES BIBLIOGRAPHIQUES

1. OUVRAGES

[1] P. Guy, Initiation aux reseaux, Eyrolles 7eme Editions, 2011.
[2] Botnet Spams 60 Billion Emails A Day, CyberInscure.com, 9 mai 2008
[3] J. Pillou, Tout sur les réseaux et Internet, DUNOD 2006.
[4] L. Bloch et C. wolfhugel, Eyrolles, 2eme Edition, 2005.
[5] TOM Thomas, La sécurité des reseaux, 2005.
[6] José DORDOIGNE, Réseau informatique, eni, février 2011.
[7] : Amarir hakim danes Adreen et Doffesidney, la protection des réseaux contre les attaques DoS, mai 2009.
[8] : H. N. Rasamimisa, A. H. rasolombo ahan jatovo « la sécurité dans les réseaux informatiques mémoire de fin d'études », dép-électropnique –ESPA, AU, 2004-2005.
[9] : Ric Vieler, professional rootkits, indianapolis, IN Wiley/wox, coll. "wrox professional guides", 2007, 334p.
[10] : Rakotama vonjatovo zina mahfarine, sécurisation des réseaux sous linux mémoire d'ingénier n° 06/EN/II/04, dép. électronique ESPA, 2003/2004.
[11] : J. Dressler, "Cases and Materials on Criminal Law", Thomson/West, 2007 « United States v. Morris »
[12] : H. NSENGE MPIA, « Sécurité Informatique », Institut Supérieur Emmanuel d"Alzon / Butembo, cours inédit, 2017.
[13] : LESCOP Yves, « Sécurité Informatique», 2002
[14] : Laurent BLOCH et Christophe WOLFHUGEL, « Sécurité informatique. Principes et méthode à l'usage des DSI, RSSI et administrateurs », 2e édition, Eyrolles, Paris, 2009.
[15] : Mark Allen Ludwig, « Naissance d'un virus : Technologie et principes fondamentaux », Diff. Bordas, 1993, 47 p
[16] : Peter Szor, "The Art of Computer Virus Research and Defense", Addison-Wesley Professional, 2005, 744 p
[17] : Greg Hoglund et James Butler; « Rootkits : infiltrations du noyau Windows », Paris, Campus Press, 2006 (1re éd. 2005), 338 p.
[18] : William Stallings, "Cryptography and Network Security: Principles and Practice", 3eme ed. Prentice Hall, 2003.
[19] : Documentation de l'Equity BCDC

2. NOTES DE COURS

[20] : Prof BOPE Christian, cours des réseaux informatiques, L2 informatique, UNIKIN 2020-2021
[21] : Prof KASENGEDIA MUTUMBE, cours de transmission de données et sécurité informatique, L2 Génie informatique, UNIKIN 2020-2021
[22] : Prof MUSESA LANDA Alain, cours de l'initiation a la recherche scientifique, G2 informatique, UNIKIN 20219-2020
[23] : Prof MUBENGA PASCAL, Cours de Droit Informatique, G3 Informatique, UNIKIN 2020-2021

[24] : Prof KASENGEDIA MUTUMBE, Cours de Téléphonie sur IP, L3 Informatique, UNIKIN 2022-2023
[25] : Prof MBUYI MUKENDI, Cours de Télématique, G3 Informatique, UNIKIN 2017-2018

3. TFE

[26] : Jean Christophe FORTON, Comment les réseaux informaticiques permettent-ils de garantir la sécurités d'information, Mémoire Master 2 University of Montréal/Canada
[27] : Christian DEMBA, Etudes des menaces, services et mécanismes de sécurité informatique utilisés dans les réseaux sociaux. Cas de WHATSAPP, TFE L2 Génie Info/UNIKIN 2020-2021
[28] : MAKENGO MEBENE, Sécurisation d'un système informatique dans une entreprise à l'aide de l'authentification radius « cas de inspirat technology sarl, TFE L2 Génie Info/UNIKIN, 2019-2020.
[29] : Jacon NDWO MAYELE, Deploiement d'un réseaux IP/MPLS. Cas de la BCC, TFE L2 Génie Info/UNIKIN 2016.

4. WEBOGRAPHIE

[30] : http://Etude de securité réseau et mise emplace d'un système de détection d'intrusion sous linux (2018).
[31] : http://www.sunrise.net/fr/home/home.htm(2017).
[32] : http://www.Commentcamarche.net/contents/initiation(2017).
[33] : http://www.google.com/service et sécurité dans les réseaux de nouvelle génération/ (2017).
[34] : http://www .Funinformatique.com (2022). Logiciels malveillants
[35] : http://fr.m.Wikipédia.org/wiki/Internet Exchange Point.
[36] : http://www.horloge-huchez.fr/blog/5-avantages-le contrôle d'accès-horaire entreprise consulté le 27/05/2020
[37] : http://fr.m.Wikipédia.org/wiki/XMPP
[38] : http://www.Securiteinfo.com (2004). Attaques du système d'exploitation

TABLE DES MATIERES

ÉPIGRAPHE i
IN MEMORIAM ii
DEDICACES iii
REMERCIEMENTS iv
LISTE DES ACRONYMES vi
LISTE DES FIGURES ix
INTRODUCTION GENERALE 1
1. HYPOTHESE 1
2. CHOIX ET INTERET DU SUJET 2
4. TECHNIQUES DE RECHERCHE 3
5. DELIMITATION 3
6. LE CANEVAS DU TRAVAIL 3
CHAPITRE I. SECURITE INFORMATIQUE [7] [8] [12] [13] [14] [21 [30] [38] 4
I.1 LA SECURITE INFORMATIQUE SELON ISO [12] [21] 4
I.1.1 Introduction 4
I.1.2 Les menaces de sécurité 4
Du point de vue de la sécurité informatique, une menace est une violation potentielle de la sécurité. Cette menace peut être accidentelle ou intentionnelle (attaque), active ou passive. 4
I.1.3 Types de menaces 4
I.1.3.1.1 Menace passive 4
I.1.3.1.2 Menace active 5
I.1.3.2 Vulnérabilité [14] 6
I.1.3.3 Risque de sécurité[14] 6
I.1.3.4 Pirate Informatique [30] 7
I.1.3.4.1 Hacker et cracker [14] 7
I.1.3.4.2 Objectifs des attaquants[38] 7
I.1.3.4.3 Compétences et moyens des attaquants [38] 7
I.1.3.5 Attaques de sécurité [38] 8
Quatrième classification 9
I.1.3.5.1 Les principales attaques [30] [38] 9

3. Le scan basé sur le RFC 12
I.1.4 SERVICES DE SECURITE [12] [21] 14
I.1.4.1 L'Authentification 15
I.1.4.2 Le Contrôle d'accès 15
I.1.4.3 La Confidentialité des données 15
I.1.4.4 L'intégrité des données 15
I.1.4.5 La non-répudiation 15
I.1.4.6 La disponibilité 16
I.1.5 LES MECANISMES DE SECURITE [12][14] 16
I.1.5.1 Mécanisme qui assume L'authentification 16
I.1.5.2 Mécanisme qui assume Le contrôle d'accès 16
I.1.5.2.1 La gestion de l'accès utilisateur 16
I.1.5.2.2 Le contrôle de l'accès au système et à l'information 16
I.1.5.3 Le Mécanisme qui assume La confidentialité de données 17
I.1.5.3.1 La Cryptographie [14] [18] 17
I.1.5.4 Mécanisme qui assume L'intégrité de données [14] 21
I.1.5.4.1 Firewall 21
I.1.5.5 Mécanisme qui assume La non répudiation 21
Mécanisme de non-répudiation est un mécanisme dont l'objectif est de ne pas permettre aux correspondants de nier la participation à un échange d'informations. 21
I.1.5.5.1 Signature numérique 21
I.1.5.6 Mécanisme qui assume La disponibilité 23
I.1.5.6.1 RAID (Redundant Array of Independent DISKS) 23
CHAPITRE II. PROGRAMMES MALVEILLANTS ET MESURES DES PROTECTIONS 24
II.1 PROGRAMMES MALVEILLANTS [15] [16] [34] 24
II.1.1 Définition 24
II.1.2 Classification du programme malveillants 24
II.1.2.1 LES VIRUS INFORMATIQUES [16] 25
II.1.2.1.1 CARACTERISTIQUES DES VIRUS 26
II.1.2.1.2 CLASSIFICATION DES VIRUS 26
II.1.2.1.3 ARCHITECTURE D'UN VIRUS 28
II.1.2.1.4 MODE DE CONTAMINATION D'UN VIRUS 29

II.1.2.1.5 CYCLE DE VIE D'UN VIRUS 30
II.1.2.2 LES VERS INFORMATIQUES [35] 30
II.1.2.2.1 Les Objectif malfaisant d'un ver informatique 30
II.1.2.2.2 CARACTERISTIQUE D'UN VER INFORMATIQUE 31
II.1.2.2.3 CLASSIFICATION D'UN VER INFORMATIQUE [11] 32
II.1.2.2.4 ARCHITECTURE D'UN VER INFORMATIQUE 32
II.1.2.2.5 MODE DE REPRODUCTION D'UN VER 33
II.1.2.3 LE CHEVAL DE TROIE [15][35] 34
II.1.2.3.1 MANIFESTIONS D'UNE INFECTION PAR UN CHEVAL DE TROIE 35
II.1.2.4 LES ROOTKITS [2] [17] 36
II.1.2.4.1 TYPES DES ROOTKITS 36
II.1.2.4.2 MODE OPERATOIRE D'UN ROOTKIT 36
II.1.2.5 LES PORTES DEROBEES [2] 37
II.1.2.5.1 TECHNIQUES UTILISEES 37
II.1.2.6 ESPIONAGE INFORMATIQUE 38
II.1.2.6.1 L'HOMME DU MILIEU 38
II.2 MESURES DES PROTECTIONS [5] [12] [13] [14] [21] [30] 39
II.2.1 LES ANTI-VIRUS [30] 39
II.2.1.1 FONCTIONNEMENT DE L'ANTI-VIRUS 39
II.2.1.2 TECHNIQUES DE DETECTION DES ANTI-VIRUS 40
II.2.2 LES SYSTÈMES DE DÉTECTION ET DE PRÉVENTION [30] [33] 40
II.2.2.1 SYSTEMES DE DÉTECTION D'INTRUSION 41
II.2.2.1.1 Les systèmes de détection d'intrusion en réseau (NIDS) 41
II.2.2.1.2 Système de détection d'intrusion basé sur Hôte(HIDS) 42
II.2.2.1.3 Les IDS hybride 42
II.2.2.2 LES FIREWALLS (PARE-FEU) [12] [14] 45
II.2.2.2.1 PRINCIPES DE FONCTIONNEMENT DE PARE-FEU 46
II.2.2.3 LE CONTRÔLE D'ACCÈS [13] [34] 49
II.2.2.3.1 Définition du contrôle d'accès 49
II.2.2.3.2 Différents types de contrôle d'accès 49
II.2.2.3.3 Le Fonctionnement du contrôle d'accès 50
II.2.2.4 L'AUTHENTIFICATION [34] 50

II.2.2.4.1 Définition 50
 Technologies pour l'authentification forte 51
CHAPITRE III. ETUDE DE L'EXISTANT (L'Equity BCDC) [19] 54
III.1 INTRODUCTION 54
III.2 PRESENTATION DE LA BCDC [19] 54
III.2.1 Historique 54
III.2.2 SITUATION GEOGRAPHIQUE 56
III.2.3 MISSION ET OBJETIFS 56
III.2.4 STRUCTURE FONCTIONNELLE [19] 57
III.2.4.1 Le réseau d'agences d'EQuity BCDC en RDC 57
III.2.5 ORGANIGRAMME 61
III.2.6 ETUDE DE L'EXISTANT [19] 61
III.2.6.1 Réseaux Informatiques et Interconnexion 61
III.2.6.2 Type de Matériels 62
III.2.6.3 Protocole cœur 62
III.2.6.4 Protocoles d'accès 62
III.2.6.5 Topologie 62
III.2.6.6 Architecture 63
III.2.6.7 Le Backbone de la Banque 63
III.2.6.8 Mécanismes de sécurité 64
III.2.6.8.1 Les contrôles d'accès constitués de filtrages de paquets (pare-feu) et de relais applicatifs (proxy) 65
III.2.6.8.2 Les contrôles d'authentification des utilisateurs 65
III.2.6.8.3 Le mécanisme de Contrôle de l'accès au réseau 65
III.2.6.8.4 Réseau virtuel privé de l'Equity BCDC 66
III.2.7 CRITIQUE DE L'EXISTANT 67
III.2.7.1 Critique sur les moyens humains 67
III.2.7.2 Critique sur les moyens matériels 67
III.2.8 PROPOSITIONS DE SOLUTION ET RECOMMANDATION 68
III.2.8.1 Proposition de solution 68
III.2.8.2 Préparations pour l'évolution du Système Informatique 68
III.2.8.3 Déploiement de l'outil dans le réseau 68

III.2.8.4 Le Recommandation 68
CHAPITRE IV. DEPLOIEMENT DE L'OUTIL DANS LE RESEAU 70
IV.1 INTROUCTION 70
IV.2 ARCHITECTURE PROPOSER POUR L'ENTREPRISE 71
IV.3 SCHEMA LOGIQUE 72
IV.4 ATTAQUES TYPIQUES ET EFFET CONCOMITTANT 74
IV.5 PRINCIPE DE FONCTIONNEMENT 74
IV.6 CODE SOURCE 78
IV.7 CONCLUSION 83
7. CONCLUSION GÉNÉRALE 84
REFERENCES BIBLIOGRAPHIQUES 85